



**Cyber Security (CYBER); CRA;
Cybersecurity requirements for physical and
virtual network interfaces**

Reference

DEN/CYBER-EUS-0017

Keywords

CRA, cybersecurity, interface

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.
In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information; or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part of this document may be reproduced in any form, by any means and in any media, without the prior written authorization of ETSI and except as expressly permitted below.

By way of exception and when the document is a normative deliverable (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)), ETSI authorizes to reproduce and incorporate into products, services and technical documentation only those extracts (e.g. templates) that are strictly necessary for the technical implementation of the normative deliverable, to ensure compliance with the latter. Nothing in this notice shall be construed as limiting any mandatory exceptions to copyright provided by applicable law.

© ETSI 2026.
All rights reserved.

Contents

Intellectual Property Rights	15
Foreword.....	15
Modal verbs terminology.....	16
Introduction	16
1 Scope	17
2 References	17
2.1 Normative references	17
2.2 Informative references.....	18
3 Definition of terms, symbols and abbreviations.....	19
3.1 Terms.....	19
3.2 Symbols.....	20
3.3 Abbreviations	20
4 Product context.....	20
4.0 Introduction	20
4.1 Product Functions.....	21
4.1.1 Physical network interface product functions	21
4.1.2 Device driver product functions.....	22
4.1.3 Virtual network interface product functions	22
4.2 Product Architecture.....	22
4.2.1 Overview	22
4.2.2 Types of network interface	22
4.2.3 Device drivers for network interfaces	24
4.3 Operational Environment	25
4.3.1 General description.....	25
4.3.2 Physical/Hardware environment.....	25
4.3.3 Logical/Software environment.....	25
4.3.4 Connectivity aspects	26
4.4 Distribution of Security Functions	26
4.4.1 General.....	26
4.4.2 Security functions provided outside the product.....	26
4.4.3 Security functions provided to other components.....	26
4.5 Users.....	27
4.6 Use Cases	27
4.6.1 Introduction.....	27
4.6.1.1 Overview	27
4.6.1.2 Guidance	28
4.6.2 Use case descriptions	28
4.6.2.1 UC-VI-ISO: Virtual interface for research within a host system	28
4.6.2.2 UC-PH-VNI: Vending machine internal network.....	28
4.6.2.3 UC-PH-VNC: Vending machine, remotely managed	29
4.6.2.4 UC-PH-IOT: Physical network interface for home IoT	29
4.6.2.5 UC-PH-IRO: Intranet router.....	29
4.6.2.6 UC-PH-EDG: Edge router	30
4.6.2.7 UC-PH-HRO: Home router in filtered network	30
4.6.2.8 UC-PH-ISP: ISP access point	30
4.6.2.9 UC-VI-VDC: Virtualize data centre	31
4.6.2.10 UC-VI-VMW: VM on multi-tenant web server.....	31
4.6.2.11 UC-VI-VMC: Virtualize critical server	31
4.6.2.12 UC-VI-VII: Virtual interface for integrators.....	32
4.6.2.13 UC-PH-SMW: Smart watch.....	32
4.6.2.14 UC-PH-SME: Smart meter	33
4.6.2.15 UC-PH-ATM: ATM.....	33
4.6.2.16 UC-PH-SPI: Solar panel inverter	33
4.6.2.17 UC-VI-VPN: Consumer VPN.....	34

4.6.2.18	UC-PH-MOB: Mobile phone or tablet.....	34
4.6.2.19	UC-PH-GPI: General purpose integrated.....	34
4.6.2.20	UC-PH-USB: External USB	35
4.6.2.21	UC-PH-STA: Standalone.....	35
4.6.2.22	UC-PH-SNS: Remote Sensor.....	35
5	Technical requirements for products.....	36
5.1	Introduction	36
5.1.1	Applicability of the requirements	36
5.1.2	Applicability of Annex K	36
5.1.3	Applicability of Annex R.....	36
5.1.4	Guidance for "cybersecurity-relevant".....	36
5.2	Appropriate level of cybersecurity	37
5.2.1	Overview	37
5.2.1.1	CRA Relevance.....	37
5.2.2	REQ-ALC-01 Resilience to potentially untrusted inputs.....	37
5.2.2.1	Requirement	37
5.2.2.2	Applicability.....	37
5.2.3	Mapping of requirements to use cases	38
5.3	No known exploitable vulnerabilities.....	38
5.3.1	Overview	38
5.3.2	REQ-KEV-01 No known exploitable vulnerabilities	38
5.3.2.1	Requirement	38
5.3.2.2	Applicability.....	38
5.3.2.3	Guidance	39
5.3.3	Mapping of requirements to use cases	40
5.4	Secure by default configuration.....	40
5.4.1	Overview	40
5.4.2	REQ-SBD-01: Provide methods to protect or disable interfaces.....	40
5.4.2.1	Requirement	40
5.4.2.2	Applicability.....	40
5.4.2.3	Guidance	41
5.4.3	REQ-SBD-02: Protect or disable access to debug or management interfaces	41
5.4.3.1	Requirement	41
5.4.3.2	Applicability.....	41
5.4.3.3	Guidance	42
5.4.4	Mapping of requirements to use cases	42
5.5	Security updates	42
5.5.1	Overview	42
5.5.2	REQ-SU-01: Secure update provided by operational environment	43
5.5.2.1	Requirement	43
5.5.2.2	Applicability.....	43
5.5.3	Mapping of requirements to use cases	44
5.6	Authentication and access control.....	44
5.6.1	Overview	44
5.6.2	REQ-AAC-01: Authentication and access control provided by operational environment.....	44
5.6.2.1	Requirement	44
5.6.2.2	Applicability.....	44
5.6.3	Mapping of requirements to use cases	45
5.7	Confidentiality protection.....	46
5.7.1	Overview	46
5.7.2	REQ-CP-01: Confidentiality protection provided by operational environment.....	46
5.7.2.1	Requirement	46
5.7.2.2	Applicability.....	46
5.7.2.3	Guidance	47
5.7.3	Mapping of requirements to use cases	47
5.8	Integrity protection	47
5.8.1	Overview	47
5.8.2	REQ-IP-01: Integrity protection provided by operational environment	47
5.8.2.1	Requirement	47
5.8.2.2	Applicability.....	47
5.8.3	Mapping of requirements to use cases	48

5.9	Data minimisation	49
5.9.1	Overview	49
5.9.2	REQ-DM-01: Data minimisation.....	49
5.9.2.1	Requirement	49
5.9.2.2	Applicability.....	49
5.9.3	Mapping of requirements to use cases	50
5.10	Availability protection.....	50
5.10.1	Overview	50
5.10.2	REQ-AP-01 Fast packet drop	50
5.10.2.1	Requirement	50
5.10.2.2	Applicability.....	50
5.10.2.3	Guidance	51
5.10.3	REQ-AP-02 Limit resource usage by incoming network data.....	51
5.10.3.1	Requirement	51
5.10.3.2	Applicability.....	51
5.10.4	REQ-AP-03 Availability protection provided by operational environment.....	52
5.10.4.1	Requirement	52
5.10.4.2	Applicability.....	52
5.10.5	REQ-AP-04: Watchdog and notification of host	53
5.10.5.1	Requirement	53
5.10.5.2	Applicability.....	53
5.10.6	REQ-AP-05: Watchdog and self-initiated reset.....	54
5.10.6.1	Requirement	54
5.10.6.2	Applicability.....	54
5.10.7	Mapping of requirements to use cases	55
5.11	Non-interference.....	55
5.11.1	Overview	55
5.11.2	REQ-NI-01: Minimise data transmitted to unverified sources	55
5.11.2.1	Requirement	55
5.11.2.2	Applicability.....	55
5.11.2.3	Guidance	56
5.11.3	Mapping of requirements to use cases	57
5.12	Attack surface minimisation.....	57
5.12.1	Overview	57
5.12.2	REQ-ASM-01: Minimise attack surface.....	57
5.12.2.1	Requirement	57
5.12.2.2	Applicability.....	57
5.12.3	Mapping of requirements to use cases	58
5.13	Exploit mitigation.....	58
5.13.1	Overview	58
5.13.2	Requirements	58
5.13.3	Mapping of requirements to use cases	59
5.14	Monitoring.....	59
5.14.1	Overview	59
5.14.2	REQ-MON-01: Logging.....	59
5.14.2.1	Requirement	59
5.14.2.2	Applicability.....	59
5.14.3	Mapping of requirements to use cases	60
5.15	Factory reset and data portability	60
5.15.1	Overview	60
5.15.2	REQ-SDT-01 Secure deletion.....	61
5.15.2.1	Requirement	61
5.15.2.2	Applicability.....	61
5.15.3	REQ-SDT-02 Secure data read provided by operational environment.....	62
5.15.3.1	Requirement	62
5.15.3.2	Applicability.....	62
5.15.4	Mapping of requirements to use cases	63
6	Assessment criteria for compliance with technical requirements	63
6.1	Introduction to the assessment and compliance criteria	63
6.1.1	General.....	63
6.1.2	Guidance for identifying interfaces or data processing.....	65

6.2	Appropriate level of cybersecurity	65
6.2.1	Overview	65
6.2.2	REQ-ALC-01 Resilience to potentially untrusted inputs.....	65
6.2.2.1	Objective	65
6.2.2.2	Preparation	66
6.2.2.3	Activities	67
6.2.2.4	Verdict.....	67
6.2.2.5	Evidence.....	67
6.2.2.6	Guidance	67
6.3	No known exploitable vulnerabilities.....	68
6.3.1	Overview	68
6.3.2	REQ-KEV-01 No known exploitable vulnerabilities	68
6.3.2.1	Objective	68
6.3.2.2	Preparation	68
6.3.2.3	Activities	68
6.3.2.4	Verdict.....	68
6.3.2.5	Evidence.....	68
6.3.2.6	Guidance	69
6.4	Secure by default configuration.....	69
6.4.1	Overview	69
6.4.2	REQ-SBD-01: Provide methods to protect or disable interfaces.....	69
6.4.2.1	Objective	69
6.4.2.2	Preparation	69
6.4.2.3	Activities	69
6.4.2.4	Verdict.....	69
6.4.2.5	Evidence.....	70
6.4.2.6	Guidance	70
6.4.3	REQ-SBD-02: Protect or disable access to debug or management interfaces	70
6.4.3.1	Objective	70
6.4.3.2	Preparation	70
6.4.3.3	Activities	70
6.4.3.4	Verdict.....	70
6.4.3.5	Evidence.....	71
6.5	Security updates	71
6.5.1	Overview	71
6.5.2	REQ-SU-01 Secure update provided by operational environment	71
6.5.2.1	Objective	71
6.5.2.2	Preparation	71
6.5.2.3	Activities	71
6.5.2.4	Verdict.....	71
6.5.2.5	Evidence.....	71
6.5.2.6	Guidance	72
6.6	Authentication and access control.....	72
6.6.1	Overview	72
6.6.2	REQ-AAC-01: Authentication and access control provided by operational environment.....	72
6.6.2.1	Objective	72
6.6.2.2	Preparation	72
6.6.2.3	Activities	72
6.6.2.4	Verdict.....	72
6.6.2.5	Evidence.....	72
6.7	Confidentiality protection.....	72
6.7.1	Overview	72
6.7.2	REQ-CP-01: Confidentiality protection provided by operational environment.....	73
6.7.2.1	Objective	73
6.7.2.2	Preparation	73
6.7.2.3	Activities	73
6.7.2.4	Verdict.....	73
6.7.2.5	Evidence.....	73
6.7.2.6	Guidance	73
6.8	Integrity protection.....	74
6.8.1	Overview	74
6.8.2	REQ-IP-01: Integrity protection provided by operational environment	74

6.8.2.1	Objective	74
6.8.2.2	Preparation	74
6.8.2.3	Activities	74
6.8.2.4	Verdict.....	74
6.8.2.5	Evidence.....	74
6.8.2.6	Guidance	74
6.9	Data minimisation	75
6.9.1	Overview	75
6.9.2	REQ-DM-01: Minimise data processed.....	75
6.9.2.1	Objective	75
6.9.2.2	Preparation	75
6.9.2.3	Activities	75
6.9.2.4	Verdict.....	75
6.9.2.5	Evidence.....	75
6.9.2.6	Guidance	76
6.10	Availability protection.....	76
6.10.1	Overview	76
6.10.2	REQ-AP-01 Fast packet drop	76
6.10.2.1	Objective	76
6.10.2.2	Preparation	76
6.10.2.3	Activities	76
6.10.2.4	Verdict.....	76
6.10.2.5	Evidence.....	77
6.10.2.6	Guidance	77
6.10.3	REQ-AP-02 Limit resource usage by incoming network data.....	77
6.10.3.1	Objective	77
6.10.3.2	Preparation	77
6.10.3.3	Activities	77
6.10.3.4	Verdict.....	77
6.10.3.5	Evidence.....	77
6.10.3.6	Guidance	78
6.10.4	REQ-AP-03 Availability protection provided by operational environment.....	78
6.10.4.1	Objective	78
6.10.4.2	Preparation	78
6.10.4.3	Activities	78
6.10.4.4	Verdict.....	78
6.10.4.5	Evidence.....	79
6.10.4.6	Guidance	79
6.10.5	REQ-AP-04: Watchdog and notification of host	79
6.10.5.1	Objective	79
6.10.5.2	Preparation	79
6.10.5.3	Activities	79
6.10.5.4	Verdict.....	79
6.10.5.5	Evidence.....	79
6.10.5.6	Guidance	79
6.10.6	REQ-AP-05: Watchdog and self-initiated reset.....	79
6.10.6.1	Objective	79
6.10.6.2	Preparation	80
6.10.6.3	Activities	80
6.10.6.4	Verdict.....	80
6.10.6.5	Evidence.....	80
6.11	Non-interference.....	80
6.11.1	Overview	80
6.11.2	REQ-NI-01: Minimise data transmitted to unverified sources	80
6.11.2.1	Objective	80
6.11.2.2	Preparation	80
6.11.2.3	Activities	80
6.11.2.4	Verdict.....	80
6.11.2.5	Evidence.....	81
6.12	Attack surface minimisation.....	81
6.12.1	Overview	81
6.12.2	REQ-ASM-01: Minimise attack surface.....	81

6.12.2.1	Objective	81
6.12.2.2	Preparation	81
6.12.2.3	Activities	81
6.12.2.4	Verdict.....	81
6.12.2.5	Evidence.....	81
6.12.2.6	Guidance	82
6.13	Exploit mitigation.....	82
6.13.1	Overview	82
6.14	Monitoring.....	82
6.14.1	Overview	82
6.14.2	REQ-MON-01 Logging.....	82
6.14.2.1	Objective	82
6.14.2.2	Preparation	82
6.14.2.3	Activities	82
6.14.2.4	Verdict.....	82
6.14.2.5	Evidence.....	83
6.14.2.6	Guidance	83
6.15	Factory reset and data portability	83
6.15.1	Overview	83
6.15.2	REQ-SDT-01 Secure deletion.....	83
6.15.2.1	Objective	83
6.15.2.2	Preparation	83
6.15.2.3	Activities	83
6.15.2.4	Verdict.....	84
6.15.2.5	Evidence.....	84
6.15.2.6	Guidance	84
6.15.3	REQ-SDT-02 Secure data read provided by operational environment	84
6.15.3.1	Objective	84
6.15.3.2	Preparation	84
6.15.3.3	Activities	84
6.15.3.4	Verdict.....	84
6.15.3.5	Evidence.....	85

Annex A (informative):	Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847.....	86
-------------------------------	--	-----------

Annex B (informative):	Security analysis.....	89
-------------------------------	-------------------------------	-----------

B.0	Overview	89
B.1	Assets	89
B.1.1	Data	89
B.1.2	Product functions.....	89
B.1.2.1	Physical network interface essential functions.....	89
B.1.2.2	Device driver essential functions	90
B.1.2.3	Virtual network interface essential functions.....	90
B.1.3	Hardware	91
B.2	Risk factors.....	91
B.2.1	List of risk factors.....	91
B.2.2	[RF-PHY] Physical access to product	91
B.2.3	[RF-NET] Access to attached network.....	91
B.2.4	[RF-COM] Complexity of product functions	91
B.2.5	[RF-HOS] Impact of access to host system assets.....	92
B.2.6	[RF-FUN] Sensitivity of functions of product	92
B.2.7	[RF-ADM] Availability and skill of administration	92
B.2.8	[RF-INI] Operational environment of initial setup.....	93
B.3	Assumptions	93
B.3.1	Overview	93
B.3.2	Proper host system.....	93
B.3.3	Proper administrator.....	93
B.3.4	Attacker has limited physical access to product	93

B.3.5	Attacker has limited resources.....	93
B.4	Threats and security analysis of threats.....	93
B.4.1	General	93
B.4.2	Security analysis methodology.....	94
B.4.3	List of threats, risk assessments, and mitigations	94
B.4.3.1	TH-UEVU: Unknown exploitable vulnerabilities	94
B.4.3.2	TH-KEVU: Known exploitable vulnerabilities	95
B.4.3.3	TH-DSTP: Compromise of data stored on product.....	95
B.4.3.4	TH-CONF: Access to assets via configuration errors.....	96
B.4.3.5	TH-UADT: Unauthorized access to data transmitted	97
B.4.3.6	TH-AVAI: Denial of service attack on product.....	98
B.4.3.7	TH-DDOS: Interference with other devices	99
B.5	Mapping of use cases to risk factors	100
B.6	Mapping of threats to requirements.....	100
B.7	Risks not treated by the requirements	100

Annexes C to

J:	Void
.....	101

Annex K (normative): Generic cryptographic requirements and assessment.....102

K.1	Cryptography.....	102
K.1.1	Requirement	102
K.1.2	Assessment of product cryptographic configuration	102
K.1.2.1	General.....	102
K.1.2.2	Assessment of ACM-listed cryptographic mechanisms.....	103
K.1.2.2.1	Assessment objective	103
K.1.2.2.2	Assessment preparation.....	103
K.1.2.2.3	Assessment activities	103
K.1.2.2.4	Assessment evidence.....	103
K.1.2.2.5	Assessment verdict.....	103
K.1.2.3	Assessment of ACM-extended cryptographic mechanisms.....	104
K.1.2.3.1	Assessment objective	104
K.1.2.3.2	Assessment preparation.....	104
K.1.2.3.3	Assessment activities	104
K.1.2.3.4	Assessment evidence.....	104
K.1.2.3.5	Assessment verdict.....	105
K.1.2.4	Assessment of interoperability-based cryptographic mechanisms.....	105
K.1.2.4.1	Assessment objective	105
K.1.2.4.2	Assessment preparation.....	105
K.1.2.4.3	Assessment activities	105
K.1.2.4.4	Assessment evidence.....	105
K.1.2.4.5	Assessment verdict.....	106
K.2	Crypto agility.....	106
K.2.1	Requirement	106
K.2.2	Assessment of crypto-agility	106
K.2.2.1	Assessment objective.....	106
K.2.2.2	Assessment preparation	106
K.2.2.3	Assessment activities	107
K.2.2.4	Assessment evidence	107
K.2.2.5	Assessment verdict	107
K.3	ACM-extended cryptographic mechanisms	107
K.3.1	Requirement	107
K.3.2	List of ACM-extended cryptographic mechanisms.....	108
K.3.3	Assessment.....	112
K.4	Interoperability-based cryptographic mechanisms.....	112
K.4.1	Requirement	112

K.4.2	List of interoperability-based cryptographic mechanisms	113
K.4.3	Assessment	114

Annexes L to

Q:	Void
.....	115

Annex R (normative): Remote Data Processing Solutions116

R.1	Scope & Applicability	116
R.2	RDPS as a product-boundary extension	116
R.3	Threat Model	117
R.3.1	Introduction	117
R.3.2	Assets	117
R.3.3	Threat catalogue	118
R.3.3.1	Overview	118
R.3.3.2	T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary	118
R.3.3.3	T-RDPS-02 Loss of integrity of interactions across the RDPS boundary	118
R.3.3.4	T-RDPS-03 Unauthorized disclosure of interactions across the RDPS boundary	119
R.3.3.5	T-RDPS-04 Degradation of interactions across the RDPS boundary	119
R.3.4	Assets to Threats mapping	119
R.4	Security Requirements	119
R.4.1	General and guidance for requirement-structure selection	119
R.4.2	Applicability of Annex R requirements	120
R.4.3	Local product side requirements	121
R.4.3.1	REQ-RDPS-L-AUTH-001	121
R.4.3.2	REQ-RDPS-L-AUTH-002	121
R.4.3.3	REQ-RDPS-L-AUTH-003	121
R.4.3.4	REQ-RDPS-L-INTEG-001	121
R.4.3.5	REQ-RDPS-L-INTEG-002	122
R.4.3.6	REQ-RDPS-L-INTEG-003	122
R.4.3.7	REQ-RDPS-L-CONF-001	122
R.4.3.8	REQ-RDPS-L-CONF-002	122
R.4.3.9	REQ-RDPS-L-CONF-003	123
R.4.3.10	REQ-RDPS-L-AVAIL-001	123
R.4.3.11	REQ-RDPS-L-AVAIL-002	123
R.4.3.12	REQ-RDPS-L-AVAIL-003	124
R.4.4	RDPS side requirements	124
R.4.4.1	REQ-RDPS-R-AUTH-001	124
R.4.4.2	REQ-RDPS-R-AUTH-002	124
R.4.4.3	REQ-RDPS-R-AUTH-003	124
R.4.4.4	REQ-RDPS-R-INTEG-001	125
R.4.4.5	REQ-RDPS-R-INTEG-002	125
R.4.4.6	REQ-RDPS-R-INTEG-003	125
R.4.4.7	REQ-RDPS-R-CONF-001	125
R.4.4.8	REQ-RDPS-R-CONF-002	126
R.4.4.9	REQ-RDPS-R-CONF-003	126
R.4.4.10	REQ-RDPS-R-AVAIL-001	126
R.4.4.11	REQ-RDPS-R-AVAIL-002	126
R.4.4.12	REQ-RDPS-R-AVAIL-003	127
R.4.5	Threats ↔ Requirements mapping	127
R.5	Conformity assessment	128
R.5.1	Overview	128
R.5.2	Applicability	128
R.5.3	Local product side requirements	128
R.5.3.1	Assessment case for REQ-RDPS-L-AUTH-001	128
R.5.3.1.1	Objective	128
R.5.3.1.2	Preparation	128
R.5.3.1.3	Activities	128
R.5.3.1.4	Verdict	128

R.5.3.1.5	Evidence.....	129
R.5.3.2	Assessment case for REQ-RDPS-L-AUTH-002	129
R.5.3.2.1	Objective	129
R.5.3.2.2	Preparation	129
R.5.3.2.3	Activities	129
R.5.3.2.4	Verdict.....	129
R.5.3.2.5	Evidence.....	130
R.5.3.3	Assessment case for REQ-RDPS-L-AUTH-003	130
R.5.3.3.1	Objective	130
R.5.3.3.2	Preparation	130
R.5.3.3.3	Activities	130
R.5.3.3.4	Verdict.....	130
R.5.3.3.5	Evidence.....	131
R.5.3.4	Assessment case for REQ-RDPS-L-INTEG-001.....	131
R.5.3.4.1	Objective	131
R.5.3.4.2	Preparation	131
R.5.3.4.3	Activities	131
R.5.3.4.4	Verdict.....	131
R.5.3.4.5	Evidence.....	131
R.5.3.5	Assessment case for REQ-RDPS-L-INTEG-002.....	132
R.5.3.5.1	Objective	132
R.5.3.5.2	Preparation	132
R.5.3.5.3	Activities	132
R.5.3.5.4	Verdict.....	132
R.5.3.5.5	Evidence.....	132
R.5.3.6	Assessment case for REQ-RDPS-L-INTEG-003.....	133
R.5.3.6.1	Objective	133
R.5.3.6.2	Preparation	133
R.5.3.6.3	Activities	133
R.5.3.6.4	Verdict.....	133
R.5.3.6.5	Evidence.....	133
R.5.3.7	Assessment case for REQ-RDPS-L-CONF-001	134
R.5.3.7.1	Objective	134
R.5.3.7.2	Preparation	134
R.5.3.7.3	Activities	134
R.5.3.7.4	Verdict.....	134
R.5.3.7.5	Evidence.....	134
R.5.3.8	Assessment case for REQ-RDPS-L-CONF-002.....	134
R.5.3.8.1	Objective	134
R.5.3.8.2	Preparation	135
R.5.3.8.3	Activities	135
R.5.3.8.4	Verdict.....	135
R.5.3.8.5	Evidence.....	135
R.5.3.9	Assessment case for REQ-RDPS-L-CONF-003	135
R.5.3.9.1	Objective	135
R.5.3.9.2	Preparation	135
R.5.3.9.3	Activities	136
R.5.3.9.4	Verdict.....	136
R.5.3.9.5	Evidence.....	136
R.5.3.10	Assessment case for REQ-RDPS-L-AVAIL-001	136
R.5.3.10.1	Objective	136
R.5.3.10.2	Preparation	136
R.5.3.10.3	Activities	137
R.5.3.10.4	Verdict.....	137
R.5.3.10.5	Evidence.....	137
R.5.3.11	Assessment case for REQ-RDPS-L-AVAIL-002	137
R.5.3.11.1	Objective	137
R.5.3.11.2	Preparation	137
R.5.3.11.3	Activities	137
R.5.3.11.4	Verdict.....	138
R.5.3.11.5	Evidence.....	138
R.5.3.12	Assessment case for REQ-RDPS-L-AVAIL-003	138

R.5.3.12.1	Objective	138
R.5.3.12.2	Preparation	138
R.5.3.12.3	Activities	138
R.5.3.12.4	Verdict.....	139
R.5.3.12.5	Evidence.....	139
R.5.4	RDPS side requirements	139
R.5.4.1	Assessment case for REQ-RDPS-R-AUTH-001.....	139
R.5.4.1.1	Objective	139
R.5.4.1.2	Preparation.....	139
R.5.4.1.3	Activities	139
R.5.4.1.4	Verdict	140
R.5.4.1.5	Evidence	140
R.5.4.2	Assessment case for REQ-RDPS-R-AUTH-002.....	140
R.5.4.2.1	Objective	140
R.5.4.2.2	Preparation.....	140
R.5.4.2.3	Activities	140
R.5.4.2.4	Verdict	141
R.5.4.2.5	Evidence	141
R.5.4.3	Assessment case for REQ-RDPS-R-AUTH-003.....	141
R.5.4.3.1	Objective	141
R.5.4.3.2	Preparation.....	141
R.5.4.3.3	Activities	141
R.5.4.3.4	Verdict	142
R.5.4.3.5	Evidence	142
R.5.4.4	Assessment case for REQ-RDPS-R-INTEG-001.....	142
R.5.4.4.1	Objective	142
R.5.4.4.2	Preparation.....	142
R.5.4.4.3	Activities	142
R.5.4.4.4	Verdict	142
R.5.4.4.5	Evidence	143
R.5.4.5	Assessment case for REQ-RDPS-R-INTEG-002.....	143
R.5.4.5.1	Objective	143
R.5.4.5.2	Preparation.....	143
R.5.4.5.3	Activities	143
R.5.4.5.4	Verdict	143
R.5.4.5.5	Evidence	144
R.5.4.6	Assessment case for REQ-RDPS-R-INTEG-003.....	144
R.5.4.6.1	Objective	144
R.5.4.6.2	Preparation.....	144
R.5.4.6.3	Activities	144
R.5.4.6.4	Verdict	144
R.5.4.6.5	Evidence	145
R.5.4.7	Assessment case for REQ-RDPS-R-CONF-001.....	145
R.5.4.7.1	Objective	145
R.5.4.7.2	Preparation.....	145
R.5.4.7.3	Activities	145
R.5.4.7.4	Verdict	145
R.5.4.7.5	Evidence	145
R.5.4.8	Assessment case for REQ-RDPS-R-CONF-002.....	146
R.5.4.8.1	Objective	146
R.5.4.8.2	Preparation.....	146
R.5.4.8.3	Activities	146
R.5.4.8.4	Verdict	146
R.5.4.8.5	Evidence	146
R.5.4.9	Assessment case for REQ-RDPS-R-CONF-003.....	146
R.5.4.9.1	Objective	146
R.5.4.9.2	Preparation.....	146
R.5.4.9.3	Activities	147
R.5.4.9.4	Verdict	147
R.5.4.9.5	Evidence	147
R.5.4.10	Assessment case for REQ-RDPS-R-AVAIL-001	147
R.5.4.10.1	Objective	147

R.5.4.10.2	Preparation.....	147
R.5.4.10.3	Activities	148
R.5.4.10.4	Verdict	148
R.5.4.10.5	Evidence	148
R.5.4.11	Assessment case for REQ-RDPS-R-AVAIL-002	148
R.5.4.11.1	Objective	148
R.5.4.11.2	Preparation.....	148
R.5.4.11.3	Activities	149
R.5.4.11.4	Verdict	149
R.5.4.11.5	Evidence	149
R.5.4.12	Assessment case for REQ-RDPS-R-AVAIL-003	149
R.5.4.12.1	Objective	149
R.5.4.12.2	Preparation.....	149
R.5.4.12.3	Activities	149
R.5.4.12.4	Verdict	150
R.5.4.12.5	Evidence	150
R.5.5	Assessment cases for mono-level alternative proposals	150
R.5.5.1	Assessment case for REQ-RDPS-L-AUTH-001.....	150
R.5.5.1.1	Objective	150
R.5.5.1.2	Preparation.....	150
R.5.5.1.3	Activities	150
R.5.5.1.4	Verdict	151
R.5.5.1.5	Evidence	151
R.5.5.2	Assessment case for REQ-RDPS-L-INTEG-001	151
R.5.5.2.1	Objective	151
R.5.5.2.2	Preparation.....	151
R.5.5.2.3	Activities	151
R.5.5.2.4	Verdict	152
R.5.5.2.5	Evidence	152
R.5.5.3	Assessment case for REQ-RDPS-L-CONF-001	152
R.5.5.3.1	Objective	152
R.5.5.3.2	Preparation.....	152
R.5.5.3.3	Activities	152
R.5.5.3.4	Verdict	152
R.5.5.3.5	Evidence	153
R.5.5.4	Assessment case for REQ-RDPS-L-AVAIL-001	153
R.5.5.4.1	Objective	153
R.5.5.4.2	Preparation.....	153
R.5.5.4.3	Activities	153
R.5.5.4.4	Verdict	153
R.5.5.4.5	Evidence	154
R.5.5.5	Assessment case for REQ-RDPS-R-AUTH-001.....	154
R.5.5.5.1	Objective	154
R.5.5.5.2	Preparation.....	154
R.5.5.5.3	Activities	154
R.5.5.5.4	Verdict	154
R.5.5.5.5	Evidence	155
R.5.5.6	Assessment case for REQ-RDPS-R-INTEG-001.....	155
R.5.5.6.1	Objective	155
R.5.5.6.2	Preparation.....	155
R.5.5.6.3	Activities	155
R.5.5.6.4	Verdict	155
R.5.5.6.5	Evidence	155
R.5.5.7	Assessment case for REQ-RDPS-R-CONF-001	156
R.5.5.7.1	Objective	156
R.5.5.7.2	Preparation.....	156
R.5.5.7.3	Activities	156
R.5.5.7.4	Verdict	156
R.5.5.7.5	Evidence	156
R.5.5.8	Assessment case for REQ-RDPS-R-AVAIL-001	156
R.5.5.8.1	Objective	156
R.5.5.8.2	Preparation.....	157

R.5.5.8.3	Activities	157
R.5.5.8.4	Verdict	157
R.5.5.8.5	Evidence	157
R.6	Mapping of CRA Annex I to Annex R requirements	157
History		160

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables (European Standard (EN), Technical Specification (TS), Group Specification (GS) or ETSI Standard (ES)) may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential; or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are; or may be; or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™** and **LTE™** are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

BLUETOOTH® is a trademark registered and owned by Bluetooth SIG, Inc.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's Standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in ETSI deliverables except when used in direct citation.

Introduction

The present document provides the technical cybersecurity requirements for the products in scope, following a risk-based approach in support of the Cyber Resilience Act (CRA) [i.1]. The technical cybersecurity requirements are thereby proportionate to the intended purpose, reasonably foreseeable use, deployment context, and threat exposure of the products.

Clause 4 does not contain technical requirements; it describes the product context that is considered for the application of the present document.

Clause 4 also defines Use Cases (UCs) that represent the main deployment scenarios reflecting the intended purpose and reasonably foreseeable use of the product, which serve as the basis for identifying relevant cybersecurity risks.

Clause 5 specifies technical cybersecurity requirements for the product to mitigate the identified risks, including their applicability conditions.

Clause 6 specifies the assessment criteria and compliance verification procedures with the requirements of clause 5.

Annex A maps the technical requirements of the present document with the essential requirements of the CRA [i.1] regulation.

Annex B informs about the methodology used to assess the security risks of the products in their context.

Annex K supports the definition of the cryptographic requirements and assessment criteria used by the present document.

Annex R provides supplementary requirements and assessment provisions where a product relies on Remote Data Processing Solutions (RDPS) for the provision or support of one or more product functions.

1 Scope

The present document specifies technical requirements and corresponding assessment criteria for physical and virtual network interfaces related to cybersecurity. The products with digital elements in scope, thereafter "network interfaces":

- are specified within the "technical description" of the "category of product" number "10" by the Commission Implementing Regulation (EU) 2025/2392 [i.2] as:

"Physical network interfaces are products with digital elements that directly connect a device to a network via an Application Programming Interface (API) provided by the interface drivers, typically operating at the data link layer, and that feature hardware adapters to transmission media with corresponding firmware, typically operating at the physical and data link layer.

Virtual network interfaces are products with digital elements that directly or indirectly connect a device to a network via an API that emulates that of drivers of physical network interfaces, typically operating at the data link layer.

This category includes but is not limited to wired and wireless network interface cards, controllers and adapters, such as for Wi-Fi®, Ethernet, IrDA, USB, Bluetooth, NearLink, Zigbee®, or Fieldbus, as well as purely virtual standalone products, such as virtual network interface cards, container network interfaces and VPN interfaces".

- are only covered within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1], Annex I Part I under the conditions identified in Annex A.

Network interfaces intended for use in the industrial Operational Technology (OT) domain are excluded from the scope of the present document, see prEN 50770 series [i.5].

Network interfaces whose intended purpose includes management or configuration of the product over the attached network are excluded from the present document.

Network interfaces whose intended purpose includes routing, switching; or transfer of information from one attached network to a different attached network are excluded from the present document.

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- [1] [ENISA Report 1747792503](#) (version 2 - April 2025): "European Cybersecurity Certification Group Sub-group on Cryptography Agreed Cryptographic Mechanisms" [ACM].

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding, but are not required for conformance to the present document.

- [i.1] [Regulation \(EU\) 2024/2847](#) of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).
 - [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical description of the categories of important and critical products with digital elements pursuant to Regulation (EU) 2024/2847 of the European Parliament and of the Council.
 - [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".
 - [i.4] prEN 40000-1-1: "Cybersecurity requirements for products with digital elements – Vocabulary" (produced by CEN CENELEC).
- NOTE: Version and date to be added upon its publication by CEN CENELEC.
- [i.5] prEN 50770 series: "Security for operational technologies" (produced by CEN CENELEC).
 - [i.6] ETSI EN 304 627: "Cyber Security (CYBER); CRA; Cybersecurity requirements for routers, modems intended for the connection to the internet, and switches".
 - [i.7] IETF RFC 7748: "Elliptic Curves for Security".
 - [i.8] IETF RFC 8032: "Edwards-Curve Digital Signature Algorithm (EdDSA)".
 - [i.9] NIST FIPS 186-5: "Digital Signature Standard (DSS)".
 - [i.10] IETF RFC 9106: "Argon2 Memory-Hard Function for Password Hashing and Proof-of-Work Applications".
 - [i.11] BSI TR-0210 2-1: "Cryptographic Mechanisms".
 - [i.12] IETF RFC 7914: "The scrypt Password-Based Key Derivation Function".
 - [i.13] IETF RFC 8439: "ChaCha20 and Poly1305 for IETF Protocols".
 - [i.14] IETF RFC 7693: "The BLAKE2 Cryptographic Hash and Message Authentication Code (MAC)".
 - [i.15] NIST IR 7896: "Third-Round Report of the SHA-3 Cryptographic Hash Algorithm Competition".
 - [i.16] IETF RFC 4418: "UMAC: Message Authentication Code using Universal Hashing".
 - [i.17] Avanzi R. (2017): "[The QARMA Block Cipher Family. Almost MDS Matrices Over Rings With Zero Divisors, Nearly Symmetric Even-Mansour Constructions With Non-Involutory Central Rounds, and Search Heuristics for Low-Latency S-Boxes](#)". IACR Transactions on Symmetric Cryptology, 2017(1), 4-44. doi:10.13154/tosc.v2017.i1.4-44.

- [i.18] Avanzi R., Banik S., Dunkelman O., Eichlseder M., Ghosh S., Nageler M. and Regazzoni F. (2023): "[The QARMAv2 Family of Tweakable Block Ciphers](#)". IACR Transactions on Symmetric Cryptology, 2023(3), 25-73. doi: 10.46586/tosc.v2023.i3.25-73.
- [i.19] ETSI EN 304 636: "Cyber Security (CYBER); CRA; Cybersecurity requirements for firewalls, intrusion detection and/or prevention systems".
- [i.20] BSI TR-02102-2: "Cryptographic Mechanisms: Recommendations and Key Lengths: Use of Transport Layer Security (TLS)".
- [i.21] BSI TR-02102-3: "Cryptographic Mechanisms: Recommendations and Key Lengths – Use of Internet Protocol Security (IPsec) and Internet Key Exchange (IKEv2)".
- [i.22] BSI TR-02102-4: "Cryptographic Mechanisms: Recommendations and Key Lengths – Use of Secure Shell (SSH)".

3 Definition of terms, symbols and abbreviations

3.1 Terms

For the purposes of the present document, the terms given in Regulation (EU) 2024/2847 [i.1], prEN 40000-1-1 [i.4] and the following apply:

cybersecurity requirement: requirement described within the present document to conform to the "Essential requirements" of the Cyber Resilience Act [i.1]

device driver: piece of software or firmware running on the host that enables communication on the network via the network interface

essential requirement: requirement described within the Cyber Resilience Act [i.1], primarily those listed in its Annex I

firmware: software stored within a device's non-volatile memory, such as ROM or flash memory, and executed by different types of hardware which can include the physical network interface and the host

host: any equipment to which the network interface part provides additional functionality, mainly network connectivity, and to which connection is necessary for the network interface to operate

modem interface: single network interface that connects a physical transmission adapter to a system bus

Network Device Driver Interface (NDDI): standardised interface provided by the host operating system or software framework that abstracts the underlying network hardware or virtualized network devices

Network Interface (NI): virtual or physical network interface

physical network interface: hardware device that directly connects to a network using a hardware adapter to the transmission media and is connected to a host system by a communications bus

physical transmission media adapter: physical adapter on a network interface that transmits and receives data on the medium

physical transmission medium: physical instantiation of a network, which can be wired or wireless

standalone modem: device with two or more network interfaces that routes network data between two different networks, relaying data from one type of physical transmission media to another

system bus: data transmission bus also connecting one or more physical network interfaces to a host

Virtual Network Interface (VNI): software-based network interface that simulates the functionality of a physical network interface

wired network interface: physical network interface which transmits data through a fixed, specific medium such as Ethernet cable, fibre optic cable, coaxial cable or power lines

wireless network interface: physical network interface which transmits data in a manner that does not require a specific medium, such as radiofrequency waves or visible light communication through the air

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

ACM	Agreed Cryptographic Mechanisms
ADM	Availability and skill of ADMinistration
API	Application Programming Interface
ALC	Appropriate Level of Cybersecurity
CEN	Comité Européen de Normalisation
COM	Complexity of product functions
CONF	Configuration (Errors)
CRA	Cyber Resilience Act
DECT	Digital Enhanced Cordless Telecommunications
DECT2020 NR	Digital Enhanced Cordless Telecommunications New Radio Plus
FUN	Sensitivity of Functions
HOS	Impact of access to Host system assets
IoT	Internet of Things
ISP	Internet Service Provider
IrDA	Infrared Data Association
IT	Information Technology
INI	Operational environment of initial setup
MACsec	Media Access Control Security
NDDI	Network Device Driver Interface
NET	Degree of public access to attached Network
NI	Network Interface
OT	Operational Technology
PCIe	Peripheral Component Interconnect Express
PHY	Physical access to product
PXE	Preboot Execution Environment
RF	Risk Factor
RDPS	Remote Data Processing Solution
ROM	Read Only Memory
RTOS	Real Time Operating System
SBOM	Software Bill Of Materials
TH	Threat
UC	Use Case
USB	Universal Serial Bus
VI	Virtual Interface
VNI	Virtual Network Interface
VPN	Virtual Private Network
WPA2	Wi-Fi® Protected Access 2

4 Product context

4.0 Introduction

A virtual or physical network interface enables the connection of a computing device to a network. A network interface provides connectivity via a device driver API operating at the data link layer.

Physical network interfaces are products that directly connect a device to a network via an Application Programming Interface (API) provided by device drivers. This connection may be wired or wireless and feature hardware adapters to transmission media with corresponding firmware, typically physical network interfaces operate at the physical and data link layer. Products that are connected to a host system by a communications bus, such as PCIe or USB are physical network interfaces, though they may use a wide variety of technologies to enable this connection including both direct physical connections and wireless connections. The category of physical network interfaces is broad and composed of wired and wireless network interface cards, controllers and adapters, and network interface hardware modules, such as for Wi-Fi®, Ethernet, cellular modems, DECT and DECT2020 NR modems, IrDA, USB, Bluetooth®, NearLink, Zigbee®, Fieldbus; or Infiniband.

Virtual network interfaces are products that directly or indirectly connect a device to a network via an API that emulates that of device drivers or physical network interfaces, typically operating at the data link layer. These virtual network interfaces consist of software running on a host system, and communicate via the device driver interface of that host. As purely virtual, standalone products, a virtual network interface remains a product whose core function is that of a network interface and that provides a remote management interface for the network interface or the host system. Examples of virtual network interfaces also include: container network interfaces, VPN interfaces, and loopback interfaces.

For the purposes of the present document, network interfaces will be split up into the following groups, due to their distinct threat models:

- Wired network interfaces
- Wireless network interfaces
- Virtual network interfaces

Network interfaces are closely related to what is commonly called a "modem", but this general term is used for two different kinds of products:

- 1) "Modem interface": A single network interface that connects a physical transmission adapter to a system bus, as for example a 5G modem interface or Power Line Communication device
- 2) "Standalone modem": A device with two or more network interfaces that routes network data between two different networks, relaying data from one type of physical transmission media to another, such as a cable modem

"Modem interfaces" are included in the present document. "Standalone modems" are excluded from the present document, but may be found in the vertical CRA standard for Routers Modems & Switches [i.6].

4.1 Product Functions

4.1.1 Physical network interface product functions

A physical network interface is the link between the physical transmission media and the host system. The product's essential function is to transfer data between the network and the host.

The product supports configuration of itself by the host. The host system may configure settings related to transmitting data, encryption; or features like waking the host after a packet arrives at the network interface.

The product may keep and report statistics about network traffic or its internal functions.

The product may update or load its own firmware. The host system may be able to update or load firmware to the product.

The product may be able to take actions that affect the entire host system, such as power cycling or reading any part of memory.

4.1.2 Device driver product functions

A device driver manages the network interface on behalf of the host system, often presenting a standardised network device driver interface to the host operating system. It manages the transfer of data from the network interface to and from host memory. It carries out requests by the host software, such as configuration or loading firmware. It may keep and report statistics about network traffic.

4.1.3 Virtual network interface product functions

A virtual network interface presents a network device driver interface to the rest of the host software. It may encrypt, filter, transform, route, discard; or otherwise modify network traffic entering the interface. The network traffic may then be directed to another virtual network interface on the same host, to another executable on the host; or to a physical network interface.

4.2 Product Architecture

4.2.1 Overview

For the purposes of the present document, a physical network interface consists of:

- A local bus interface to connect to the host via a communications bus
- A hardware transceiver to communicate on the network
- Hardware and firmware to process incoming signals and host commands

Physical network interfaces may also include the following parts:

- Device driver
- Removable/changeable antenna
- Daughter boards/add-on hardware modules

A virtual network interface consists of a device driver only.

4.2.2 Types of network interface

A network interface connects via a communications bus to the host. The host transmits to and receives data from the network by means of a device driver interface provided by the device driver for the network interface. A network interface might read and write the host memory directly and raise interrupts. It sometimes has more advanced features that allow it to power cycle the entire system, download files using simple protocols, and act as a simple boot loader.

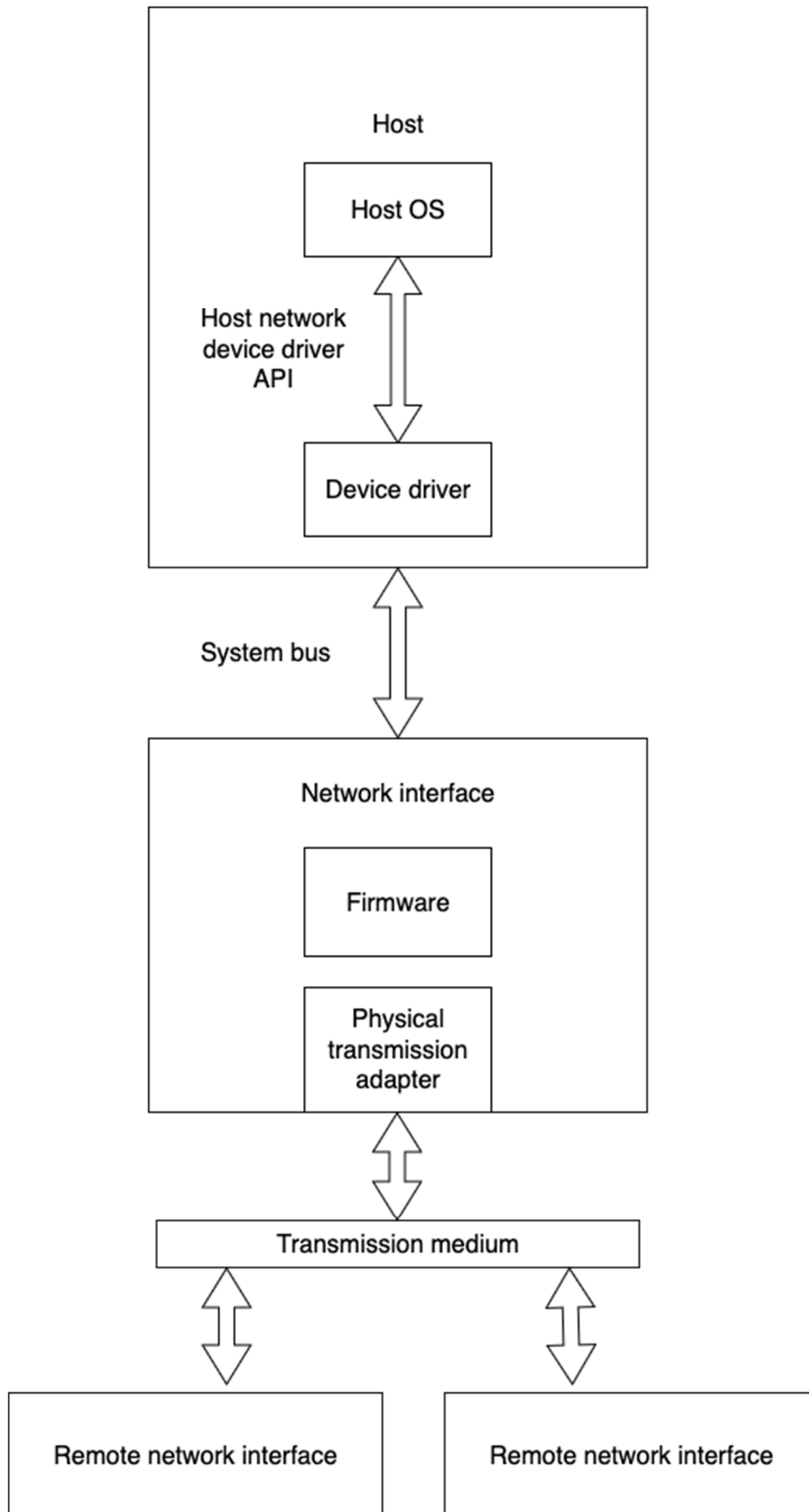


Figure 4.2.2-1: Physical network device architecture

A wired network interface transmits data via a specific physical medium such as Ethernet cable, fibre optic cable, coaxial cable or power lines. A wireless network interface transmits data in a manner that does not require a specific medium, such as radiofrequency waves or visible light communication through the air. A virtual network interface transmits data through software within the memory of a host system, sometimes across a software-defined network fabric.

Wireless network interfaces often have an independent real-time operating system on the network interface itself. Wireless medium access often requires real-time response to manage the radio frequency transmissions properly. The network interface may also need to prevent improper settings of radio frequency transmission parameters, which is often implemented by having the internal firmware set the parameters, rather than exposing them to the host. The complexity of this firmware may increase the risk of a wireless interface.

A virtual network interface emulates the device driver interface of a network interface to a host's device driver API. Instead of a physical network interface, it may send and receive packets to a hypervisor, a container, another device driver, another part of the network stack, an application; or other software.

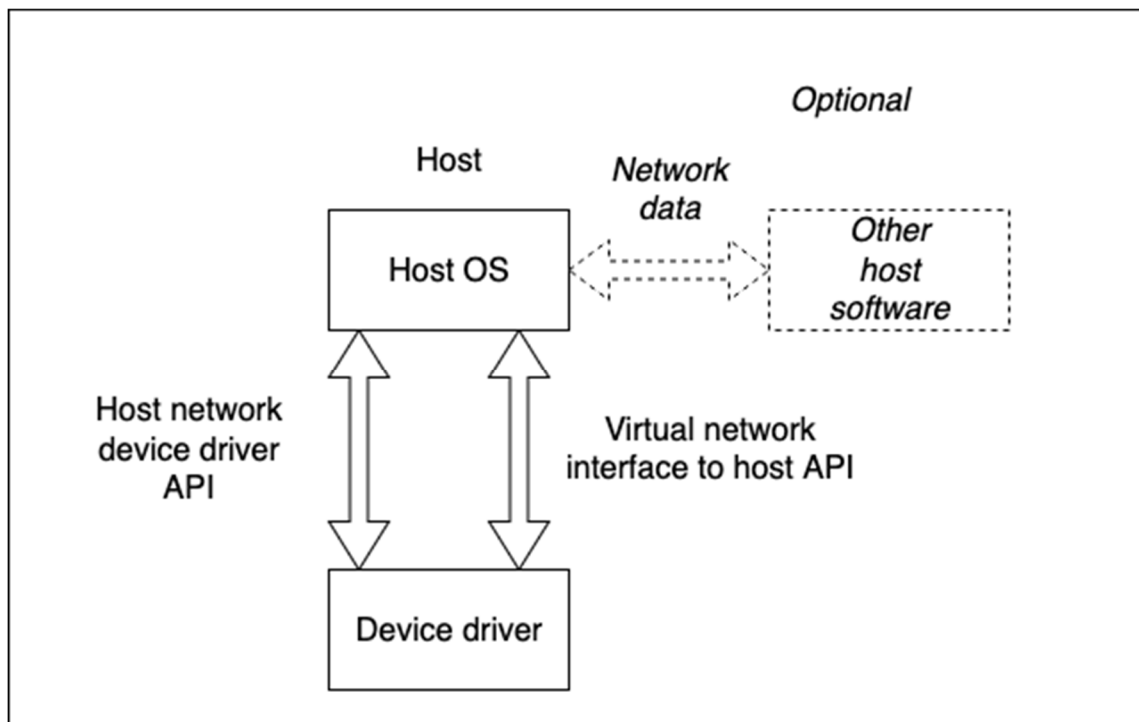


Figure 4.2.2-2: Virtual network device architecture

4.2.3 Device drivers for network interfaces

The device driver communicates with the host software or firmware by means of a network device driver API. This API abstracts the implementation details of the underlying network interface. Such network device driver API is typically defined by the host operating system or other software and is used by the host network stack to send or receive data through the network interface.

Physical network interfaces require device drivers to make use of the physical hardware through a device driver interface. Virtual network interfaces are effectively device drivers only, since they are made of software only without underlying hardware.

The device driver often needs elevated privileges to read and write memory. Device drivers for physical network interfaces often need to have access also to the network interface control registers, directly or via host memory address space mapped to them; sometimes device drivers need to enable or disable interrupts or other host hardware functions. This usually requires that the device driver has a high level of privilege on the host system.

4.3 Operational Environment

4.3.1 General description

A network interface in use for its intended purpose is integrated into a host system and attached to a network.

4.3.2 Physical/Hardware environment

A physical network interface communicates with its host by a system bus, and the network by a transmission media adapter. A physical network interface may have access to host system assets via the system bus. Other devices may also have access to the system bus or the network and therefore access to the product via these interfaces.

In a physical network interface, the system bus connection, transmission media adapter; or entire interface may be physically accessible to unauthorized users. Some examples of physical environments that an network interface may encounter:

- a factory for an integrator
- the interior of a physically secured appliance
- plugged into the USB port of a laptop in a home
- in a library computer with the physical transmission adapter physically accessible to the user

A physical network interface will vary in ease of removal from the host system.

A virtual network interface communicates with the host system and the network via software interfaces to the host software, all of which runs on a hardware platform.

4.3.3 Logical/Software environment

The host system makes use of the physical or virtual network interface via host software that communicates with the network interface, most often an operating system that implements a device driver interface and a network stack.

The host software is responsible for controlling access to the network interface from the host system. For the purposes of protecting the cybersecurity of the user of the network interface, the network interface fully trusts the host system to protect the assets exposed to the host system.

However, the network interface may, for regulatory or business reasons, implement features that do not rely on trusting the host system. For example, a radio frequency transmission media adapter may not accept the installation of firmware not cryptographically signed by the manufacturer to fulfil regulatory requirements (such as the power of a software-controlled radio) or satisfy intellectual property concerns (such as revealing the content of the firmware binary).

The host system typically uses the functions of a physical network interface through a device driver. This device driver may be included with the product or provided independently of the product.

A virtual network interface is a device driver running in the context of the host software. A virtual network interface does not require a separate device driver.

Users may be able to gain unauthorized access to the host system via compromise of the host system, and therefore may bypass the host system's authorization and access control system.

The hardware and software on the product and any associated device driver will range in complexity depending on the number and type of features implemented.

The sensitivity of the data stored on and transmitted by the host system will vary, as will the functions of the host system.

Users not authorized by the host system to directly access the network interface may have the ability to indirectly exercise the functions of the product, such as by sending data using a host system interface that send the data over the network interface.

4.3.4 Connectivity aspects

A network interface is connected to a network which may be accessible by other devices connected to the network.

A physical network interface is connected to a host system bus which may be accessible to other devices connected to the system bus.

A virtual network interface is connected to a host system by a software interface and by shared memory or other system resources which may be accessible by other software on the system.

The network the device is connected to may be an isolated private network with no connection to a public network, a private network with a filtered connection to a public network; or a public network directly accessible by many untrusted agents.

4.4 Distribution of Security Functions

4.4.1 General

For each cybersecurity requirement, a product may:

- 1) Provide some or all of the necessary security functions itself
- 2) Require some or all of the security functions be provided by the operational environment
- 3) Provide security functions used by other components for their cybersecurity requirement

For example, many network interfaces do not have a built-in method of securely updating the software or firmware in the product. Instead, they rely on host system to check for security updates, download and verify them, and write the updated software image. The host system does this by using interfaces provided by the network interface to query the version of the installed software and write the software image.

4.4.2 Security functions provided outside the product

The following security functionalities are often provided partly or entirely by the operational environment, such as the host operating system or the physical protection of the product:

- Secure by default configuration
- Secure configuration changes
- Secure update of firmware and/or device driver
- Authentication and access control
- Confidentiality and integrity protection of data stored and transmitted
- Availability protection other than at the physical or link layer of the network
- Exploit mitigation
- Deletion and transfer of user data
- Provision of cryptographic keys to network interface

A component that provides a security function critical to the cybersecurity of the product is assumed to be trustworthy for the purposes of the present document.

4.4.3 Security functions provided to other components

The network interface provides the following security functions to other parts of the system:

- Monitoring, such as reporting of network-related statistics or interface state changes

The product may implement additional optional security functions, such as with hardware offloading of encryption. These features are often implemented as part of the network protocol the network interface implements. These functions can be, but are not limited to:

- Integrity protection via data link layer error detection and correction
- Confidential communication channel when providing encryption at the data link layer (WPA2, MACsec)
- Availability protection via packet processing offload features

4.5 Users

Users of almost every product with digital elements are also indirectly using a network interface. Thus the indirect users of network interfaces include all users. The primary users for the purpose of the present document are primarily those removing, installing, administering; or otherwise directly interacting with the network interface as an individual product, as distinct from interacting with the device it is integrated with. However, broad categories of indirect users are also described, divided up by how they affect the product risks.

Direct users of network interfaces include:

- System integrators
- Internet equipment manufacturers
- Engineers
- Professional IT administrators
- Professional OT administrators
- Computer repair technicians
- Non-professional moderately skilled computer users

Indirect users of network interfaces include:

- People with little to no computer administration skills
- People with advanced computer administration skills

4.6 Use Cases

4.6.1 Introduction

4.6.1.1 Overview

The purpose of a use case is to create defined sets of technical requirements (clause 5) that may be used to treat the risks found by the manufacturer's independent cybersecurity risk analysis.

Use cases are defined by their risk factor levels. The risk factor levels are used by the informative Security Analysis in Annex B to select the group of technical requirements associated with that use case.

Specific use cases are identified by their use case IDs, which are constructed in the following manner:

UC-[XX]-[YYY]

Where "XX" is either "PH" for physical network interface or "VI" for virtual network interface, and "YYY" is three letters that serve to remind the reader of one or more examples.

4.6.1.2 Guidance

It is not necessary to find a use case whose risks are identical to those identified by the product's cybersecurity risk assessment. If a use case has equal or higher risks to the product's, then it can be used. For example, a use case that includes the product being connected to a public network (a high level of this risk factor) can also be used for a product whose intended purpose is to be connected to a private network with a filtered connection to a public network.

New use cases may be added to the present document along with any new risk factors or requirements necessary to fully treat the risks.

Any use case for an end product can be converted to an integrator use case by copying it and setting the RF-INI value to 0.

4.6.2 Use case descriptions

4.6.2.1 UC-VI-ISO: Virtual interface for research within a host system

- Goal: Simulate networking for research or development
- Description:
 - Examples: Loopback interface, container interface
 - Product type: Virtual network interface
 - Physical access: N/A
 - Network connectivity: Isolated private network
 - Function: Transmit data between VMs for research or development purposes
 - Host system impact: Low
 - Complexity: Low
 - User administration skill: High (low risk)
 - Initial setup: Low risk

4.6.2.2 UC-PH-VNI: Vending machine internal network

- Goal: Connect internal machine components, no external connection
- Description:
 - Examples: Ethernet interfaces connecting payment module to dispenser hardware
 - Product type: Physical network interface
 - Physical access: Access-controlled
 - Network connectivity: Isolated private network
 - Function: Send data between components
 - Complexity: Medium
 - Host system impact: Low
 - User administration skill: Medium
 - Initial setup environment: Access-controlled

4.6.2.3 UC-PH-VNC: Vending machine, remotely managed

- Goal: Allow remote management of devices
- Description:
 - Examples: 5G in vending machine to service electronic payments, report
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Public network
 - Function: Allow management of device
 - Complexity: Medium
 - Host system impact: Low
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.4 UC-PH-IOT: Physical network interface for home IoT

- Goal: Connect a home appliance to a home network for local control and monitoring
- Description:
 - Examples: Smart lightbulb Bluetooth module, ethernet module for coffee machines
 - Product type: Physical network interface
 - Physical access: Home
 - Network connectivity: Filtered private network
 - Function: Connect low sensitivity device to local private network for management
 - Complexity: High
 - Host system impact: Low
 - User administration skill: Low
 - Initial setup environment: Access-controlled

4.6.2.5 UC-PH-IRO: Intranet router

- Goal: Connect to routers and devices in intranet
- Description:
 - Examples: Line cards in an intranet router for enterprise office intranet
 - Product type: Physical network interface
 - Physical access: Access-controlled
 - Network connectivity: Filtered private network
 - Function: Connect intranet devices and routers
 - Complexity: High
 - Host system impact: Medium

- User administration skill: High
- Initial setup environment: Access-controlled

4.6.2.6 UC-PH-EDG: Edge router

- Goal: Provide connection and filtering to public network
- Description:
 - Examples: Line cards in an edge router for enterprise office intranet
 - Product type: Physical network interface
 - Physical access: Access-controlled
 - Network connectivity: Public network
 - Function: Connect intranet with public network
 - Complexity: High
 - Host system impact: Medium
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.7 UC-PH-HRO: Home router in filtered network

- Goal: Connect home devices and internet access point
- Description:
 - Examples: Ethernet and Wi-Fi® modules in home router behind ISP access point
 - Product type: Physical network interface
 - Physical access: Home
 - Network connectivity: Filtered private network
 - Function: Connect devices to each other in filtered private network
 - Complexity: High
 - Host system impact: Medium
 - User administration skill: Low
 - Initial setup environment: Access-controlled

4.6.2.8 UC-PH-ISP: ISP access point

- Goal: Provide connection and filtering to public network
- Description:
 - Examples: Cable modem or fiber card in ISP access point
 - Product type: Physical network interface
 - Physical access: Home
 - Network connectivity: Public network

- Function: Connect home network with public network
- Complexity: High
- Host system impact: Medium
- User administration skill: Medium (mix of professional and amateur)
- Initial setup environment: Access-controlled

4.6.2.9 UC-VI-VDC: Virtualize data centre

- Goal: Connect VMs in data centre to each other and public network
- Description:
 - Examples: Emulated interfaces in a business's data processing cluster
 - Product type: Virtual network interface
 - Physical access: None
 - Network connectivity: Filtered private network
 - Function: Share hardware, connect to filtered private network
 - Complexity: Medium
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.10 UC-VI-VMW: VM on multi-tenant web server

- Goal: Connect VMs in web server to public network
- Description:
 - Examples: Virtual interface in container for shared web hosting provider
 - Product type: Virtual network interface
 - Physical access: None
 - Network connectivity: Public network
 - Function: Share hardware, connect to public network
 - Complexity: Medium
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.11 UC-VI-VMC: Virtualize critical server

- Goal: Connect VMs running critical infrastructure to public network
- Description:
 - Examples: Virtual interface in guest VM for banking infrastructure

- Product type: Virtual network interface
- Physical access: None
- Network connectivity: Public network
- Function: Share hardware, connect to public network
- Complexity: Medium
- Host system impact: High
- User administration skill: High
- Initial setup environment: Access-controlled

4.6.2.12 UC-VI-VII: Virtual interface for integrators

- Goal: Provide virtual interfaces to developers of products
- Description:
 - Examples: Virtio network driver in virtual machine, loopback for containers
 - Product type: Virtual network interface
 - Physical access: None
 - Network connectivity: Public network
 - Function: Share hardware, connect to public network
 - Complexity: Medium
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.13 UC-PH-SMW: Smart watch

- Goal: Connect small mobile devices to larger mobile devices
- Description:
 - Examples: Smart watch Bluetooth/Wi-Fi®, battery-powered Wi-Fi®/5G hotspot
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Filtered private network
 - Function: Connect wirelessly to public network via nearby trusted device
 - Complexity: High
 - Host system impact: Low
 - User administration skill: Low
 - Initial setup environment: Access-controlled

4.6.2.14 UC-PH-SME: Smart meter

- Goal: Connect infrastructure device to server
- Description:
 - Examples: Energy smart meter/data concentrator PLC connection, water or gas meters wMBUS connection, NBIoT connection, LoRaWAN connection, handy terminal to read meter data wMBUS connection, parking meter Bluetooth, etc.
 - Product type: Physical network interface
 - Physical access: Home/semi-public
 - Network connectivity: Public network
 - Function: Transmit device data to private server via private or public network
 - Complexity: High
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.15 UC-PH-ATM: ATM

- Goal: Connect public infrastructure device to public network
- Description:
 - Examples: ATM ethernet module, traffic camera LoRaWAN module
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Filtered private network
 - Function: Connect infrastructure to filtered network to public network
 - Complexity: High
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.16 UC-PH-SPI: Solar panel inverter

- Goal: Connect critical infrastructure device to server
- Description:
 - Examples: Solar panel inverter Wi-Fi®, water pump LoRaWAN, meter data concentrator WAN connection
 - Product type: Physical network interface
 - Physical access: Semi-private
 - Network connectivity: Public network
 - Function: Remote management of devices

- Complexity: High
- Host system impact: High
- User administration skill: High
- Initial setup environment: Access-controlled

4.6.2.17 UC-VI-VPN: Consumer VPN

- Goal: Encrypt/route traffic
- Description:
 - Examples: Consumer VPN client, VPN interface in remotely managed power strip
 - Product type: Virtual network interface
 - Physical access: None
 - Network connectivity: Public network
 - Function: Provide secure tunnel across public networks
 - Complexity: High
 - Host system impact: High
 - User administration skill: Low
 - Initial setup environment: Home

4.6.2.18 UC-PH-MOB: Mobile phone or tablet

- Goal: Connect high importance mobile device to public networks
- Description:
 - Examples: 5G modem in phone, Wi-Fi®/Bluetooth module in tablet
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Public network
 - Function: Connect to public network via local wireless
 - Complexity: High
 - Host system impact: High
 - User administration skill: High
 - Initial setup environment: Access-controlled

4.6.2.19 UC-PH-GPI: General purpose integrated

- Goal: Connect server/desktop/laptop computer to public network
- Description:
 - Examples: Ethernet on motherboard on server, pre-installed Wi-Fi® card on laptop
 - Product type: Physical network interface

- Physical access: Public
- Network connectivity: Public network
- Function: Individuals accessing the public internet
- Complexity: High
- Host system impact: High
- User administration skill: Low
- Initial setup environment: Access-controlled

4.6.2.20 UC-PH-USB: External USB

- Goal: Connect computer to public network
- Description:
 - Examples: USB ethernet dongle, USB Wi-Fi® dongle
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Public network
 - Function: Provide access to public network from a computer
 - Complexity: High
 - Host system impact: Medium
 - User administration skill: Low
 - Initial setup environment: Public

4.6.2.21 UC-PH-STA: Standalone

- Goal: User installs into server/laptop/desktop/etc.
- Description:
 - Examples: PCIe ethernet card for server, Wi-Fi®/Bluetooth module for laptop
 - Product type: Physical network interface
 - Physical access: Public
 - Network connectivity: Public network
 - Function: Provide access to public network from a computer
 - Complexity: High
 - Host system impact: High
 - User administration skill: Low
 - Initial setup environment: Public

4.6.2.22 UC-PH-SNS: Remote Sensor

- Goals: Connect sensor to server

- Description:
 - Example: Weather sensor, GPS tracker
 - Product type: Physical network interface
 - Physical access: Home/semi-public
 - Network connectivity: Filtered private network
 - Function: Transmit sensor data to private server via public network
 - Complexity: Medium
 - Host system impact: High
 - User administration skill: Low
 - Initial setup environment: Access-controlled

5 Technical requirements for products

5.1 Introduction

5.1.1 Applicability of the requirements

The technical requirements of the present document apply under the product context described in clause 4, which shall be in accordance with its intended use. The product shall comply with all applicable technical requirements of the present document at all times when operating in such a product context.

Not all requirements are universally applicable: The applicability of requirements may be based on use cases or specific capabilities of the product.

5.1.2 Applicability of Annex K

Where the product relies on cryptographic mechanisms for the provision or support of one or more product functions, the product shall satisfy the applicable requirements specified in Annex K.

5.1.3 Applicability of Annex R

Where the product relies on a Remote Data Processing Solution (RDPS) for the provision or support of one or more product functions, the product shall satisfy the applicable requirements specified in Annex R.

NOTE: Annex R specifies supplementary requirements for the product-facing RDPS boundary and does not replace the requirements applicable to the product function as such.

5.1.4 Guidance for "cybersecurity-relevant"

The term "cybersecurity-relevant" is intended to allow the assessor to exclude some elements of the product from assessment if they are not relevant to the essential cybersecurity requirement being assessed. The exclusions need to be documented with a clear reason. It is not necessary to identify which parts of the product are cybersecurity-relevant with any precision (or at all) as long as all cybersecurity-relevant parts of the product are included in the assessment.

5.2 Appropriate level of cybersecurity

5.2.1 Overview

5.2.1.1 CRA Relevance

This clause addresses the requirements in the CRA [i.1], Annex I Part I (1).

In alignment with the Cyber Resilience Act [i.1], Annex I Part I (1), this clause addresses overarching risks and mitigations regarding the secure design and development of the product that are not specifically treated by other categorical essential requirements (such as confidentiality, access control; or security updates). The requirements herein ensure the final product itself embodies security by design.

5.2.2 REQ-ALC-01 Resilience to potentially untrusted inputs

5.2.2.1 Requirement

All cybersecurity-relevant parts of the product shall implement methods to validate untrusted inputs and mitigate the effects thereof.

5.2.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required

- UC-PH-STA: required
- UC-PH-SNS: required

5.2.3 Mapping of requirements to use cases

Use case	REQ-ALC-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.3 No known exploitable vulnerabilities

5.3.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (a).

5.3.2 REQ-KEV-01 No known exploitable vulnerabilities

5.3.2.1 Requirement

The product shall have no known exploitable vulnerabilities at the time of placement on the market, with the exception of known exploitable vulnerabilities that satisfy at least one of the following criteria:

- the vulnerability became known to the manufacturer within the 14 days prior to placement on the market; or
- the vulnerability became known to the manufacturer within the time period permitted before addressing and remediation of the vulnerability as described in the vulnerability handling procedure for the product prior to placement on the market; or
- the vulnerability became known to the manufacturer within the time period permitted before public disclosure as described in the vulnerability handling procedure for the product prior to placement on the market; or
- the vulnerability has associated publicly-available documentation explaining the risk and how that risk has been mitigated.

5.3.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required

- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.3.2.3 Guidance

A vulnerability may become known but be determined to be unexploitable, then later discovered to be exploitable. Thus the "exploitable" part of "known exploitable vulnerability" should be based on the determination of its exploitability at the time of placement on the market.

5.3.3 Mapping of requirements to use cases

Use case	REQ-KEV-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.4 Secure by default configuration

5.4.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (b).

NOTE: The CRA [i.1] essential requirement laid out in Annex I Part I (2) (b) foresees an applicability exception to the secure configuration by default in case there is an agreement between manufacturer and business user in relation to a tailor-made product with digital elements.

5.4.2 REQ-SBD-01: Provide methods to protect or disable interfaces

5.4.2.1 Requirement

The product shall provide methods to disable or protect all debug or management interfaces on the product that are exposed to unauthorized users, unless necessary for backwards compatibility.

5.4.2.2 Applicability

- UC-VI-ISO: required
- UC-PH-VNI: required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required

- UC-VI-VDC: required
- UC-VI-VMW: not required
- UC-VI-VMC: not required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: not required
- UC-PH-MOB: required
- UC-PH-GPI: not required
- UC-PH-USB: not required
- UC-PH-STA: not required

5.4.2.3 Guidance

The exposure of interfaces to unauthorized users is determined by the intended purpose of the product as specified by the manufacturer and the manufacturer's cybersecurity risk assessment.

5.4.3 REQ-SBD-02: Protect or disable access to debug or management interfaces

5.4.3.1 Requirement

All debug or management interfaces accessible to unauthorized users shall be protected or disabled by default, unless necessary for backwards compatibility.

5.4.3.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: not required
- UC-PH-EDG: not required
- UC-PH-HRO: not required
- UC-PH-ISP: not required
- UC-VI-VDC: not required
- UC-VI-VMW: required
- UC-VI-VMC: required

- UC-VI-VII: not required
- UC-PH-SMW: not required
- UC-PH-SME: not required
- UC-PH-ATM: not required
- UC-PH-SPI: not required
- UC-VI-VPN: required
- UC-PH-MOB: not required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.4.3.3 Guidance

Only interfaces that would be exposed to unauthorized users need be disabled or protected. Which interfaces are determined by the intended purpose and reasonably foreseeable use specified by the manufacturer, and the manufacturer's risk assessment.

5.4.4 Mapping of requirements to use cases

Use case	REQ-SBD-01	REQ-SBD-02
UC-VI-ISO	x	
UC-PH-VNI	x	
UC-PH-VNC	x	
UC-PH-IOT	x	
UC-PH-IRO	x	
UC-PH-EDG	x	
UC-PH-HRO	x	
UC-PH-ISP	x	
UC-VI-VDC	x	
UC-VI-VMW		x
UC-VI-VMC		x
UC-VI-VII	x	
UC-PH-SMW	x	
UC-PH-SME	x	
UC-PH-ATM	x	
UC-PH-SPI	x	
UC-VI-VPN		x
UC-PH-MOB	x	
UC-PH-GPI		x
UC-PH-USB		x
UC-PH-STA		x
UC-PH-SNS		x

5.5 Security updates

5.5.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (c).

5.5.2 REQ-SU-01: Secure update provided by operational environment

5.5.2.1 Requirement

The product shall provide a method of securely updating the product via the operational environment before or during the time of first use.

5.5.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.5.3 Mapping of requirements to use cases

Use case	REQ-SU-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	
UC-PH-IOT	
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.6 Authentication and access control

5.6.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (d).

5.6.2 REQ-AAC-01: Authentication and access control provided by operational environment

5.6.2.1 Requirement

The product shall provide methods for the operational environment to implement authentication and access control to the product.

5.6.2.2 Applicability

- UC-VI-ISO: required
- UC-PH-VNI: required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required

- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.6.3 Mapping of requirements to use cases

Use case	REQ-AAC-01
UC-VI-ISO	X
UC-PH-VNI	X
UC-PH-VNC	X
UC-PH-IOT	X
UC-PH-IRO	X
UC-PH-EDG	X
UC-PH-HRO	X
UC-PH-ISP	X
UC-VI-VDC	X
UC-VI-VMW	X
UC-VI-VMC	X
UC-VI-VII	X
UC-PH-SMW	X
UC-PH-SME	X
UC-PH-ATM	X
UC-PH-SPI	X
UC-VI-VPN	X
UC-PH-MOB	X
UC-PH-GPI	X
UC-PH-USB	X
UC-PH-STA	X
UC-PH-SNS	X

NOTE 1: The product may provide security functions that the operational environment may make use of to provide authentication and access control for a product that integrates this product as a component. But products in the scope of the present document are not required to provide authentication and access control independently of their operational environment.

NOTE 2: The scope of the present document could potentially be extended to cover products whose intended purpose and reasonably foreseeable use requires authentication and access control in their secure-by-default configuration. One way to do this is to copy the relevant requirements from related standards, such as those for routers (ETSI EN 304 627 [i.6]) or firewalls (ETSI EN 304 636 [i.19]).

5.7 Confidentiality protection

5.7.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (e).

5.7.2 REQ-CP-01: Confidentiality protection provided by operational environment

5.7.2.1 Requirement

The product shall provide methods by which the operational environment may protect the confidentiality of data transmitted by or stored on the product that is necessary to the cybersecurity of the product.

5.7.2.2 Applicability

- UC-VI-ISO: required
- UC-PH-VNI: required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.7.2.3 Guidance

The product may provide security functions that the operational environment may make use of to provide confidentiality protection for a product that integrates this product as a component. But products in the scope of the present document are not required to provide confidentiality protection independently of their operational environment.

5.7.3 Mapping of requirements to use cases

Use case	REQ-CP-01
UC-VI-ISO	x
UC-PH-VNI	x
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.8 Integrity protection

5.8.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (f).

5.8.2 REQ-IP-01: Integrity protection provided by operational environment

5.8.2.1 Requirement

The product shall provide methods by which the operational environment may protect the integrity of data transmitted by or stored on the product that is necessary to the cybersecurity of the product.

5.8.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required

- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.8.3 Mapping of requirements to use cases

Use case	REQ-IP-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

The product may provide security functions that the operational environment may make use of to provide integrity protection for a product that integrates this product as a component. But products in the scope of the present document are not required to provide integrity protection independently of their operational environment to protect their own cybersecurity. Products may choose to implement integrity protection of data stored or transmitted for other reasons, such as to satisfy regulatory requirements by preventing an authorized user on the host system from installing non-conforming firmware.

5.9 Data minimisation

5.9.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (g).

5.9.2 REQ-DM-01: Data minimisation

5.9.2.1 Requirement

The product shall minimize the data processing by the product.

5.9.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required

- UC-PH-SNS: required

5.9.3 Mapping of requirements to use cases

Use case	REQ-DM-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	
UC-PH-IOT	
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.10 Availability protection

5.10.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (h).

5.10.2 REQ-AP-01 Fast packet drop

5.10.2.1 Requirement

The product shall process and drop invalid packets in a manner that protects the availability of the product.

5.10.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: not required
- UC-PH-EDG: REQ-AP-01 or REQ-AP-03
- UC-PH-HRO: not required
- UC-PH-ISP: not required
- UC-VI-VDC: REQ-AP-01 or REQ-AP-03

- UC-VI-VMW: REQ-AP-01 or REQ-AP-03
- UC-VI-VMC: REQ-AP-01 or REQ-AP-03
- UC-VI-VII: REQ-AP-01 or REQ-AP-03
- UC-PH-SMW: not required
- UC-PH-SME: not required
- UC-PH-ATM: REQ-AP-01 or REQ-AP-03
- UC-PH-SPI: REQ-AP-01 or REQ-AP-03
- UC-VI-VPN: REQ-AP-01 or REQ-AP-03
- UC-PH-MOB: REQ-AP-01 or REQ-AP-03
- UC-PH-GPI: REQ-AP-01 or REQ-AP-03
- UC-PH-USB: REQ-AP-01 or REQ-AP-03
- UC-PH-STA: not required

5.10.2.3 Guidance

Efficiently dropping invalid packets may be accomplished by checking the frame length, header fields, and destination address in order from least to most computationally expensive, and dropping the packet as soon as any field is found to be invalid without further processing.

5.10.3 REQ-AP-02 Limit resource usage by incoming network data

5.10.3.1 Requirement

The product shall manage internal resource usage by data received over the network or from the host system in such a manner that the impact of the exhaustion of any resource on the product's cybersecurity and functions is minimised.

5.10.3.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: REQ-AP-02 or REQ-AP-03
- UC-PH-IOT: REQ-AP-02 or REQ-AP-03
- UC-PH-IRO: REQ-AP-02 or REQ-AP-03
- UC-PH-EDG: REQ-AP-02 or REQ-AP-03
- UC-PH-HRO: REQ-AP-02 or REQ-AP-03
- UC-PH-ISP: REQ-AP-02 or REQ-AP-03
- UC-VI-VDC: REQ-AP-02 or REQ-AP-03
- UC-VI-VMW: REQ-AP-02 or REQ-AP-03
- UC-VI-VMC: REQ-AP-02 or REQ-AP-03
- UC-VI-VII: REQ-AP-02 or REQ-AP-03
- UC-PH-SMW: REQ-AP-02 or REQ-AP-03

- UC-PH-SME: REQ-AP-02 or REQ-AP-03
- UC-PH-ATM: REQ-AP-02 or REQ-AP-03
- UC-PH-SPI: REQ-AP-02 or REQ-AP-03
- UC-VI-VPN: REQ-AP-02 or REQ-AP-03
- UC-PH-MOB: REQ-AP-02 or REQ-AP-03
- UC-PH-GPI: REQ-AP-02 or REQ-AP-03
- UC-PH-USB: REQ-AP-02 or REQ-AP-03
- UC-PH-STA: REQ-AP-02 or REQ-AP-03
- UC-PH-SNS: REQ-AP-02 or REQ-AP-03

5.10.4 REQ-AP-03 Availability protection provided by operational environment

5.10.4.1 Requirement

The product shall provide methods by which the operational environment may protect the availability of product assets necessary to the cybersecurity of the product.

5.10.4.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: REQ-AP-03 or REQ-AP-02
- UC-PH-EDG: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-HRO: REQ-AP-03 or REQ-AP-02
- UC-PH-ISP: REQ-AP-03 or REQ-AP-02
- UC-VI-VDC: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-VI-VMW: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-VI-VMC: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-VI-VII: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-SMW: REQ-AP-03 or REQ-AP-02
- UC-PH-SME: REQ-AP-03 or REQ-AP-02
- UC-PH-ATM: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-SPI: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-VI-VPN: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-MOB: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)

- UC-PH-GPI: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-USB: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-STA: REQ-AP-03 or (REQ-AP-01 and REQ-AP-02)
- UC-PH-SNS: REQ-AP-03 or REQ-AP-02

5.10.5 REQ-AP-04: Watchdog and notification of host

5.10.5.1 Requirement

The product shall implement a mechanism to notify the host system when it detects that it is no longer able to perform its functions and provide a method for the host to reset the product.

5.10.5.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.10.6 REQ-AP-05: Watchdog and self-initiated reset

5.10.6.1 Requirement

The product shall implement a mechanism to trigger an automatic reset when it detects that it is no longer able to perform its functions.

5.10.6.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: not required
- UC-PH-IOT: not required
- UC-PH-IRO: not required
- UC-PH-EDG: required
- UC-PH-HRO: not required
- UC-PH-ISP: not required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: not required
- UC-PH-SME: not required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: not required

5.10.7 Mapping of requirements to use cases

Use case	REQ-AP-01	REQ-AP-02	REQ-AP-03	REQ-AP-04	REQ-AP-05
UC-VI-ISO					
UC-PH-VNI					
UC-PH-VNC					
UC-PH-IOT					
UC-PH-IRO		x ¹	x ¹	x	
UC-PH-EDG	x ²	x ²	x ²		x
UC-PH-HRO		x ¹	x ¹	x	
UC-PH-ISP		x ¹	x ¹	x	
UC-VI-VDC	x ²	x ²	x ²		x
UC-VI-VMW	x ²	x ²	x ²		x
UC-VI-VMC	x ²	x ²	x ²		x
UC-VI-VII	x ²	x ²	x ²		x
UC-PH-SMW		x ¹	x ¹	x	
UC-PH-SME		x ¹	x ¹	x	
UC-PH-ATM	x ²	x ²	x ²		x
UC-PH-SPI	x ²	x ²	x ²		x
UC-VI-VPN	x ²	x ²	x ²		x
UC-PH-MOB	x ²	x ²	x ²		x
UC-PH-GPI	x ²	x ²	x ²		x
UC-PH-USB	x ²	x ²	x ²		x
UC-PH-STA	x ²	x ²	x ²		x
UC-PH-SNS		x ¹	x ¹	x	

- x¹ REQ-AP-02 or REQ-AP-03
- x² (REQ-AP-01 and REQ-AP-02) or REQ-AP-03

5.11 Non-interference

5.11.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (i).

5.11.2 REQ-NI-01: Minimise data transmitted to unverified sources

5.11.2.1 Requirement

The product shall minimise the data originating from the product itself that is transmitted to a destination that has not been verified as requesting the transmitting data.

5.11.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required

- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.11.2.3 Guidance

Denial of service attacks over the network often use traffic reflection or amplification techniques, in which the threat actor sends packet to third party devices with a spoofed source address. The third party then sends a response packet to the spoofed source destination - a reflection attack. If the response is larger than the packet it is responding to, then it is an amplification attack. By minimising or rate-limiting the data sent to potentially spoofed source addresses, a product can reduce its interference with other devices.

This requirement operates at the link layer (IP) or data link layer and/or physical layer (OSI model). Interfaces of this type are relatively uncommon for the products in the scope of the present document and are mostly located outside the product, in higher layers of the network stack. Non-interference at higher layers in the network stack is the responsibility of the operational environment.

5.11.3 Mapping of requirements to use cases

Use case	REQ-NI-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.12 Attack surface minimisation

5.12.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (j).

5.12.2 REQ-ASM-01: Minimise attack surface

5.12.2.1 Requirement

Exposure of interfaces on the product shall be minimised in its secure-by-default configuration.

5.12.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required

- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.12.3 Mapping of requirements to use cases

Use case	REQ-ASM-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.13 Exploit mitigation

5.13.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (k).

5.13.2 Requirements

The following requirements address this essential cybersecurity requirement:

- REQ-ALC-01 Resilience to potentially untrusted inputs
- REQ-AP-04: Watchdog and self-initiated reset

- REQ-AP-05: Watchdog and notification of host
- REQ-MON-01: Logging

5.13.3 Mapping of requirements to use cases

Use case	REQ-ALC-01	REQ-AP-04	REQ-AP-05	REQ-MON-01
UC-VI-ISO				
UC-PH-VNI				
UC-PH-VNC	X			X
UC-PH-IOT	X			X
UC-PH-IRO	X	X		X
UC-PH-EDG	X		X	X
UC-PH-HRO	X	X		X
UC-PH-ISP	X	X		X
UC-VI-VDC	X		X	X
UC-VI-VMW	X		X	X
UC-VI-VMC	X		X	X
UC-VI-VII	X		X	X
UC-PH-SMW	X	X		X
UC-PH-SME	X	X		X
UC-PH-ATM	X		X	X
UC-PH-SPI	X		X	X
UC-VI-VPN	X		X	X
UC-PH-MOB	X		X	X
UC-PH-GPI	X		X	X
UC-PH-USB	X		X	X
UC-PH-STA	X		X	X
UC-PH-HRO	X	X		X

5.14 Monitoring

5.14.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (l).

5.14.2 REQ-MON-01: Logging

5.14.2.1 Requirement

The product shall record cybersecurity-relevant internal events. The product shall provide an opt-out mechanism.

5.14.2.2 Applicability

- UC-VI-ISO: not required
- UC-PH-VNI: not required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required

- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.14.3 Mapping of requirements to use cases

Use case	REQ-MON-01
UC-VI-ISO	
UC-PH-VNI	
UC-PH-VNC	x
UC-PH-IOT	x
UC-PH-IRO	x
UC-PH-EDG	x
UC-PH-HRO	x
UC-PH-ISP	x
UC-VI-VDC	x
UC-VI-VMW	x
UC-VI-VMC	x
UC-VI-VII	x
UC-PH-SMW	x
UC-PH-SME	x
UC-PH-ATM	x
UC-PH-SPI	x
UC-VI-VPN	x
UC-PH-MOB	x
UC-PH-GPI	x
UC-PH-USB	x
UC-PH-STA	x
UC-PH-SNS	x

5.15 Factory reset and data portability

5.15.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (m).

5.15.2 REQ-SDT-01 Secure deletion

5.15.2.1 Requirement

The product shall automatically delete all user data and settings and restore to its secure-by-default state after at least one of:

- 1) a power cycle; or
- 2) a specific reset command; or
- 3) a reinstallation, if necessary with a specified delete option; or
- 4) a specific delete command.

5.15.2.2 Applicability

This requirement applies to products with the capability for the user to write data and/or settings that fall within the following use cases:

- UC-VI-ISO: required
- UC-PH-VNI: required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.15.3 REQ-SDT-02 Secure data read provided by operational environment

5.15.3.1 Requirement

The product shall provide a method by which an authorized user can securely read all data and settings from the product.

5.15.3.2 Applicability

This requirement applies to products with the capability for the user to write data and/or settings that fall within the following use cases:

- UC-VI-ISO: required
- UC-PH-VNI: required
- UC-PH-VNC: required
- UC-PH-IOT: required
- UC-PH-IRO: required
- UC-PH-EDG: required
- UC-PH-HRO: required
- UC-PH-ISP: required
- UC-VI-VDC: required
- UC-VI-VMW: required
- UC-VI-VMC: required
- UC-VI-VII: required
- UC-PH-SMW: required
- UC-PH-SME: required
- UC-PH-ATM: required
- UC-PH-SPI: required
- UC-VI-VPN: required
- UC-PH-MOB: required
- UC-PH-GPI: required
- UC-PH-USB: required
- UC-PH-STA: required
- UC-PH-SNS: required

5.15.4 Mapping of requirements to use cases

Use case	REQ-SDT-01	REQ-SDT-02
UC-VI-ISO	X	X
UC-PH-VNI	X	X
UC-PH-VNC	X	X
UC-PH-IOT	X	X
UC-PH-IRO	X	X
UC-PH-EDG	X	X
UC-PH-HRO	X	X
UC-PH-ISP	X	X
UC-VI-VDC	X	X
UC-VI-VMW	X	X
UC-VI-VMC	X	X
UC-VI-VII	X	X
UC-PH-SMW	X	X
UC-PH-SME	X	X
UC-PH-ATM	X	X
UC-PH-SPI	X	X
UC-VI-VPN	X	X
UC-PH-MOB	X	X
UC-PH-GPI	X	X
UC-PH-USB	X	X
UC-PH-STA	X	X
UC-PH-SNS	X	X

6 Assessment criteria for compliance with technical requirements

6.1 Introduction to the assessment and compliance criteria

6.1.1 General

This clause provides objective and reproducible assessment criteria to determine whether a product complies with the technical security requirements of clause 5.

For each cybersecurity requirements defined in clause 5, the following clauses specify assessment criteria to determine if the technical requirement is met.

The assessment criteria for each security requirements are described in a structured manner, as follows:

- **Assessment reference:** Refers to the identifier of the concerned technical requirement.
- **Assessment objective:** Defines the security property or capability that shall be verified, ensuring that the assessment remains focused on the intent of the requirement.
- **Assessment preparation:** Describes the environment, setup, and preconditions required before executing the test with a view to guaranteeing consistent evaluation results. It includes the following elements as applicable:
 - Test environment: Describe the hardware, software, and network setup used for the assessment, including versions, topology, and any relevant dependencies.
 - Preconditions: Specify any configurations, credentials, or operational states that should be established before the test (e.g. product initialized, certificates loaded, user roles created).
 - Required tools: Identify the tools or software necessary to perform the assessment (e.g. vulnerability scanners, protocol fuzzers, traffic analysers, static code analysers, cryptographic test suites).

- Required information/documentation for the assessment: Specify all information that is necessary to perform the assessment.
- Reference any vendor-provided setup guides, configuration instructions, or operational manuals, as well as any relevant standards or technical notes, that define how the product shall be configured or operated for the assessment.
- **Assessment activities:** Provides execution steps to be performed such that the same assessment verdict would be reached when repeating these steps now or at a later point in time. Assessment activities may include, as applicable:
 - Review information/documentation for the assessment to confirm that the described implementation matches the requirement (e.g. verify that the security architecture document specifies TLS 1.2 or higher for all external interfaces, or that the password policy aligns with the defined threshold).
 - Perform security functional tests to verify the completeness and correctness of the information/documentation for the assessment.
 - Perform security functional or penetration tests to verify that implemented controls are correctly implemented e.g. to prevent unauthorized access or data modification (e.g. via attempting to log in with invalid credentials to test lockout enforcement or trying to modify protected configuration files without administrative privileges).
 - Analyse code or binaries to identify potential security weaknesses or misconfigurations (e.g. perform static analysis to detect hardcoded credentials or use dynamic analysis tools to identify buffer overflow or injection vulnerabilities).
 - Inspect configurations to ensure that required security parameters are correctly applied (e.g. check that weak cipher suites are disabled, two-factor authentication is enabled, and least-privilege access controls are configured in the system).
 - Observe runtime behaviour to confirm that protections such as encryption, authentication, and integrity verification operate as intended (e.g. monitor network traffic to ensure data in transit is encrypted or observe system logs to verify successful validation of digital signatures during startup).
- **Assessment verdict:** Defines the pass/fail criteria.
 - **Pass:** The assessment is considered passed if the product demonstrably fulfils the requirement and meets the defined security thresholds. Examples of such thresholds include:
 - Minimum cryptographic strength (e.g. AES-128 or higher);
 - Password policy limits (e.g. minimum of 12 characters);
 - Login protection mechanisms (e.g. account lockout after five consecutive failed attempts);
 - Resistance to a specified attack potential (e.g. equivalent to CSA High/AVA_VAN.3 or higher).
 - **Fail:** The assessment is considered failed if the requirement is not fulfilled, or if the defined security thresholds are not achieved (e.g. insufficient key length, missing authentication enforcement, or inadequate resistance to the required attack potential).
- **Assessment evidence:** Defines the artefacts and documentation collected to demonstrate that the requirement has been assessed and fulfilled. The evidence shall be sufficient to enable independent verification of the assessment results and to demonstrate compliance with the relevant CRA essential requirements. The supporting evidence include, where applicable:
 - Test or assessment reports showing the steps performed and results obtained;
 - Logs, configuration files, or audit traces demonstrating the implementation of the requirement;
 - Screenshots, captures, or console outputs confirming the correct execution or protection behaviour;
 - Relevant vendor or design documentation describing the applied security measures;

This clause details the assessment process for compliance with the cybersecurity requirements specified in clause 5 of the present document. Each assessment corresponds to a mitigation defined in clause 5 and specifies the activities, verdict criteria, and supporting evidence required to determine conformity.

6.1.2 Guidance for identifying interfaces or data processing

Some assessments require compiling a list of interfaces provided by or data processing done by the product. These are not limited to those described in accompanying product documentation, if any.

Some sources for compiling these lists may include, where available:

- documentation accompanying product
- product technical documentation
- product functions
- product interfaces
- product configuration
- product metrics
- product logs
- product binaries
- product source code
- data transmitted by the product
- data stored by the product
- network scanners
- packet sniffers
- system bus scanners
- reverse-engineering tools
- penetration testing tools
- vulnerability testing tools
- manual testing
- custom test programs

6.2 Appropriate level of cybersecurity

6.2.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements of clause 5.2.1 relating to the CRA [i.1], Annex I Part I (1).

6.2.2 REQ-ALC-01 Resilience to potentially untrusted inputs

6.2.2.1 Objective

Secure design and development.

6.2.2.2 Preparation

Identify all sources of untrusted input to the product. For each source of untrusted input, identify fields in the inputs that are used for:

- calculation of memory accesses
- allocation of product resources
- incrementing or decrementing of internal counters
- creating or populating internal data structures

For each source of untrusted input, the product shall be assessed using one or more appropriate assessment techniques to verify that the input validation and processing are implemented correctly:

- 1) For each identified field, identify a set of inputs that contains at least one input that fulfils each of the following descriptions, if and only if the description is applicable to the field, condition can be exercised deterministically by providing specific input values, the described values exist, and they are possible to send as input:
 - the maximum **valid** value or length of input for that field
 - the minimum **valid** value or length of input for that field
 - the next value/length of input above the minimum valid value
 - the next value/length of input below the minimum valid value
 - the next value/length of input below the maximum valid value
 - the next value/length of input above the maximum valid value
 - the maximum **possible** value or length of input for that field
 - the minimum **possible** value or length of input for that field
 - the next value/length of input above the minimum possible value
 - the next value/length of input below the maximum possible value
 - a representative selection of other valid and invalid values or input lengths for that field
 - values that could cause overflow or underflow of internal counters
 - values that are inconsistent with other values in the input
- 2) Coverage-guided fuzzing reaching at least a 50 % of code coverage of the interface code
- 3) Static analysis on the codebase with source code analysis tool that detects code that may produce common memory errors, such as:
 - buffer overflow
 - out-of-bounds
 - use after free
 - double free
 - use of uninitialized variables
 - dereference of invalid pointer

Identify the acceptable behaviour(s) of the product in response to the inputs that would be consistent with validating the input and mitigating the cybersecurity risks of untrusted input. Identify a method of sending these inputs to the product and recording the responses. Set up this testing environment.

6.2.2.3 Activities

Perform the selected assessment technique(s) for each identified source of untrusted input and record the corresponding results:

- 1) For input generation techniques, send the identified inputs to the product and record its response.
- 2) For coverage-guided fuzzing, record the achieved code coverage and any identified findings.
- 3) For static analysis, record the analysis results and any identified findings.

6.2.2.4 Verdict

PASS if the selected assessment technique(s) have been successfully performed and the results demonstrate that the product responds in a manner consistent with the identified acceptable behaviour and mitigates the cybersecurity risks associated with untrusted input.

Otherwise FAIL.

6.2.2.5 Evidence

- Description of identified fields of untrusted input
- Analysis of sources of untrusted input for identified inputs
- Sufficiency analysis of analysis of untrusted sources of input
- Description of test inputs and acceptable behaviours
- Logs of testing inputs and recording behaviour
- Sufficiency analysis of testing logs

6.2.2.6 Guidance

Assessment can often be done with minimal effort using commonly available fuzzer or security testing tools or adapting an existing product test suite. It can also be done by hand.

Examples of each of the types of input:

- calculation of memory accesses: length, index, hash table lookup values, packet reassembly
- allocation of product resources: buffer length, number of packet descriptors, buffers for reassembly of fragmented packets, CPU-intensive cryptographic operations
- incrementing or decrementing of internal counters: packet counters, event counters
- creating or populating internal data structures: parameters for creating an array of packet descriptors

The list of inputs to test includes some types of input that may not exist or be possible to send. For example, if the maximum **valid** value is also the maximum **possible** value, then it is not possible to send the next value higher than the maximum value. These values do not need to be tested.

Secure design and development practices such as static analysis or secure compilation flags may assist in the fulfilment of this requirement by identifying potential sources of untrusted input for review, as well as automatically validating and mitigating invalid values.

Acceptable behaviours might include:

- Rejection of input and returning an error
- Silent discard of input
- Correction of input

- Dropping a packet and incrementing an error counter
- Emitting a notification when a counter rolls over
- Crashing and restarting
- Terminating a thread

6.3 No known exploitable vulnerabilities

6.3.1 Overview

This clause provides assessment criteria for compliance with the requirements in clause 5.3 relating to the CRA [i.1], Annex I Part I (2) (a).

6.3.2 REQ-KEV-01 No known exploitable vulnerabilities

6.3.2.1 Objective

Prevent exploitation of known exploitable vulnerabilities.

6.3.2.2 Preparation

Using the product's SBOM if applicable, HBOM if applicable, and relevant publicly accessible vulnerability databases (e.g. [GCVE](#), [EUVD](#)), compile a list of target components. Identify a representative list of vulnerabilities that constitute known exploitable vulnerabilities according to the product's cybersecurity risk assessment, including some that became known close in time to the date of placement of the tested product on the market, but none that became known to be exploitable vulnerabilities after that date. Select the appropriate testing methodology to verify the mitigation of these vulnerabilities.

6.3.2.3 Activities

If any vulnerabilities are identified, run the tests on a product placed on the market, and compare the results with the identified list of known exploitable vulnerabilities. For any false positives, document why the result does not indicate the presence of a known exploitable vulnerability.

6.3.2.4 Verdict

PASS if **any** of the following are fulfilled:

- no vulnerabilities meeting the described criteria were identified;
- no vulnerabilities were found during testing; or
- all found vulnerabilities satisfy **any** of the following:
 - are identified as a false positive; or
 - satisfy the elapsed time since discovery exception; or
 - satisfy the elapsed time before public disclosure exception; or
 - satisfy the mitigation and documentation exception

Otherwise FAIL

6.3.2.5 Evidence

- Documented vulnerability handling policy

- Product SBOM, if applicable
- Product HBOM, if applicable
- Description of testing tools used or manual test plan
- Test reports/scan results
- Sufficiency analysis of analysis of any detected vulnerabilities for false positives, elapsed time exceptions; or documented mitigations

6.3.2.6 Guidance

Known exploitable vulnerabilities may be identified by manual security testing, automated vulnerability scanners; or custom tests.

6.4 Secure by default configuration

6.4.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements of clause 5.4 relating to the CRA [i.1], Annex I Part I (2) (b).

6.4.2 REQ-SBD-01: Provide methods to protect or disable interfaces

6.4.2.1 Objective

Secure by default configuration.

6.4.2.2 Preparation

Identify all debug or management interfaces in the product. Categorize them into those that can be protected or disabled and those that cannot. For those that can be protected or disabled, identify methods to do so, using as necessary or available.

Identify an operational environment that permits testing these methods. Identify any necessary configuration, inputs; or other preparation for attempting to access these interfaces without authorization. Install the product in the identified operational environment.

6.4.2.3 Activities

For each identified interface that can be disabled or protected, and for each method, disable or protect each interface, carry out the identified testing preparations, then attempt to use the interface without authorization. For each identified interface that cannot be disabled or protected, analyse whether backwards compatibility prevents the interface from being disabled.

6.4.2.4 Verdict

PASS if **all** of the following are fulfilled:

- all attempts to use debug or management interfaces without authorization fail; and
- for all debug or management interfaces that cannot be disabled or protected, the necessity for backward compatibility and the instructions to the user to mitigate the risk are deemed sufficient.

Otherwise FAIL

6.4.2.5 Evidence

- Documentation of and rationale for search process for interfaces
- Logs of searches for interfaces
- Description of identified interfaces
- Sufficiency analysis of rationale for interface search process
- Description of methods for protecting or disabling interfaces
- Logs or records of protecting or disabling interfaces
- Logs or records of attempts to access interfaces
- Sufficiency analysis of documentation of necessity for exposing interfaces for backward compatibility, if any

6.4.2.6 Guidance

See clause 6.1.2 "Guidance for identifying interfaces or data processing."

This requirement is intended for the use case of an integrator or distributor who may disable or protect interfaces as necessary for the use case of product in the next step of the supply chain. The initial use for the integrator is often in an operational environment in which no unauthorized users have access to the product.

Authorization may be via a variety of methods: passwords, physical access to the product, host system access, etc. An attempt to access without authorization may involve trying to login without the password, attempting to use a physical interface without physical access to the device; or using an interface available to the host system without authorization on the host system.

6.4.3 REQ-SBD-02: Protect or disable access to debug or management interfaces

6.4.3.1 Objective

Secure by default configuration.

6.4.3.2 Preparation

Examine the product technical documentation to find all accessible debug or management interfaces, and which interfaces are necessary for backward compatibility. Identify which are accessible to unauthorized users in the product's intended purpose and reasonably foreseeable use.

6.4.3.3 Activities

For each debug or management interface identified in the previous step, attempt to use the interface without authorization. For any interface which is found to be usable without authorization, examine the product technical documentation for documentation of the requirement for backward compatibility and the instructions for the user to mitigate the risks.

6.4.3.4 Verdict

PASS if **all** of the following are fulfilled:

- All attempts to use debug or management interfaces not necessary for backward compatibility without authorization fail, and
- Analysis of the necessity for backward compatibility of interfaces that cannot be disabled or protected, if any, is deemed sufficient, and

- Mitigation and information for the user for any such interfaces is deemed sufficient.

Otherwise FAIL.

6.4.3.5 Evidence

- Pictures of physical interfaces to the product, if applicable
- Descriptions of identified debug or management interfaces
- Logs or records of protecting or disabling interfaces
- Logs or records of attempts to access interfaces
- Sufficiency analysis of documentation of necessity for any unauthorized access for backward compatibility, if any
- Sufficiency analysis of instructions to user for mitigating risks, if any

6.5 Security updates

6.5.1 Overview

This clause provides assessment criteria for compliance with the technical requirements in clause 5.5 relating to CRA [i.1], Annex I Part I (2) (c).

6.5.2 REQ-SU-01 Secure update provided by operational environment

6.5.2.1 Objective

Prevent exploitation of known vulnerabilities.

6.5.2.2 Preparation

Identify methods the product provides for installing updates. Identify an operational environment that permits testing these methods. Set up the product in the identified operational environment. Identify a method to verify the installation of an update (e.g. read a version number from the product). Identify an update that is not yet installed on the product.

6.5.2.3 Activities

Install the identified update for the product and use the identified method to verify it.

6.5.2.4 Verdict

PASS if verification of the installation of the update succeeds.

Otherwise FAIL.

6.5.2.5 Evidence

- Logs of reading original and updated version of product
- Security update file(s)
- Logs of update installation process

6.5.2.6 Guidance

A method of assessment might be: install one version of the firmware, read the version number from the logs of the host system, then install a different version of the firmware and read the version number from that.

6.6 Authentication and access control

6.6.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements of clause 5.6 relating to the CRA [i.1], Annex I Part I (2) (d).

6.6.2 REQ-AAC-01: Authentication and access control provided by operational environment

6.6.2.1 Objective

Prevent unauthorized access.

6.6.2.2 Preparation

Identify methods the product provides for authorization or access control of cybersecurity-relevant product assets. Identify an operational environment that permits testing these methods. Identify product assets that require authentication or access control to protect the cybersecurity of the product. Identify any necessary configuration, inputs; or other preparation for testing authentication or access control for that asset. Set up the product in the identified operational environment.

6.6.2.3 Activities

For each method and each type of product asset identified, carry out the identified testing preparations and attempt to access the product asset without the necessary authorization.

6.6.2.4 Verdict

PASS if every attempt to access the product asset without the necessary authorization fails.

Otherwise FAIL.

6.6.2.5 Evidence

- Descriptions of types of product assets requiring authorization or access control
- Records of configuration, input, and/or preparation for each test
- Logs of access attempts and their results

6.7 Confidentiality protection

6.7.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements in clause 5.7 relating to the CRA [i.1], Annex I Part I (2) (e).

6.7.2 REQ-CP-01: Confidentiality protection provided by operational environment

6.7.2.1 Objective

Protect confidentiality of data transmitted by or stored on the product.

6.7.2.2 Preparation

Identify methods the product provides for confidentiality protection of cybersecurity-relevant product assets. Identify an operational environment that permits testing these methods. Identify product assets that require confidentiality protection. For each identified asset, identify the methods to protect its confidentiality and any necessary configuration, inputs; or other preparation for testing confidentiality protection of that product asset. Install the product in the identified operational environment.

6.7.2.3 Activities

For each method and each type of data identified, carry out the identified testing preparations and attempt to read the confidentiality protected data without the necessary authorization.

6.7.2.4 Verdict

PASS if every attempt to read the confidentiality protected data without the necessary authorization fails.

Otherwise FAIL

6.7.2.5 Evidence

- Descriptions of types of data requiring confidentiality protection
- Records of configuration, input, and/or preparation for each test
- Logs of read attempts and their results

6.7.2.6 Guidance

Many products in the scope of the present document require data confidentiality protection only on data assets that are only accessible from the host system, which is usually trusted. E.g. encryption keys stored on the network interface may only be transmitted to and from the host system over the host system bus. In this situation, a cybersecurity risk assessment may conclude that, for the product integrating the network interface, the risk of an threat actor reading the data transmitted over the system bus is already low enough to present an acceptable risk without further treatment.

Examples of data that might need to be protected by the operational environment:

- Firmware on a physical network device
- Software comprising a virtual network device
- Contents of memory in the product
- Confidential cryptographic materials stored on the device
- Packet data while it is being copied (transmitted over the system bus) from the host to the network interface

Examples of attempts to read data without authorization:

- Use the operating system interface to read cryptographic material from the product without necessary operating system privileges
- Attempt to read the memory mapped to the network interface's registers and memory without the necessary memory permissions

- Attempt to decrypt encrypted data sent over the network without the private cryptographic key

6.8 Integrity protection

6.8.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements in clause 5.8 relating to the CRA [i.1], Annex I Part I (2) (f).

6.8.2 REQ-IP-01: Integrity protection provided by operational environment

6.8.2.1 Objective

Protect integrity of data transmitted by or stored on the product.

6.8.2.2 Preparation

Identify methods the product provides for integrity protection of cybersecurity-relevant product assets. Identify an operational environment that permits testing these methods. Identify product assets that require integrity protection. For each identified asset, identify the methods to protect its integrity and any necessary configuration, inputs; or other preparation for testing integrity protection of that product asset. Install the product in the identified operational environment.

6.8.2.3 Activities

For each method and each type of data identified, carry out the identified testing preparations and attempt to modify the integrity protected data without the necessary authorization.

6.8.2.4 Verdict

PASS if every attempt to modify the integrity protected data without the necessary authorization fails or is detected.

Otherwise FAIL.

6.8.2.5 Evidence

- Descriptions of types of data requiring integrity protection
- Records of configuration, input, and/or preparation for each test
- Logs of modification attempts and their results

6.8.2.6 Guidance

Many products in the scope of the present document may require data integrity protection only on data assets only accessible from the host system. E.g. encryption keys stored on the network interface may only be transmitted to and from the host system over the host system bus. In this situation, a cybersecurity risk assessment may conclude that, for the product integrating the network interface, the risk of an threat actor modifying the data transmitted over the system bus is already low enough to present an acceptable risk without further treatment.

Examples of data that might need to be protected by the operational environment:

- Firmware on a physical network device
- Software comprising a virtual network device
- Contents of memory in the product
- Confidential cryptographic materials stored on the device

- Packet data while it is being copied (transmitted over the system bus) from the host to the network interface

Examples of attempts to modify data without authorization:

- Use the operating system interface to configure the network interface without the necessary operation system privileges
- Attempt to write to the memory mapped to the network interface's registers and memory without the necessary memory permissions
- Attempt to write to the file containing the virtual network interface's executable without the necessary file system permissions

6.9 Data minimisation

6.9.1 Overview

This clause addresses the assessment criteria for compliance with the technical requirements in clause 5.9 relating to the CRA [i.1], Annex I Part I (2) (g).

6.9.2 REQ-DM-01: Minimise data processed

6.9.2.1 Objective

Minimise data processed by the product.

6.9.2.2 Preparation

Determine all data processing done by the product, using as necessary:

- product technical documentation
- product functions
- product interfaces
- data transmitted by the product
- data stored by the product
- product binaries
- source code
- other sources of product information

6.9.2.3 Activities

For each type of data processing identified, analyse its relevance and necessity for the intended purpose of the product.

6.9.2.4 Verdict

PASS if, for every type of data processing identified, the data processed is determined to be relevant and limited to what is necessary for the intended purpose of the product.

Otherwise FAIL.

6.9.2.5 Evidence

- Product information used to determine what data processing the product does

- Sufficiency analyses of relevance, limitation, and necessity of data for product purpose

6.9.2.6 Guidance

The product operation can require storing information relevant for the protocol implementation like out-of-order TCP packets, that are later recombined for the receiver as a continuous stream of information. This can be often considered to be part of the core functionality of the product.

Outside of the core functionality, the default set size of data that needs to be collected from the operation is zero. Therefore:

- Example DM-01-1: The product supports NetFlow protocol and collects information from traffic going through the interface.
- Example DM-01-2: The product is a managed interface and supports a variety of different collectable metrics which are by default off, but the collection and reporting can be activated remotely.
- Example DM-01-3: The product is purpose-built for high level application co-operation and participates on the content delivery network function by storing most frequent replies in the network interface volatile memory. The replies are served directly from the memory without relying the request forward. Key information and metrics are collected and relied for the application.

6.10 Availability protection

6.10.1 Overview

This clause provides assessment for the requirements in clause 5.10 relating to CRA [i.1], Annex I Part I (2) (h).

6.10.2 REQ-AP-01 Fast packet drop

6.10.2.1 Objective

Maintain product availability during denial-of-service attacks.

6.10.2.2 Preparation

For each type of packet format processed by the product; order the fields by least to most expensive to process, approximately.

Identify fields in the packet formats processed by the product that would make the packet invalid.

6.10.2.3 Activities

Measure the availability of the product while processing different kinds of invalid packets. Record whether invalid packets were dropped or accepted.

Analyse the availability of the product for indications that the product is doing significantly more processing of an invalid packet than necessary to reject it.

6.10.2.4 Verdict

PASS if **all** of the following are fulfilled:

- All invalid packets were rejected; and
- the availability of the product was reasonably maintained; and
- any significant reduction of availability was necessary to the product's intended purpose.

Otherwise FAIL.

6.10.2.5 Evidence

- Description of types of invalid packets
- Logs of packet rejection or acceptance
- Logs of measurements of product availability
- Sufficiency analysis of product availability

6.10.2.6 Guidance

One method to probe the efficiency of invalid packet processing is to construct pairs of invalid packet formats that could both be rejected with the same process, but one packet could potentially require significantly more resources to process if the packet processing was done in a less efficient order. Then send a large number of each kind of packet to the device and measure resource usage.

E.g. given a packet with a 4 byte destination address field and a 1 000 byte payload with a checksum, create a packet with an invalid address field and a correct checksum and a packet with an invalid address and an invalid checksum. Then measure the packet processing rate for each kind of packet. This may reveal whether the packet rejection code is unnecessarily validating the packet checksum for a packet it will reject anyway.

6.10.3 REQ-AP-02 Limit resource usage by incoming network data

6.10.3.1 Objective

Maintain product availability during denial-of-service attacks.

6.10.3.2 Preparation

Identify product resources that may be exhausted by data received over the network. For each resource, prepare a sequence of network data that if received by the product (possibly with specific timing) will exhaust that resource. Identify ways to measure the availability of product functions and monitor any impact on product cybersecurity. Identify the performance of the product with maximum sustainable usage of each resource by incoming network data.

6.10.3.3 Activities

For each resource, send the network data that will exhaust that resource to the interface while measuring and monitoring availability and cybersecurity. Compare the results to the performance with the maximum sustainable usage of that resource. Analyse the monitoring for any degradation to cybersecurity.

6.10.3.4 Verdict

PASS if **all** of the following are fulfilled:

- For each resource and network data tested:
 - the availability of the product was not significantly degraded compared to the maximum sustainable usage; and
 - the cybersecurity of the product was not compromised.

Otherwise FAIL.

6.10.3.5 Evidence

- Set of inputs
- Logs of measurements and monitoring of resource usage, availability, and cybersecurity
- Explanation of choice of metrics

- Sufficiency analysis of availability
- Sufficiency analysis of cybersecurity

6.10.3.6 Guidance

Some examples of internal resources that may be exhausted:

- packet buffers
- descriptor rings
- processor time

Some ways to exhaust the resources are to send packets:

- faster than the product can process them
- with the maximum valid length as fast as possible
- that are fragmented and need to be reassembled in the network interface
- that are encrypted
- that contain a large number of unusual or optional fields

Some ways to measure the cybersecurity of the product:

- data transferred to the host or network are correct
- product does not reset
- product continues to function correctly
- product metrics are correct and consistent with input

6.10.4 REQ-AP-03 Availability protection provided by operational environment

6.10.4.1 Objective

Maintain product availability during denial-of-service attacks.

6.10.4.2 Preparation

Identify methods the product provides for availability protection of cybersecurity-relevant product assets. Identify an operational environment that permits testing these methods. Identify product assets that require availability protection. For each identified asset, identify the methods to protect its availability and any necessary configuration, inputs; or other preparation for testing availability protection of that product asset. Install the product in the identified operational environment.

6.10.4.3 Activities

For each method and each type of asset identified, carry out the identified testing preparations and measure its availability.

6.10.4.4 Verdict

PASS if for all tests, the availability of the product asset is deemed sufficient.

Otherwise FAIL.

6.10.4.5 Evidence

- Descriptions of types of data requiring integrity protection
- Records of configuration, input, and/or preparation for each test
- Logs of availability measurements
- Sufficiency analysis of analysis of availability of product asset

6.10.4.6 Guidance

See the other requirements in the present clause for examples of testing availability of product assets.

6.10.5 REQ-AP-04: Watchdog and notification of host

6.10.5.1 Objective

Maintain product availability during denial-of-service attacks.

6.10.5.2 Preparation

Identify the conditions that indicate that the product is not performing its functions sufficiently. Identify representative methods of causing the product to enter that condition.

6.10.5.3 Activities

Use each identified method and monitor notifications to the host.

6.10.5.4 Verdict

PASS if, after causing the product to enter each condition, the host system receives a notification.

Otherwise FAIL

6.10.5.5 Evidence

- Description of identified conditions and methods
- Log of using method
- Log of notifications received on host system
- Log of device activity and/or state
- Packet captures

6.10.5.6 Guidance

Forcing the product into a non-functional state can often be done by enabling and using testing interfaces.

6.10.6 REQ-AP-05: Watchdog and self-initiated reset

6.10.6.1 Objective

Maintain product availability during denial-of-service attacks.

6.10.6.2 Preparation

Identify the conditions that indicate that the product is not performing its functions sufficiently. Identify representative methods of causing the product to enter that condition.

6.10.6.3 Activities

Use each identified method and monitor the product functions.

6.10.6.4 Verdict

PASS if, after causing the product to enter each condition, the product regains the ability to perform its functions without outside intervention.

Otherwise FAIL

6.10.6.5 Evidence

- Description of identified conditions and methods
- Log of using method
- Log of device activity and/or state
- Packet captures

6.11 Non-interference

6.11.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (i).

6.11.2 REQ-NI-01: Minimise data transmitted to unverified sources

6.11.2.1 Objective

Minimise negative impact on other devices or services.

6.11.2.2 Preparation

Identify interfaces that may transmit data originating from the product itself in reply to incoming data to addresses that have not been verified as requesting the transmitted data. Identify network input that may cause the interface to transmit data in such a manner.

6.11.2.3 Activities

For each identified network input, transmit the input to the interface and record any data the product transmits in response. Analyse the amount of data sent in response in the context of the product function and cybersecurity risk assessment.

6.11.2.4 Verdict

PASS if the response is consistent with reasonable minimisation of data in the response.

Otherwise FAIL.

6.11.2.5 Evidence

- Description of identified interfaces
- Description of methods for identifying interfaces
- Sufficiency analysis of methods for identifying interfaces
- Description of identified inputs
- Packet captures or other appropriate logs of the data transmitted
- Sufficiency analysis of analysis of amount of data in response

6.12 Attack surface minimisation

6.12.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (j).

6.12.2 REQ-ASM-01: Minimise attack surface

6.12.2.1 Objective

Minimise attack surface.

6.12.2.2 Preparation

Identify all exposed interfaces in the product in its secure-by-default configuration, including different run-time states such as initial configuration, startup, in use, idle, shutdown, and reset, if applicable. Use appropriate tools and methodology to search for interfaces that may have accidentally or unintentionally exposed and that could reasonably be found by a threat actor under the conditions of the manufacturer's cybersecurity risk assessment.

6.12.2.3 Activities

For each identified interface, analyse if the exposure of the interface is necessary for the product's intended purpose and reasonably foreseeable use in its secure-by-default configuration, connecting it to specific product functions and comparing with any obvious reasonable alternatives with smaller attack surface.

6.12.2.4 Verdict

PASS if for each identified exposed interface, the analysis for exposure of the interface concludes that it is necessary and that there is no obvious reasonable alternative with smaller attack surface.

Otherwise FAIL

6.12.2.5 Evidence

- Documentation of and rationale for search process for interfaces
- Logs of searches for interfaces
- Description of identified interfaces
- Sufficiency analysis of rationale for interface search process
- Analysis of necessity of and alternatives to each identified interface
- Sufficiency analysis of necessity analysis for identified exposed interfaces

6.12.2.6 Guidance

See clause 6.1.2 "Guidance for identifying interfaces or data processing".

6.13 Exploit mitigation

6.13.1 Overview

This clause addresses the requirements in the CRA [i.1], Annex I Part I (2) (k).

No additional assessment is necessary for the requirements in this clause, as the included requirements are assessed in other clauses of the present document.

6.14 Monitoring

6.14.1 Overview

This clause provides assessment for the requirements in clause 5.14 relating to CRA [i.1], Annex I Part I (2) (l).

6.14.2 REQ-MON-01 Logging

6.14.2.1 Objective

Monitoring and recording cybersecurity-relevant events.

6.14.2.2 Preparation

Identify cybersecurity-relevant events that should be recorded on the product or communicated to the operational environment. Identify methods to trigger each event. Identify the opt-out mechanism.

6.14.2.3 Activities

For each type of cybersecurity-relevant internal event:

- 1) trigger the event on the product; and
- 2) check if the event was recorded internally on the product; or the product sent a notification to the host; or the event was recorded in some other manner.

Activate the opt-out mechanism, trigger a cybersecurity-relevant internal event, and observe whether the event was recorded.

6.14.2.4 Verdict

PASS if **any** of the following are fulfilled:

For each triggered event:

- the product recorded the event internally; or
- the product notified the host of the event; or
- the event was recorded in some other manner; or
- the opt-out was active and the event was not recorded.

Otherwise FAIL.

6.14.2.5 Evidence

- Description of identified events
- Method of triggering events
- Logs of triggering events
- Logs of internal event records and/or host notifications

6.14.2.6 Guidance

Examples of cybersecurity-relevant events:

- configuration changes
- state changes
- data transmitted
- packet counters
- invalid packets
- dropped packets
- resource exhaustion
- cryptographic material changes

The opt-out mechanism, like the logging itself, may be provided by the operational environment (e.g. disable the system log or exclude a type of log message from being saved).

6.15 Factory reset and data portability

6.15.1 Overview

This clause provides assessment for the requirements in clause 5.15 relating to CRA [i.1], Annex I Part I (2) (m).

6.15.2 REQ-SDT-01 Secure deletion

6.15.2.1 Objective

Secure deletion.

6.15.2.2 Preparation

Identify every type of stored data or setting that may be changed by the user on the product, how to store it on the product, and how to read it from the product. Identify a method to securely delete user data and settings and reset the product to its secure-by-default state.

6.15.2.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

- 1) record the value of the setting in the secure-by-default configuration of the product
- 2) write an instance of the data or setting stored on the product that is different from the default

Once all types of user data or settings have been written and read, use the identified method to delete all user data and settings and reset to a secure-by-default configuration. Record the value of each type of user data or setting again. Compare with the original records for each type of user data or setting in its secure-by-default state.

6.15.2.4 Verdict

PASS if **all** of the following are fulfilled:

- All user data and settings tested have been deleted; and
- All settings data and settings tested are restored to a secure-by-default state.

Otherwise FAIL.

6.15.2.5 Evidence

- Description of each type of user data or setting written
- For each type, record of original value, written value, and value after deletion and reset to secure-by-default method
- Comparison and analysis of different values
- Sufficiency analysis of comparison

6.15.2.6 Guidance

Some user settings or data (e.g. dates, randomly generated values, installation logs) may differ harmlessly between different secure-by-default configurations, so a direct comparison of the initial and final values may show some differences in a conforming product.

6.15.3 REQ-SDT-02 Secure data read provided by operational environment

6.15.3.1 Objective

Secure data read.

6.15.3.2 Preparation

Identify every type of stored data or setting that may be changed by the user on the product, how to store it on the product, and how to read it from the product.

6.15.3.3 Activities

For each type of user data or setting that may be stored and changed by the user on the product:

- 1) record the value of the setting in the secure-by-default configuration of the product
- 2) write an instance of the data or setting stored on the product that is different from the default

Once all types of user data or settings have been written and read, use the identified method to read all user data and settings. Compare with written value and the original records for each type of user data or setting in its secure-by-default state.

6.15.3.4 Verdict

PASS if all user data and settings read are consistent with the user data and settings written.

Otherwise FAIL.

6.15.3.5 Evidence

- Description of each type of user data or setting written
- For each type, record of original value, written value, and read value
- Comparison and analysis of values
- Sufficiency analysis of comparison

Annex A (informative): Relationship between the present document and the essential cybersecurity requirements of EU Regulation (EU) 2024/2847

The present document has been prepared under the Commission's Standardisation request C(2025) 618 final [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (CRA) [i.1].

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

**Table A.1: Relationship between the present document and
the requirements of Regulation (EU) 2024/2847 - the Cyber Resilience Act**

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (1)	"Products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks."	Clauses 5.2 and 6.2	
Annex I, Part I, (2)(a)	"Products with digital elements shall be made available on the market without known exploitable vulnerabilities."	Clauses 5.3 and 6.3	
Annex I, Part I, (2)(b)	"Products with digital elements shall be made available on the market with a secure by default configuration, unless otherwise agreed between manufacturer and business user in relation to a tailor-made product with digital elements, including the possibility to reset the product to its original state."	Clauses 5.4 and 6.4	
Annex I, Part I, (2)(c)	"Products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including, where applicable, through automatic security updates that are installed within an appropriate timeframe enabled as a default setting, with a clear and easy-to-use opt-out mechanism, through the notification of available	Clauses 5.5 and 6.5	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
	updates to users, and the option to temporarily postpone them".		
Annex I, Part I, (2)(d)	"Products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access".	Clauses 5.6 and 6.6	
Annex I, Part I, (2)(e)	"Products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by best practice mechanisms, and by using other technical means."	Clauses 5.7 and 6.7	
Annex I, Part I, (2)(f)	"Products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions."	Clauses 5.8 and 6.8	
Annex I, Part I, (2)(g)	"Products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation)."	Clauses 5.9 and 6.9	
Annex I, Part I, (2)(h)	"Products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks."	Clause 5.10 and 6.10	
Annex I, Part I, (2)(i)	"Products with digital elements shall minimise the negative impact by the products themselves or connected products on the availability of services provided by other products or networks."	Clauses 5.11 and 6.11	

Description	Essential Requirements of Regulation (EU) 2024/2847	Clause(s) of the present document	Remarks / Notes
Annex I, Part I, (2)(j)	"Products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces."	Clauses 5.12 and 6.12	
Annex I, Part I, (2)(k)	"Products with digital elements shall be designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques."	Clauses 5.13 and 6.13	
Annex I, Part I, (2)(l)	"Products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user."	Clauses 5.14 and 6.14	
Annex I, Part I, (2)(m)	"Products with digital elements shall provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner."	Clauses 5.15 and 6.15	

Key to columns:

Description A textual reference to the requirement.

Requirements of Regulation

Identification of point(s) defining the requirement in Regulation (EU) 2024/2847 - the Cyber Resilience Act.

Clause(s) of the present document

Identification of clause(s) addressing the requirement in the present document

Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list published in the Official Journal of the European Union. Users of the present document should consult frequently the latest list published in the Official Journal of the European Union.

Other Union legislation may be applicable to the product(s) falling within the scope of the present document.

Annex B (informative): Security analysis

B.0 Overview

This annex applies state of the art methodology to identify assets, threats, identify and evaluate risk factors, and associate risk factor levels with different use cases identified in the product context. This security analysis informs the applicability of the technical requirements.

The security analysis in this annex represents a risk assessment done by the standardisers solely for the purpose of informing the applicability of technical requirements.

A list of product assets are used to identify potential threats to the product. The assumptions are used to define the scope of potential threats that are addressed by this security analysis.

Risk factor levels for each use case are determined by using the definition of the use case to choose a risk factor level that most accurately represents the highest risk for that use case. The use case is restricted by the intended purpose and reasonably foreseeable use as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat. This security analysis uses the Likelihood and Impact of each threat to identify specific technical requirements that treat that risk.

B.1 Assets

B.1.1 Data

- Firmware/software
- Device identity (MAC address, etc.)
- Device configuration (transmit power/channel configuration/options)
- Metrics
- Cryptographic material for validation of access to itself (firmware, management access)
- Cryptographic material for packet encryption or network access
- Device driver shipped with device or stored on device, if any
- All accessible host data and functions
- Data transmitted over the network
- Data transmitted to the host system
- Device driver executable

B.1.2 Product functions

B.1.2.1 Physical network interface essential functions

- Receive and transmit data between host and network at data link layer
- Execute commands from the host (power, config, tx/rx)

- Read/write/etc. host resources accessible from card

Optional:

- Send commands/trigger actions on host (e.g. wake on network messages)
- Offload of packet processing at layers higher than data link
- Packet encryption at data link layer
- Packet encryption at higher layer
- Keep and report metrics
- Update firmware with image provided by host
- Manage firmware update autonomously (image received from the network)
- Provide remote management interface
- Implement/support network boot

B.1.2.2 Device driver essential functions

- Interact with operating system
- Copy data between network device interface and host memory
- Handle interrupts, set up tx/rx, keep/copy metrics, etc.
- Configure the network interface
- Monitor device interface and network interface health
- Interact with operating system and user programs

Optional:

- Set up and execute firmware update/load with image provided by host software
- Support optional features of the underlying device hardware or software
- Provision cryptographic material to device (network access, management, packet encryption)
- Generate log messages
- Use debug interfaces

B.1.2.3 Virtual network interface essential functions

- Process/move around data sent to virtual network interface
- Interact with operating system
- Configure the network interface
- Keep and report metrics
- Read/write/etc host resources accessible from virtual network interface

Optional:

- Packet encryption
- Provision cryptographic material (network access, management, packet encryption)

- Generate log messages

B.1.3 Hardware

- Physical transmission media interface
- Connection to host system
- Processors
- Memory

B.2 Risk factors

B.2.1 List of risk factors

The risk factor levels determine the impact and likelihood of each threat in this security analysis. Risk factor levels also specify which requirements reduce the risk of each threat to satisfy all of the technical cybersecurity requirements in clause 5.2.

Risk factors may increase the likelihood of an incident, increase the impact of an incident; or both. As a result, different mitigation strategies may be more or less relevant to different risk factors.

The overall risk related to each use case should be considered as a result of combining risk factors affecting both likelihood and impact of an incident.

B.2.2 [RF-PHY] Physical access to product

Description: Exposure of the product to physical access by unauthorized agents.

Rationale: More unauthorized agents with physical access to the product increases the likelihood of an attack via the product's physical interfaces.

- **[RF-PHY-L-0]** Foreseeable use is physical access only to authorized users or not a physical network interface
- **[RF-PHY-L-1]** Foreseeable use is incidental physical access by unauthorized users
- **[RF-PHY-L-2]** Foreseeable use is prolonged physical access by unauthorized users

B.2.3 [RF-NET] Access to attached network

Description: How publicly accessible the attached network is.

Rationale: The more unrestricted the access to the attached network is, the more likely a threat actor can send packets to the device.

- **[RF-NET-L-0]** Foreseeable use is in an isolated private network
- **[RF-NET-L-1]** Foreseeable use is in a private network with filtered connection to public network
- **[RF-NET-L-2]** Foreseeable use is in a public network

B.2.4 [RF-COM] Complexity of product functions

Description: How complex the available product functions are in its secure-by-default configuration.

Rationale: More complex functions means increased likelihood of errors in the implementation and more attack surface.

- **[RF-COM-L-0]** Product implements minimal features necessary to send/recv packets but not the features in COM-L-1 or COM-L-2
- **[RF-COM-L-1]** Product implements features such as simple performance improvements which are more complex than COM-L-0 but less complex than those in COM-L-2
- **[RF-COM-L-2]** Product implements complex features such as encryption functions, RTOS managing radio, PXE boot, remote management, etc.

B.2.5 [RF-HOS] Impact of access to host system assets

Description: Measures the impact of the product's access to host system assets, which is a combination of the level of access and the sensitivity of the host system assets.

The communications bus used to connect to the host system usually controls the level of access. E.g. a network interface connected by USB versions below 4.0 can only access system resources via the host USB stack software, but a network interface on a PCIe bus (including tunnelled over USB 4.0) or a virtual network interface that has privileged access to the host system can write any part of host system memory. The sensitivity of the host assets changes the impact of this risk factor.

Rationale: An attacker can get access to host system functions via the product's access.

- **[RF-HOS-L-0]** Little or no access to the host; or little or no sensitivity of host assets
- **[RF-HOS-L-1]** High degree of access to host and moderate sensitivity of host assets; or moderate access and high sensitivity
- **[RF-HOS-L-2]** High degree of access and high sensitivity of host assets

B.2.6 [RF-FUN] Sensitivity of functions of product

Description: Sensitivity of functions of the product.

Rationale: The more sensitive the functions of the product, the higher the impact of unavailability or degradation of its functions.

- **[RF-FUN-L-0]** Foreseeable use is for unimportant functions
- **[RF-FUN-L-1]** Foreseeable use is for moderately sensitive functions, such as encrypting transmitted data
- **[RF-FUN-L-2]** Foreseeable use is for highly sensitive functions, such as primary management interface of host system

B.2.7 [RF-ADM] Availability and skill of administration

Description: What the availability and skill of administration is for the product.

Rationale: Skilled, fully resourced administration allows more risk transfer and can reduce the impact of incidents.

Type: Affects likelihood and impact of all attacks.

- **[RF-ADM-L-0]** Foreseeable use is with fully resourced professional administration
- **[RF-ADM-L-1]** Foreseeable use is with professional administration with limited resources
- **[RF-ADM-L-2]** Foreseeable use is with unskilled or no administration

B.2.8 [RF-INI] Operational environment of initial setup

Description: The security of the operational environment in which the product is initially used and configured.

Rationale: A more secure operational environment for initial use and configurations affects the risk of the secure-by-default configuration.

- **[RF-INI-L-0]** Product is initially used and configured in an extremely secure operational environment, such as a professional engineer in an integrator's factory
- **[RF-INI-L-1]** Product is initially used and configured in a moderately secure operational environment, such as a computer professional at home
- **[RF-INI-L-2]** Product is initially used and configured in an insecure operational environment, such as an unskilled user installing it in a laptop while in a cafe

B.3 Assumptions

B.3.1 Overview

Assumptions are used to define the scope of the potential threats addressed by this security analysis.

B.3.2 Proper host system

The host system the product is attached to is trustworthy.

B.3.3 Proper administrator

The product administrator is not intentionally hostile and is engaging in good faith efforts to administer the product properly.

B.3.4 Attacker has limited physical access to product

An attacker will have only temporary physical access to the product.

B.3.5 Attacker has limited resources

An attacker will use limited resources in proportion to the value of the assets of the product in each use case.

B.4 Threats and security analysis of threats

B.4.1 General

The approach to listing threats is to separate them by mitigation so that they may be associated with mitigations more directly.

For the purposes of the list of threats, the product includes:

- the physical network interface (if any)
- the device driver (if any)
- the virtual network interface (if any)

B.4.2 Security analysis methodology

Risk factor levels for each use case are determined by reading the descriptions for each risk factor level and choosing the one that most accurately represents the highest risk for the intended purpose and reasonably foreseeable use of the product, as specified by the manufacturer.

For each threat, a formula based on the risk factor levels is used to calculate the Likelihood and Impact of the threat, on a scale of Low, Medium, and High.

For each threat, both likelihood and impact need to be Low before the risk is considered sufficiently mitigated. If the calculated levels are not already Low, then mitigations need to be applied until they are both Low. The set of requirements that will accomplish this are listed in each threat description.

For some threats, the risk analysis assigns the same requirements to treat both High and Medium risk. When this occurs, it is because the same mitigation treats both High and Medium risk and there is no lesser mitigation that treats Medium risk but not High risk. Risk formulas like this could be simplified, but keeping the distinction between High and Medium risk may simplify the addition of new mitigations for Medium risk use cases.

B.4.3 List of threats, risk assessments, and mitigations

B.4.3.1 TH-UEVU: Unknown exploitable vulnerabilities

Attacker may use unknown exploitable vulnerabilities in the product to harm the product's assets.

Table B.1: Mapping risks to use cases: Likelihood of Unknown exploitable vulnerabilities

Risk formula	Likelihood	Use cases
(PHY and NET are 0) or COM is 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-SNS
(PHY or NET is 2) and COM is 2	High	PH-VNC, PH-EDG, PH-ISP, PH-SMH, PH-SME, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Table B.2: Mapping risks to use cases: Impact of Unknown exploitable vulnerabilities

Risk formula	Impact	Use cases
FUN and HOS are 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, PH-SMH, PH-SME
FUN or HOS are 2	High	PH-EDG, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA, PH-SNS

Mitigations for Likelihood:

- Medium to Low:
 - REQ-ALC-01
 - REQ-ASM-01
- High to Low:
 - REQ-ALC-01
 - REQ-ASM-01

Mitigations for Impact:

- Medium to Low:
 - REQ-MON-01

- High to Low:
 - REQ-MON-01

B.4.3.2 TH-KEVU: Known exploitable vulnerabilities

Attacker may use known exploitable vulnerabilities in the product implementation to get unauthorized access to product assets.

Table B.3: Mapping risks to use cases: Likelihood of known exploitable vulnerabilities

Risk formula	Likelihood	Use cases
PHY and NET are 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, PH-SNS
PHY or NET is 2	High	PH-VNC, PH-EDG, PH-ISP, VI-VMW, VI-VMC, VI-VII, PH-SMH, PH-SME, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Table B.4: Mapping risks to use cases: Impact of known exploitable vulnerabilities

Risk formula	Impact	Use cases
FUN and HOS are 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, PH-SMH, PH-SME
FUN or HOS are 2	High	PH-EDG, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA, PH-SNS

Mitigations for Likelihood:

- Medium to Low:
 - REQ-KEV-01
 - REQ-SU-01
- High to Low:
 - REQ-KEV-01
 - REQ-SU-01

Mitigations for Impact:

- Medium to Low:
 - REQ-MON-01
- High to Low:
 - REQ-MON-01

B.4.3.3 TH-DSTP: Compromise of data stored on product

Attacker may get unauthorized access to confidential data stored on the product through acquisition of a used product or during transfer of user data and settings from one product to another.

Table B.5: Mapping risks to use cases: Likelihood of Compromise of data stored on product

Risk formula	Likelihood	Use cases
all others	Medium	VI-ISO, PH-VNI, PH-VNC, PH-IRO, PH-ISP, PH-EDG, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-SME, PH-ATM, PH-SPI
ADM is 2	High	PH-IOT, PH-HRO, PH-SMH, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA, PH-SNS

Table B.6: Mapping risks to use cases: Impact of Compromise of data stored on product

Risk formula	Impact	Use cases
FUN is 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, VI-VMW, PH-SMH, PH-SME, PH-SNS
FUN is 2	High	PH-EDG, VI-VDC, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-CP-01
 - REQ-IP-01
 - REQ-SDT-01
 - REQ-SDT-02
- High to Low:
 - REQ-AAC-01
 - REQ-CP-01
 - REQ-IP-01
 - REQ-SDT-01
 - REQ-SDT-02

Mitigations for Impact:

- Medium to Low:
 - REQ-DM-01
- High to Low:
 - REQ-DM-01

B.4.3.4 TH-CONF: Access to assets via configuration errors

Attacker may use unintentional configuration errors to get unauthorized access to the product assets.

Table B.7: Mapping risks to use cases: Likelihood of Access to assets via configuration errors

Risk formula	Likelihood	Use cases
INI is 0	Medium	VI-ISO, PH-VNI, PH-VNC, PH-IOT, PH-IRO, PH-EDG, PH-HRO, PH-ISP, VI-VDC, VI-VII, PH-SMH, PH-SME, PH-ATM, PH-SPI, PH-MOB, PH-GPI, PH-SNS
all others	High	PH-USB, PH-STA, VI-VMW, VI-VMC, VI-VPN

Table B.8: Mapping risks to use cases: Impact of Access to assets via configuration errors

Risk formula	Impact	Use cases
FUN and HOS are 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, PH-SMH, PH-SME
FUN or HOS are 2	High	PH-EDG, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA, PH-SNS

Mitigations for Likelihood:

- Medium to Low:
 - REQ-SBD-01
- High to Low:
 - REQ-SBD-02

Mitigations for Impact:

- Medium to Low:
 - REQ-MON-01
- High to Low:
 - REQ-MON-01

B.4.3.5 TH-UADT: Unauthorized access to data transmitted

Attacker may use access to the attached network to compromise the confidentiality or integrity of data transmitted by the product.

Table B.9: Mapping risks to use cases: Likelihood of Unauthorized access to data transmitted

Risk formula	Likelihood	Use cases
NET is 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, PH-SMH, PH-ATM, PH-SNS
NET is 2	High	PH-VNC, PH-EDG, PH-ISP, VI-VMW, VI-VMC, VI-VII, PH-SME, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Table B.10: Mapping risks to use cases: Impact of Unauthorized access to data transmitted

Risk formula	Impact	Use cases
FUN is 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, VI-VMW, PH-SMH, PH-SME, PH-SNS
FUN is 2	High	PH-EDG, VI-VDC, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AAC-01
 - REQ-CP-01
 - REQ-IP-01
 - REQ-SDT-01

- High to Low:
 - REQ-AAC-01
 - REQ-CP-01
 - REQ-IP-01
 - REQ-SDT-01
 - REQ-SDT-02

Mitigations for Impact:

- Medium to Low:
 - REQ-DM-01
- High to Low:
 - REQ-DM-01

B.4.3.6 TH-AVAI: Denial of service attack on product

Attacker may use network access to product to reduce availability of product functions.

Table B.11: Mapping risks to use cases: Likelihood of denial of service attack on product

Risk formula	Likelihood	Use cases
NET is 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, PH-SMH, PH-ATM, PH-SNS
NET is 2	High	PH-VNC, PH-EDG, PH-ISP, VI-VMW, VI-VMC, VI-VII, PH-SME, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Table B.12: Mapping risks to use cases: Impact of denial of service attack on product

Risk formula	Impact	Use cases
FUN and HOS are 0	Low	VI-ISO, PH-VNI, PH-VNC, PH-IOT
all others	Medium	PH-IRO, PH-HRO, PH-ISP, PH-SMH, PH-SME
FUN or HOS are 2	High	PH-EDG, VI-VDC, VI-VMW, VI-VMC, VI-VII, PH-ATM, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA, PH-SNS

Mitigations for Likelihood:

- Medium to Low:
 - REQ-AP-02 or REQ-AP-03
- High to Low:
 - REQ-AP-01 or REQ-AP-03
 - REQ-AP-02 or REQ-AP-03

Mitigations for Impact:

- Medium to Low:
 - REQ-MON-01
 - REQ-AP-04

- High to Low:
 - REQ-MON-01
 - REQ-AP-04
 - REQ-AP-05

B.4.3.7 TH-DDOS: Interference with other devices

Attacker may use product functions to interfere with other devices or services.

Table B.13: Mapping risks to use cases: Likelihood of interference with other devices

Risk formula	Likelihood	Use cases
NET is 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, PH-SMH, PH-ATM, PH-SNS
NET is 2	High	PH-VNC, PH-EDG, PH-ISP, VI-VMW, VI-VMC, VI-VII, PH-SME, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Table B.14: Mapping risks to use cases: Impact of interference with other devices

Risk formula	Impact	Use cases
NET is 0	Low	VI-ISO, PH-VNI
all others	Medium	PH-IOT, PH-IRO, PH-HRO, VI-VDC, PH-SMH, PH-ATM, PH-SNS
NET is 2	High	PH-VNC, PH-EDG, PH-ISP, VI-VMW, VI-VMC, VI-VII, PH-SME, PH-SPI, VI-VPN, PH-MOB, PH-GPI, PH-USB, PH-STA

Mitigations for Likelihood:

- Medium to Low:
 - REQ-NI-01
- High to Low:
 - REQ-NI-01

Mitigations for Impact:

- Medium to Low:
 - REQ-MON-01
- High to Low:
 - REQ-MON-01

B.5 Mapping of use cases to risk factors

Table B.15: Mapping of use cases to risk factors

Use case	PHY	NET	FUN	COM	HOS	ADM	INI
UC-VI-ISO: isolated researcher vm	0	0	0	0	0	0	0
UC-PH-VNI: vending machine, internal only	0	0	0	1	0	1	0
UC-PH-VNC: vending machine, connected	2	2	0	2	0	1	0
UC-PH-IOT: home IoT	1	1	0	2	0	2	0
UC-PH-IRO: intranet router	0	1	1	2	1	0	0
UC-PH-EDG: edge router	0	2	2	2	1	0	0
UC-PH-HRO: home router	1	1	1	2	1	2	0
UC-PH-ISP: ISP access point	1	2	1	2	1	1	0
UC-VI-VDC: virtualize data centre	0	1	2	1	2	0	0
UC-VI-VMW: virtualize web hosting	0	2	1	1	2	0	1
UC-VI-VMC: virtualize critical server	0	2	2	1	2	0	1
UC-VI-VII: virtual - integrator	0	2	2	1	2	0	0
UC-PH-SMH: smart watch	2	1	1	2	1	2	0
UC-PH-SME: smart meter	1	2	1	2	1	0	0
UC-PH-ATM: ATM	2	1	2	2	2	0	0
UC-PH-SPI: solar panel inverter	1	2	2	2	2	0	0
UC-VI-VPN: consumer VPN	0	2	2	2	2	2	1
UC-PH-MOB: mobile phone/tablet	2	2	2	2	2	2	0
UC-PH-GPI: general purpose, integrated	2	2	2	2	2	2	0
UC-PH-USB: external USB	2	2	2	2	1	2	2
UC-PH-STA: standalone	2	2	2	2	2	2	2
UC-PH-SNS: remote sensor	1	1	1	1	2	2	0

B.6 Mapping of threats to requirements

Table B.16: Mapping of threats to requirements

Threat	Requirements
TH-UEVU	REQ-ALC-01, REQ-ASM-01, REQ-MON-01
TH-KEVU	REQ-KEV-01, REQ-SU-01, REQ-MON-01
TH-DSTP	REQ-AAC-01, REQ-CP-01, REQ-IP-01, REQ-SDT-01, REQ-SDT-02, REQ-DM-01
TH-CONF	REQ-SBD-01, REQ-SBD-02, REQ-MON-01
TH-UADT	REQ-AAC-01, REQ-CP-01, REQ-IP-01, REQ-SDT-01, REQ-SDT-02, REQ-DM-01
TH-AVAI	REQ-AP-01, REQ-AP-02, REQ-AP-03, REQ-AP-04, REQ-AP-05, REQ-MON-01
TH-DDOS	REQ-NI-01, REQ-MON-01

B.7 Risks not treated by the requirements

For each risk untreated by the product itself in each applicable use case, a corresponding mitigation has been created to explicitly permit the risk to be transferred to the user or operational environment. These are:

- REQ-SU-01 Secure update provided by operational environment
- REQ-SBD-01 Provide methods to protect or disable interfaces
- REQ-AAC-01 Authentication and access control provided by operational environment
- REQ-CP-01 Confidentiality protection provided by operational environment
- REQ-IP-01 Integrity protection provided by operational environment
- REQ-AP-03 Availability protection provided by operational environment
- REQ-SDT-03 Secure data read from product

Annexes C to J:
Void

Annex K (normative): Generic cryptographic requirements and assessment

K.1 Cryptography

K.1.1 Requirement

The product's default configuration shall only use cryptographic mechanisms that meet at least one of the following criteria:

- 1) ACM-listed: the cryptographic mechanism is listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
- 2) ACM-extended: the cryptographic mechanism is not listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1] and meets at least one of the following conditions:
 - a) the cryptographic mechanism is listed in clause K.3.2 as an ACM-extended cryptographic mechanism for the specific product function(s), following consideration of the criteria specified in item 2)b);
 - b) where the cryptographic mechanism is not listed in clause K.3.2, the cryptographic mechanism meets all the following criteria:
 - i) the cryptographic mechanism; or where applicable the ACM-listed cryptographic mechanism on which it is based, is not deprecated per the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1];
 - ii) the cryptographic mechanism has been specified, developed or maintained through a transparent process by a recognized European, international or sector-specific standards development organization; or by an industry specification organization accountable for the relevant specification, including CEN, CENELEC, ETSI, ISO, IEC, ISO/IEC JTC 1, IETF, IEEE, ITU-T, NIST, 3GPP, O-RAN Alliance, BSI, ACN, [C2SP](#); or the cryptographic mechanism is listed as suitable in a publicly available cryptographic catalogue maintained by a recognized national or governmental cybersecurity authority, where the catalogue is maintained under a documented revision and retirement process, including BSI TR-02102-1 [i.11], BSI TR-02102-2 [i.20], BSI TR-02102-3 [i.21] and BSI TR-02102-4 [i.22];
 - iii) the cryptographic mechanism is described in a valid, publicly available and uniquely referenceable specification;
 - iv) the cryptographic properties of the cryptographic mechanism are known;
 - v) no known weakness affects the cryptographic mechanism in a way that affects its cryptographic properties;
 - vi) the cryptographic mechanism is required for a specific set of product functions;
- 3) Interoperability-based: the cryptographic mechanism is listed in clause K.4.2 as an interoperability-based cryptographic mechanism for specific product function(s) and external specification(s) or external requirement(s).

K.1.2 Assessment of product cryptographic configuration

K.1.2.1 General

The assessment in clause K.1.2 verifies the cryptographic mechanisms used in the product's default configuration against clause K.1.1.

For ACM-extended cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is either listed in clause K.3.2 or fulfils the criteria specified in clause K.1.1 item 2)b). For interoperability-based cryptographic mechanisms, the assessment verifies that the cryptographic mechanism is listed in clause K.4.2. The assessment also verifies that the product uses the cryptographic mechanism in accordance with the relevant characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in the present document.

K.1.2.2 Assessment of ACM-listed cryptographic mechanisms

K.1.2.2.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 1) and used in the product's default configuration are listed in the ECCG Agreed Cryptographic Mechanisms (ACM) catalogue [1].

K.1.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 1), including the related product function, relevant parameters where applicable, and the relevant ACM entry.

K.1.2.2.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 1) is identified by reference to a relevant ACM entry;
- b) the ACM entry corresponds to the cryptographic mechanism used in the product's default configuration, including relevant parameters where applicable;
- c) where the ACM entry includes lifecycle information, such as expiry date, deprecation date, migration condition or usage limitation, this information is reflected in the documentation.

K.1.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 1);
- c) references to the relevant ACM entries;
- d) relevant parameters, profiles, cipher suites or configuration constraints, where applicable;
- e) relevant lifecycle information from the ACM catalogue, where applicable.

K.1.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 1).
- The verdict FAIL shall be assigned otherwise.

K.1.2.3 Assessment of ACM-extended cryptographic mechanisms

K.1.2.3.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 2) and used in the product's default configuration are either listed as ACM-extended cryptographic mechanisms in clause K.3.2 or fulfil the criteria specified in clause K.1.1 item 2)b), and are used for the claimed product function(s).

K.1.2.3.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 2), including the related product function, use case where applicable, relevant parameters where applicable, and at least one of the following:
 - a) the relevant entry in clause K.3.2; or
 - b) evidence that the cryptographic mechanism fulfils all applicable criteria in clause K.1.1 item 2)b).

K.1.2.3.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 2) is either listed in clause K.3.2 as an ACM-extended cryptographic mechanism or supported by evidence demonstrating fulfilment of the applicable criteria in clause K.1.1 item 2)b);
- b) the cryptographic mechanism used by the product corresponds to the mechanism listed in clause K.3.2 or described in the evidence provided under clause K.1.1 item 2)b);
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.3.2 or justified under clause K.1.1 item 2)b);
- d) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.3.2 or justified under clause K.1.1 item 2)b), where applicable;
- e) where clause K.3.2 or the justification under clause K.1.1 item 2)b) defines conditions or limitations for the use of the cryptographic mechanism, these conditions or limitations are reflected in the product's default configuration;
- f) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.3.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 2);
- c) reference to the relevant entry in clause K.3.2, where the mechanism is listed in clause K.3.2;
- d) evidence that the cryptographic mechanism fulfils the criteria in clause K.1.1 item 2)b), where compliance with clause K.1.1 item 2) is claimed on the basis of those criteria;
- e) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;

- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.3.2 or in the justification under clause K.1.1 item 2)b), where applicable.

K.1.2.3.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 2).
- The verdict FAIL shall be assigned otherwise.

K.1.2.4 Assessment of interoperability-based cryptographic mechanisms

K.1.2.4.1 Assessment objective

The purpose of this assessment case is to verify that cryptographic mechanisms claimed to comply with clause K.1.1 item 3) and used in the product's default configuration are listed as interoperability-based cryptographic mechanisms in clause K.4.2 and are used in accordance with the characteristics, product functions, use cases where applicable, external specifications or external requirements, and conditions specified in clause K.4.2.

K.1.2.4.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall provide a list of cryptographic mechanisms used in the product's default configuration and claimed under clause K.1.1 item 3), including the related product function, use case where applicable, relevant parameters where applicable, the external specification or external requirement requiring its use, and the relevant entry in clause K.4.2.

K.1.2.4.3 Assessment activities

The assessment shall include verification that:

- a) each cryptographic mechanism claimed under clause K.1.1 item 3) is listed in clause K.4.2 as an interoperability-based cryptographic mechanism;
- b) the cryptographic mechanism used by the product corresponds to the cryptographic mechanism listed in clause K.4.2;
- c) the product function using the cryptographic mechanism, and the use case where applicable, correspond to the related product function and use case specified in clause K.4.2;
- d) the external specification or external requirement requiring the use of the cryptographic mechanism corresponds to the external specification or external requirement specified in clause K.4.2;
- e) the relevant characteristics, parameters, profiles, cipher suites or configuration constraints of the cryptographic mechanism correspond to those specified in clause K.4.2, where applicable;
- f) the conditions or limitations specified in clause K.4.2 for the use of the cryptographic mechanism are reflected in the product's default configuration;
- g) where technically feasible, the cryptographic mechanism, parameters and configuration identified in the documentation correspond to the assessed product configuration.

K.1.2.4.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) description of the product's default configuration;
- b) list of cryptographic mechanisms claimed under clause K.1.1 item 3);
- c) reference to the relevant entry in clause K.4.2;

- d) identification of the related product function using the cryptographic mechanism and the use case where applicable;
- e) identification of the external specification or external requirement requiring use of the cryptographic mechanism;
- f) relevant characteristics, parameters, profiles, cipher suites or configuration constraints, where applicable;
- g) evidence that the cryptographic mechanism is used in accordance with the conditions or limitations specified in clause K.4.2.

K.1.2.4.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.1.1 item 3).
- The verdict FAIL shall be assigned otherwise.

K.2 Crypto agility

K.2.1 Requirement

Where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue; or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product shall provide means for addressing the affected cryptographic mechanism by one or more of the following:

- a) updating the cryptographic mechanism;
- b) using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation;
- c) disabling the use of the affected cryptographic mechanism; or
- d) limiting the use of the affected product functions accordingly.

K.2.2 Assessment of crypto-agility

K.2.2.1 Assessment objective

The purpose of this assessment case is to verify whether, where the product's default configuration uses a cryptographic mechanism for which the ACM catalogue; or the present document, specifies a deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product, the product provides means to address the affected cryptographic mechanism in accordance with clause K.2.1.

K.2.2.2 Assessment preparation

- Preconditions for the assessment: The product's default configuration shall be used for the assessment.
- The documentation shall identify:
 - a) the intended lifetime of the product;
 - b) the cryptographic mechanisms used in the product's default configuration;
 - c) the related product function(s) for each cryptographic mechanism;

- d) the lifecycle information applicable to each cryptographic mechanism, where specified by the ACM catalogue or the present document, including any deprecation date, expiry date, migration condition or usage limitation.

K.2.2.3 Assessment activities

The assessment shall include verification that:

- a) for each cryptographic mechanism used in the product's default configuration, the lifecycle information specified by the ACM catalogue or the present document has been identified, where such information is specified;
- b) where the ACM catalogue or the present document specifies a deprecation date, expiry date, migration condition or usage limitation for a cryptographic mechanism, this information is reflected in the documentation;
- c) where a deprecation date, expiry date, migration condition or usage limitation falls within the intended lifetime of the product, the product provides an applicable mechanism for updating the cryptographic mechanism, using another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation, disabling the use of the affected cryptographic mechanism; or limiting the use of the affected product functions accordingly;
- d) where another cryptographic mechanism is used, that cryptographic mechanism complies with clause K.1.1 and is not subject to the relevant deprecation date, expiry date, migration condition or usage limitation.

K.2.2.4 Assessment evidence

The assessment evidence shall include, as applicable:

- a) documentation of the intended lifetime of the product;
- b) list of cryptographic mechanisms used in the product's default configuration;
- c) identification of the related product function(s) for each cryptographic mechanism;
- d) references to the ACM catalogue entry or to the provision of the present document used to determine lifecycle information, where applicable;
- e) identification of any deprecation date, expiry date, migration condition or usage limitation falling within the intended lifetime of the product;
- f) description of the means provided by the product, such as update of the cryptographic mechanism, use of another cryptographic mechanism that complies with clause K.1.1 and is not subject to the relevant lifecycle constraint, disabling the use of the affected cryptographic mechanism; or limitation of the use of the affected product functions.

K.2.2.5 Assessment verdict

- The verdict PASS shall be assigned if the required evidence has been provided, is complete, is applicable to the assessed configuration, and demonstrates compliance with clause K.2.1.
- The verdict FAIL shall be assigned otherwise.

K.3 ACM-extended cryptographic mechanisms

K.3.1 Requirement

Where the product's default configuration uses ACM-extended cryptographic mechanisms, these mechanisms shall comply with the ACM-extended criterion in clause K.1.1 item 2).

K.3.2 List of ACM-extended cryptographic mechanisms

Table K.1 lists the ACM-extended cryptographic mechanisms specified by the present document.

Table K.1: ACM-extended cryptographic mechanisms

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
Curve25519	Primitive	-	-	Confidentiality, Authentication, Key Establishment	IETF RFC 7748 [i.7]	
X25519	Primitive	256 bit	TLS, IPC, VPN protocols, key agreement	Key establishment	IETF RFC 7748 [i.7]	
Ed25519	Primitive	256 bit	Package Signature, TLS, IPC, VPN protocols, data signature	Authentication	IETF RFC 8032 [i.8], NIST FIPS 186-5 [i.9]	
Curve448	Primitive	-	-	Confidentiality, Authentication, Key Establishment	IETF RFC 7748 [i.7]	
X448	Primitive	448 bit	TLS, IPC, VPN protocols	Key establishment	IETF RFC 7748 [i.7]	
Ed448	Primitive	456 bit	Package Signature, TLS, IPC, VPN protocols	Authentication	IETF RFC 8032 [i.8], NIST FIPS 186-5 [i.9]	
Argon2	Algorithm	Refer to 4. Parameter Choice in IETF RFC 9106 [i.10] and the ACN's guidance.Argon2id, Argon2i, Argon2d	Password-based hashing, Key derivation	Cryptographic hashing, Integrity, Authentication	IETF RFC 9106 [i.10], BSI TR-0210 2-1 [i.11], ACN	
scrypt	Algorithm	Refer to 2. scrypt Parameters in IETF RFC 7914 [i.12] and the ACN's guidance.	Password-based hashing, Key derivation	Cryptographic hashing, Integrity, Authentication	IETF RFC 7914 [i.12], ACN	

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
ChaCha20	Algorithm	Key: 256 bit Nonce: 96bit or 192bit (XChaCha).	TLS, data encryption, VPN protocols	confidentiality	IETF RFC 8439 [i.13]	
Salsa20	Algorithm	Key: 256 bit Nonce: 64 bit, 192bit (XSalsa20)	data encryption, VPN protocols	confidentiality	IETF RFC 8439 [i.13]	20 rounds
Poly1305	Algorithm	256 bit	MAC, VPN protocols	Authentication, Integrity	IETF RFC 8439 [i.13]	
AEGIS	Algorithm	256 bit, 128 bit AEGIS-128, AEGIS-128L, AEGIS-256, AEGIS-256X	Authenticated data encryption, VPN protocols	Authentication, confidentiality, integrity	RFC-AEGIS	
Blake2	Algorithm	Blake2s, Blake2b	Key derivation, Generic hashing, MAC	Authentication, integrity	IETF RFC 7693 [i.14], NIST IR 7896 [i.15]	
Blake3	Algorithm		Key derivation, Generic hashing, MAC	Authentication, integrity	BLAKE3, C2SP	
UMAC	Algorithm	128 bit	MAC	Authentication, Integrity	IETF RFC 4418 [i.16]	
QARMA-64	Lightweight block cipher (tweakable)	128 bit key	Cryptographic memory protection (DDR), Pointer Authentication (PAC)	confidentiality, integrity	"The QARMA Block Cipher Family. Almost MDS Matrices Over Rings With Zero Divisors, Nearly Symmetric Even-Mansour Constructions With Non-Involutory Central Rounds, and Search Heuristics for Low-Latency S-Boxes" [i.17]	Permitted for the following use-cases: protection of the confidentiality and/or integrity of the contents of memory; generation of short authentication codes for microarchitectural protections including (but not limited to) pointer authentication, control flow integrity.

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
QARMA-128	Lightweight block cipher (tweakable)	256 bit key	Cryptographic memory protection (DDR), Pointer Authentication (PAC)	confidentiality, integrity	"The QARMA Block Cipher Family. Almost MDS Matrices Over Rings With Zero Divisors, Nearly Symmetric Even-Mansour Constructions With Non-Involutory Central Rounds, and Search Heuristics for Low-Latency S-Boxes" [i.17]	Permitted for the following use-cases: protection of the confidentiality and/or integrity of the contents of memory; generation of short authentication codes for microarchitectural protections including (but not limited to) pointer authentication, control flow integrity.
QARMAv2-64	Lightweight block cipher (tweakable)	128 bit key	Cryptographic memory protection (DDR), Pointer Authentication (PAC)	confidentiality, integrity	"The QARMAv2 Family of Tweakable Block Ciphers" [i.18]	Permitted for the following use-cases: protection of the confidentiality and/or integrity of the contents of memory; generation of short authentication codes for microarchitectural protections including (but not limited to) pointer authentication, control flow integrity.

ACM-extended cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	Cryptographic properties	Specification / reference	Conditions or limitations, where applicable
QARMAv2-128	Lightweight block cipher (tweakable)	128. 192, 256 bit key	Cryptographic memory protection (DDR), Pointer Authentication (PAC)	confidentiality, integrity	"The QARMAv2 Family of Tweakable Block Ciphers" [i.18]	Permitted for the following use-cases: protection of the confidentiality and/or integrity of the contents of memory; generation of short authentication codes for microarchitectural protections including (but not limited to) pointer authentication, control flow integrity.
QARMAv2-64-σ0	Lightweight block cipher (tweakable)	128 bit key	Pointer authentication (PAC)	confidentiality, integrity	"The QARMAv2 Family of Tweakable Block Ciphers" [i.18]	Permitted for the following use-cases: generation of short authentication codes for microarchitectural protections including (but not limited to) pointer authentication, control flow integrity.

K.3.3 Assessment

Compliance with the ACM-extended criterion in clause K.1.1 item 2) is assessed in clause K.1.2.2.

K.4 Interoperability-based cryptographic mechanisms

K.4.1 Requirement

Where the product's default configuration uses interoperability-based cryptographic mechanisms, these mechanisms shall be selected from the interoperability-based cryptographic mechanisms listed in clause K.4.2 for the specified product functions and external specifications or external requirements and shall be used in accordance with the conditions or limitations specified in clause K.4.2.

K.4.2 List of interoperability-based cryptographic mechanisms

Table K.2 lists the interoperability-based cryptographic mechanisms specified by the present document.

Table K.2: Interoperability-based cryptographic mechanisms

Interoperability-based cryptographic mechanism	Type of cryptographic mechanism	Characteristics / parameters	Related product function(s) / use case(s), where applicable	External specification(s) or external requirement(s)	Interoperability justification	Conditions or limitations, where applicable
QARMA-64, QARMAv2-64	Lightweight, tweakable block cipher	Key length 128 bits	Pointer authentication	Arm8.3-A (FEAT_Pauth)	Canonical/recommended algorithm in the Arm ecosystem for pointer authentication. While implementation-defined mechanisms are acceptable, there are rarely, if ever, used. Support is explicitly indicated in AArch64_id_aa64isar1_el1 register (GPA field, Arm8.3-A and later) for use where compatibility is required. Server-focused Arm systems are required to implement QARMA for PAC (Arm Server Base System Architecture v8.0(J) / DEN0029J	Pointer authentication
QARMA-64, QARMAv2-64	Lightweight, tweakable block cipher	Key length 128 bits	Pointer authentication	Arm8.1-M PACBTI	Canonical/recommended algorithm in the Arm ecosystem for pointer authentication. While implementation-defined mechanisms are acceptable, there are rarely, if ever, used. Support is explicitly indicated in AArch64_id_aa64isar1_el1 register (GPA field, Arm8.3-A and later) for use where compatibility is required.	Pointer authentication

K.4.3 Assessment

Compliance with the requirement in clause K.4.1 is assessed in clause K.1.2.3.

NOTE: The assessment of the external specifications or external requirements themselves is outside the scope of this assessment. Their relevance is deemed confirmed by their inclusion in the present document.

Annexes L to Q:
Void

Annex R (normative): Remote Data Processing Solutions

R.1 Scope & Applicability

This annex specifies additional technical requirements and assessment provisions for products with digital elements that rely on Remote Data Processing Solutions ("RDPS") for the provision or support of one or more product functions.

The requirements applicable to the product functions themselves remain specified in the core part of the concerned standard and continue to apply to the product as a whole, including where a product function is performed locally, supported by an RDPS; or performed in part through an RDPS.

This annex specifies supplementary requirements and assessment provisions for the product-facing RDPS boundary, i.e. for the additional attack surface, interactions, and dependency conditions introduced where a product function is performed or supported across the local product side and the RDPS side.

Where the product does not rely on remote data processing solutions for the provision or support of any product function, this annex is not applicable.

This annex does not extend to the full remote service environment or underlying third-party infrastructure, except to the extent necessary to define assumptions, dependencies, and assessment conditions relevant to the product-facing RDPS boundary and the secure operation of the RDPS-dependent product function.

R.2 RDPS as a product-boundary extension

When a product relies on RDPS for the provision or support of one or more product functions, the use of RDPS is considered, for the purposes of the present annex, to introduce an additional product-facing boundary and interface between the local product side and the RDPS side.

The present annex does not restate or replace the requirements applicable to the product function as such. It specifies only the supplementary requirements needed to address the increased attack surface introduced by the RDPS boundary.

The present annex therefore addresses the security implications introduced by that additional boundary and interface, including:

- a) the exchanged interactions across the RDPS boundary;
- b) the relevant product-side and RDPS-side endpoints; and
- c) the dependency conditions arising where the secure operation of the product function relies on interactions across that boundary.

The scope of the present annex is limited to the RDPS interface between the local product side and the RDPS side.

For the purposes of the present annex:

- local product side means the product elements within the product boundary that participate in the interaction with the RDPS;
- RDPS means the remote data processing solution performing or supporting operations relevant to the RDPS-dependent product function;
- RDPS interface means the communication boundary between the product-side endpoint and the RDPS-side endpoint.

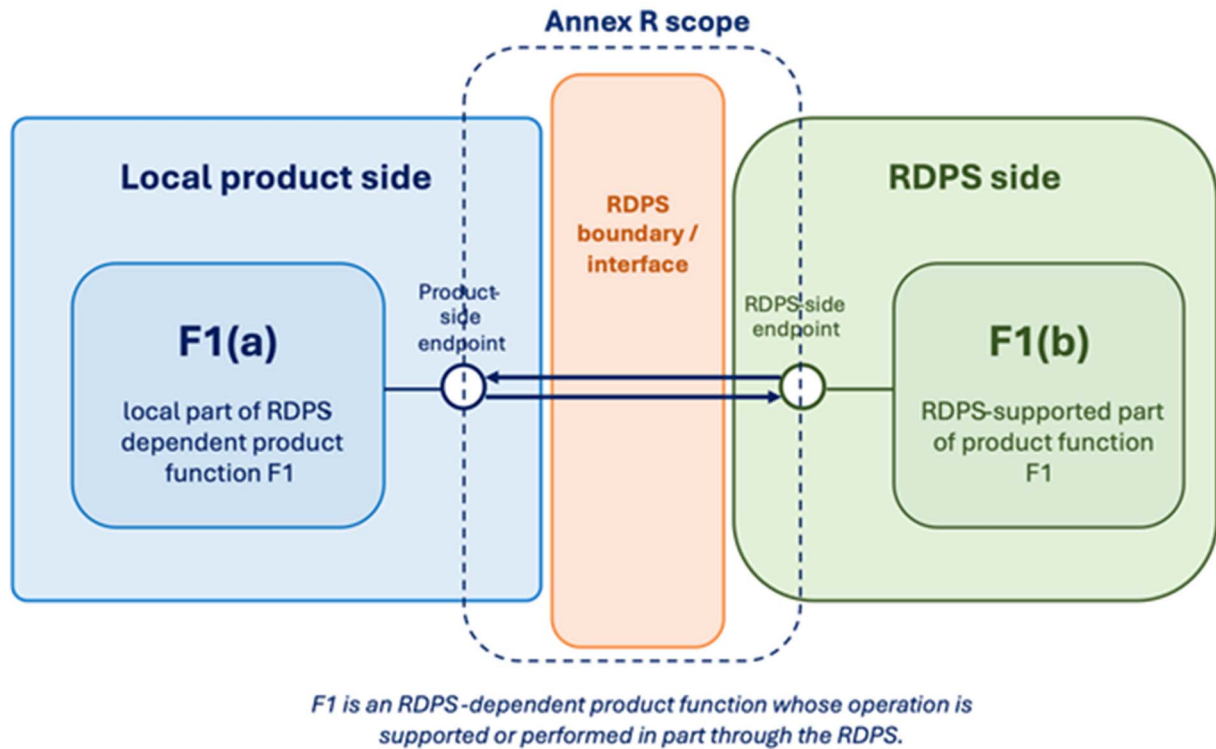


Figure R.1: RDPS model for Annex R - scope focused on the product ↔ RDPS boundary

R.3 Threat Model

R.3.1 Introduction

This clause does not restate or replace threats for local product components that are already defined in the main clauses of the standard. Instead, it focuses on:

- threats introduced by the local product ↔ RDPS interface; and
- threats introduced by the RDPS as a remote service capability.

The threat model:

- identifies RDPS assets; and
- defines a set of threats applicable to RDPS.

R.3.2 Assets

The threat model considers the following assets:

DA-RDPS-001 - RDPS interaction content: The information exchanged across the RDPS boundary, including, as applicable, requests, commands, responses, decisions, configuration data, secrets, update-related data, and personal data where such data is exchanged.

For the purposes of DA-RDPS-001, Table R.1 identifies categories of RDPS interaction content and the security properties that are relevant to them.

For the purposes of DA-RDPS-001, Table R.1 identifies potential categories of RDPS interaction content and indicates the security properties to be considered for each category when determining the applicable Annex R requirement families.

Table R.1: Security properties for DA-RDPS-001

Content type	Data authenticity	Integrity	Confidentiality
Commands / requests & Responses / decisions	X	X	
Configuration data	X	X	
Secrets (e.g. keys)	X	X	X
Code or update data	X	X	
Confidential code or update data	X	X	X
Personal data		X	X

NOTE: In Table R.1, "data authenticity" refers to the authenticity or trusted origin of the exchanged interaction content. It does not refer to authentication of the RDPS boundary endpoint.

DA-RDPS-002 – RDPS-dependent product function: product function for which one or more operations depend on an RDPS, including the associated security-relevant state, decisions, outputs; or configuration.

For the purposes of DA-RDPS-002, Table R.2 identifies the security property relevant to the RDPS-dependent product function.

Table R.2: Security property for DA-RDPS-002

Content type	Availability
RDPS-dependent product function	X

R.3.3 Threat catalogue

R.3.3.1 Overview

The following threats constitute the baseline threat set considered for the RDPS boundary within the scope of Annex R, covering the RDPS interaction content exchanged across the boundary and the availability of the RDPS-dependent product function.

R.3.3.2 T-RDPS-01 Loss of data authenticity of interactions across the RDPS boundary

An attacker causes an endpoint to accept interaction content across the RDPS boundary whose claimed source or origin is not genuine.

Threat type

Spoofing / impersonation

Security impact

The receiving endpoint may rely on interaction content that does not originate from the intended source, which can affect the behaviour, state, configuration; or security of the RDPS-dependent product function.

R.3.3.3 T-RDPS-02 Loss of integrity of interactions across the RDPS boundary

An interaction exchanged across the RDPS boundary is modified, substituted, injected, corrupted; or replayed before it is processed by the receiving endpoint.

Threat type

Tampering

Security impact

The receiving endpoint may act upon interaction content whose contents no longer correspond to what was sent or intended by the legitimate source, which can affect the behaviour, state, configuration; or security of the RDPS-dependent product function.

R.3.3.4 T-RDPS-03 Unauthorized disclosure of interactions across the RDPS boundary

Data exchanged across the RDPS boundary is disclosed to an unauthorized party.

Threat type

Information disclosure

Security impact

An attacker may obtain interaction content whose disclosure can affect the security or secure operation of the RDPS-dependent product function.

R.3.3.5 T-RDPS-04 Degradation of interactions across the RDPS boundary

The local product side or the RDPS side is unable to send, receive; or process interactions across the RDPS boundary; or receives them only after an unacceptable delay; or experiences degradation of communication performance across the RDPS boundary to an extent that is not tolerable for the successful operation of the RDPS-dependent product function.

Threat type

Denial of service

Security impact

The RDPS-dependent product function may fail to operate as intended, may operate with incomplete, outdated; or degraded information, may remain blocked; or may continue without the required interaction being available when needed.

R.3.4 Assets to Threats mapping

Table R.3: Assets to Threats mapping

Threat ID	Threat title	Related asset(s)
T-RDPS-01	Loss of data authenticity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-02	Loss of integrity of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-03	Unauthorized disclosure of interactions across the RDPS boundary	DA-RDPS-001
T-RDPS-04	Unavailability, unacceptable delay; or intolerable degradation of interactions across the RDPS boundary	DA-RDPS-002

R.4 Security Requirements

R.4.1 General and guidance for requirement-structure selection

The requirements in the present clause are organized by requirement family. The requirement families address the primary security properties identified for the assets in clause R.3.2, namely data authenticity, integrity, confidentiality, and availability.

The present version of Annex R provides two alternative drafting scenarios for integration into vertical standards:

- a) Three-level requirement scenario: within each requirement family, the requirements are expressed as a sequence of requirements with increasing rigour. In this scenario, the lower-numbered requirement defines the

baseline security outcome to be achieved, while the higher-numbered requirements define strengthened requirements for cases where increased protection is needed.

- b) Mono-level requirement scenario: within each requirement family, the requirements are expressed as a single consolidated requirement. In this scenario, the requirement defines the expected security outcome for the relevant RDPS boundary and allows the means of implementation and the level of assurance to be determined according to the security needs of the RDPS-dependent product function.

The three-level requirement scenario and the mono-level requirement scenario are alternative drafting approaches. They are not intended to be applied cumulatively.

The rapporteur of the concerned vertical standard should select one of these approaches when integrating Annex R, taking into account the structure, use cases, security profiles, applicability model, and assessment approach of that standard.

When Annex R is integrated into a vertical standard, only the selected requirement scenario should be retained. The non-selected alternative should be removed from the integrated text.

Where the three-level requirement scenario is selected, the applicable requirement or requirements within a given family are intended to be determined in accordance with the integration approach of the concerned standard, including any relevant use case, security profile, equivalent classification; or risk-based applicability model, together with the manufacturer's risk assessment for the product and the RDPS-dependent product function.

Where the mono-level requirement scenario is selected, the corresponding mono-level requirement is intended to replace the three-level sequence for that requirement family. The mono-level formulation provides a lighter integration option for vertical standards that do not use a three-level security profile structure or that prefer to define one outcome-based requirement per requirement family.

NOTE: This clause provides integration guidance for rapporteurs. It is not intended to be copied unchanged into a vertical standard where only one requirement scenario is retained.

R.4.2 Applicability of Annex R requirements

The requirements in the present clause address the protection of the security properties identified for the assets in clause R.3.2.

Where a security property is identified as relevant for a given asset in the asset tables of clause R.3.2, the corresponding requirement family or families in the present clause shall be considered for applicability to that asset.

For DA-RDPS-001, the primary requirement families considered for applicability are:

- a) data authenticity of interactions;
- b) integrity of interactions; and
- c) confidentiality of exchanged data.

For DA-RDPS-002, the primary requirement family considered for applicability is availability.

Where the three-level requirement scenario is selected, the applicable level within each selected requirement family should be determined in accordance with the use case, security profile, equivalent classification; or risk-based applicability model defined by the concerned vertical standard.

Where the three-level requirement scenario is used, the requirements within a given requirement family represent alternative levels of rigour and are not cumulative. For each applicable requirement family, one applicable level shall be selected. Selection of a higher-numbered requirement within a family includes the security outcome of the lower-numbered requirement(s) in that family and does not require separate selection of those lower-numbered requirement(s).

Where the mono-level requirement scenario is selected, the corresponding mono-level requirement should be considered for the selected requirement family.

NOTE: The mono-level requirement proposals are alternatives to the corresponding three-level requirement sequences and are not additional requirements to be applied together with them.

R.4.3 Local product side requirements

R.4.3.1 REQ-RDPS-L-AUTH-001

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction originates from the intended RDPS-side endpoint.

Purpose

Data authenticity of interactions received from the RDPS side

Rationale

This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

R.4.3.2 REQ-RDPS-L-AUTH-002

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel; or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Purpose

Data authenticity of interactions received from the RDPS side

Rationale

This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

R.4.3.3 REQ-RDPS-L-AUTH-003

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that:

- a) the cryptographic authenticity of the interaction is bound to the intended RDPS-side endpoint; and
- b) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Purpose

Data authenticity of interactions received from the RDPS side

Rationale

This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.3.4 REQ-RDPS-L-INTEG-001

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted; or injected.

Purpose

Integrity of interactions received from the RDPS side

Rationale

This requirement protects against loss of integrity of received interaction content.

R.4.3.5 REQ-RDPS-L-INTEG-002

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Purpose

Integrity of interactions received from the RDPS side

Rationale

This requirement strengthens protection against unauthorized modification or substitution of received interactions.

R.4.3.6 REQ-RDPS-L-INTEG-003

The local product side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Purpose

Integrity of interactions received from the RDPS side

Rationale

This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.3.7 REQ-RDPS-L-CONF-001

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side.

Purpose

Confidentiality of data exchanged with the RDPS side

Rationale

Confidentiality is not required for every exchange. However, where disclosure of data exchanged with the RDPS side could affect the security or secure operation of the RDPS-dependent product function, confidentiality protection is required.

R.4.3.8 REQ-RDPS-L-CONF-002

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall protect the confidentiality of that data during exchange with the RDPS side using cryptographic confidentiality protection.

Purpose

Confidentiality of data exchanged with the RDPS side

Rationale

This requirement strengthens confidentiality protection by requiring cryptographic protection of exchanged data where disclosure would create unacceptable cybersecurity risk.

R.4.3.9 REQ-RDPS-L-CONF-003

Where disclosure of data exchanged with the RDPS side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side shall use cryptographic confidentiality protection that is established with the intended RDPS-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Purpose

Confidentiality of data exchanged with the RDPS side

Rationale

This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.3.10 REQ-RDPS-L-AVAIL-001

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions; and
- c) apply a defined behaviour for the RDPS-dependent product function.

Purpose

Availability

Rationale

This requirement ensures that loss, delay; or degradation of RDPS-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

R.4.3.11 REQ-RDPS-L-AVAIL-002

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions;
- c) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits; and
- d) support recovery of the RDPS-dependent product function using locally maintained state, configuration; or other recovery information where such information is necessary to restore secure operation.

Purpose

Availability

Rationale

This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

R.4.3.12 REQ-RDPS-L-AVAIL-003

Where the availability or timeliness of interactions received from the RDPS side is necessary for the secure operation of the RDPS-dependent product function, the local product side shall:

- a) detect unavailability of the RDPS side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected RDPS-side interactions;
- c) apply a defined degraded behaviour or secure state when the required RDPS-side interactions are unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits; d) support recovery of the RDPS-dependent product function using locally maintained state, configuration; or other recovery information where such information is necessary to restore secure operation;
- d) support continuity of operation through failover, redundancy; or an equivalent resilience mechanism where such a mechanism is necessary.

Purpose

Availability

Rationale

This requirement provides stronger protection by requiring resilience measures.

R.4.4 RDPS side requirements

R.4.4.1 REQ-RDPS-R-AUTH-001

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction originates from the intended local product-side endpoint.

Purpose

Data authenticity of interactions received from the local product side

Rationale

This requirement protects against acceptance of interaction content whose claimed source or origin is not genuine.

R.4.4.2 REQ-RDPS-R-AUTH-002

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, the data authenticity of that interaction using cryptographic endpoint authentication, an authenticated communication channel; or an equivalent cryptographic mechanism that provides assurance of the origin of the interaction.

Purpose

Data authenticity of interactions received from the local product side

Rationale

This requirement strengthens protection against spoofed or falsely originated interaction content by requiring cryptographic assurance of origin.

R.4.4.3 REQ-RDPS-R-AUTH-003

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that:

- a) the cryptographic authenticity of the interaction is bound to the intended local product-side endpoint; and
- b) replayed or stale interactions are detected and rejected where replay or reuse could affect the secure operation of the RDPS-dependent product function.

Purpose

Data authenticity of interactions received from the local product side

Rationale

This requirement provides stronger protection by requiring source-bound authenticity and replay protection.

R.4.4.4 REQ-RDPS-R-INTEG-001

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction has not been modified, substituted, corrupted; or injected.

Purpose

Integrity of interactions received from the local product side

Rationale

This requirement protects against loss of integrity of received interaction content.

R.4.4.5 REQ-RDPS-R-INTEG-002

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, the integrity of that interaction using a cryptographic integrity-protection mechanism.

Purpose

Integrity of interactions received from the local product side

Rationale

This requirement strengthens protection against unauthorized modification or substitution of received interactions.

R.4.4.6 REQ-RDPS-R-INTEG-003

The RDPS side shall verify, before acting upon a received interaction that can influence the behaviour, state, configuration; or security of the RDPS-dependent product function, that the interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

Purpose

Integrity of interactions received from the local product side

Rationale

This requirement provides stronger protection by requiring cryptographic integrity protection bound to the authenticated source.

R.4.4.7 REQ-RDPS-R-CONF-001

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side.

Purpose

Confidentiality of data exchanged with the local product side

Rationale

This requirement ensures confidentiality where disclosure of exchanged data could affect the security or secure operation of the RDPS-dependent product function.

R.4.4.8 REQ-RDPS-R-CONF-002

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall protect the confidentiality of that data during exchange with the local product side using cryptographic confidentiality protection.

Purpose

Confidentiality of data exchanged with the local product side

Rationale

This requirement strengthens confidentiality protection by requiring cryptographic protection during exchange.

R.4.4.9 REQ-RDPS-R-CONF-003

Where disclosure of data exchanged with the local product side could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side shall use cryptographic confidentiality protection that is established with the intended local product-side endpoint and that prevents disclosure of the exchanged data to endpoints other than that intended endpoint.

Purpose

Confidentiality of data exchanged with the local product side

Rationale

This requirement provides stronger protection by ensuring that confidential exchanged data is disclosed only to the intended peer endpoint.

R.4.4.10 REQ-RDPS-R-AVAIL-001

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions; and
- c) apply a defined behaviour for the RDPS-dependent product function.

Purpose

Availability

Rationale

This requirement ensures that loss, delay; or degradation of local product-side interactions is detected and handled in a defined manner before it adversely affects the secure operation of the RDPS-dependent product function.

R.4.4.11 REQ-RDPS-R-AVAIL-002

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions;
- c) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits; and
- d) support recovery of the RDPS-dependent product function using maintained state, configuration; or other recovery information where such information is necessary to restore secure operation.

Purpose

Availability

Rationale

This requirement strengthens protection by requiring controlled degraded operation or transition to a secure state, together with support for restoration of secure operation.

R.4.4.12 REQ-RDPS-R-AVAIL-003

Where the availability or timeliness of interactions received from the local product side is necessary for the secure operation of the RDPS-dependent product function, the RDPS side shall:

- a) detect unavailability of the local product side, unacceptable delay of expected interactions; or intolerable degradation of the interaction;
- b) use timeout or equivalent timeliness controls for expected local product-side interactions;
- c) apply a defined degraded behaviour or secure state when the required local product-side interactions are unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits;
- d) support recovery of the RDPS-dependent product function using maintained state, configuration; or other recovery information where such information is necessary to restore secure operation; and
- e) support continuity of operation through failover, redundancy; or an equivalent resilience mechanism where such a mechanism is necessary.

Purpose

Availability

Rationale

This requirement provides stronger protection by requiring resilience measures.

R.4.5 Threats ↔ Requirements mapping

Table R.4: Threats ↔ Requirements mapping

Threat ID	Requirement(s) – Local product side	Requirement(s) – RDPS side
T-RDPS-01	REQ-RDPS-L-AUTH-001REQ-RDPS-L-AUTH-002REQ-RDPS-L-AUTH-003	REQ-RDPS-R-AUTH-001REQ-RDPS-R-AUTH-002REQ-RDPS-R-AUTH-003
T-RDPS-02	REQ-RDPS-L-INTEG-001REQ-RDPS-L-INTEG-002REQ-RDPS-L-INTEG-003	REQ-RDPS-R-INTEG-001REQ-RDPS-R-INTEG-002REQ-RDPS-R-INTEG-003
T-RDPS-03	REQ-RDPS-L-CONF-001REQ-RDPS-L-CONF-002REQ-RDPS-L-CONF-003	REQ-RDPS-R-CONF-001REQ-RDPS-R-CONF-002REQ-RDPS-R-CONF-003
T-RDPS-04	REQ-RDPS-L-AVAIL-001REQ-RDPS-L-AVAIL-002REQ-RDPS-L-AVAIL-003	REQ-RDPS-R-AVAIL-001REQ-RDPS-R-AVAIL-002REQ-RDPS-R-AVAIL-003

R.5 Conformity assessment

R.5.1 Overview

The assessment cases in the present clause are aligned with the requirements in clause R.4. Each assessment case follows a common structure: assessment reference, assessment objective, assessment preparation, assessment activities, assessment verdict, and assessment evidence.

R.5.2 Applicability

See clause R.4.2.

R.5.3 Local product side requirements

R.5.3.1 Assessment case for REQ-RDPS-L-AUTH-001

R.5.3.1.1 Objective

The objective of the assessment is to verify that the local product side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended RDPS-side endpoint.

R.5.3.1.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the interactions received from the RDPS side that can influence the behaviour, state, configuration; or security of that function;
- the intended RDPS-side endpoint for those interactions; and
- the mechanism used by the local product side to determine the origin of the received interaction.

R.5.3.1.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the local product side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted; and
- verify that interactions not originating from the intended RDPS-side endpoint are rejected or not acted upon.

R.5.3.1.4 Verdict

Pass:

- the local product side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended RDPS-side endpoint are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying its origin; or
- the local product side accepts and acts upon a relevant interaction not originating from the intended RDPS-side endpoint.

R.5.3.1.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended RDPS-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.3.2 Assessment case for REQ-RDPS-L-AUTH-002

R.5.3.2.1 Objective

The objective of the assessment is to verify that the local product side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel; or an equivalent cryptographic mechanism providing assurance of origin.

R.5.3.2.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the local product side accepts or rejects those interactions.

R.5.3.2.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the local product side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and
- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

R.5.3.2.4 Verdict

Pass:

- the local product side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the local product side verifies that protection before acting upon the interaction; and
- interactions without valid assurance of origin are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying cryptographic assurance of origin; or

- the local product side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

R.5.3.2.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.3.3 Assessment case for REQ-RDPS-L-AUTH-003

R.5.3.3.1 Objective

The objective of the assessment is to verify that the local product side verifies that the cryptographic authenticity of the received interaction is bound to the intended RDPS-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

R.5.3.3.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended RDPS-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

R.5.3.3.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended RDPS-side endpoint;
- inspect the design and configuration of the freshness, anti-replay; or equivalent mechanism used;
- verify that a valid interaction bound to the intended RDPS-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended RDPS-side endpoint is rejected or not acted upon; and
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.3.3.4 Verdict

Pass:

- the local product side verifies that authenticity is bound to the intended RDPS-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

Fail:

- the local product side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended RDPS-side endpoint; or

- the local product side fails to detect and reject replayed or stale interactions where such protection is required.

R.5.3.3.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed; or stale interactions.

R.5.3.4 Assessment case for REQ-RDPS-L-INTEG-001

R.5.3.4.1 Objective

The objective of the assessment is to verify that the local product side checks that a relevant received interaction has not been modified, substituted, corrupted; or injected before acting upon it.

R.5.3.4.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the local product side to detect modification, substitution, corruption; or injection.

R.5.3.4.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted; or injected interactions are rejected or not acted upon.

R.5.3.4.4 Verdict

Pass:

- the local product side checks the integrity of relevant received interactions before acting upon them; and
- modified, substituted, corrupted; or injected interactions are rejected or not acted upon.

Fail:

- the local product side acts upon a relevant interaction without verifying its integrity; or
- the local product side accepts and acts upon an altered, substituted, corrupted; or injected interaction.

R.5.3.4.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and

- evidence showing rejection or non-processing of altered or injected interactions.

R.5.3.5 Assessment case for REQ-RDPS-L-INTEG-002

R.5.3.5.1 Objective

The objective of the assessment is to verify that the local product side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

R.5.3.5.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

R.5.3.5.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

R.5.3.5.4 Verdict

Pass:

- the local product side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

Fail:

- the local product side does not use cryptographic integrity verification where required; or
- the local product side accepts and acts upon an interaction whose integrity protection is missing or invalid.

R.5.3.5.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;
- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.3.6 Assessment case for REQ-RDPS-L-INTEG-003

R.5.3.6.1 Objective

The objective of the assessment is to verify that the local product side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

R.5.3.6.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

R.5.3.6.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

R.5.3.6.4 Verdict

Pass:

- the local product side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

Fail:

- the local product side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the local product side acts upon the interaction before performing the required checks.

R.5.3.6.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.3.7 Assessment case for REQ-RDPS-L-CONF-001

R.5.3.7.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

R.5.3.7.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and
- the mechanism used by the local product side to protect confidentiality during exchange.

R.5.3.7.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the RDPS side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.3.7.4 Verdict

Pass:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

Fail:

- the local product side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

R.5.3.7.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.3.8 Assessment case for REQ-RDPS-L-CONF-002

R.5.3.8.1 Objective

The objective of the assessment is to verify that the local product side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

R.5.3.8.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and
- the cryptographic confidentiality-protection mechanism used during exchange.

R.5.3.8.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

R.5.3.8.4 Verdict

Pass:

- relevant exchanged data is protected using cryptographic confidentiality protection; and
- exchange without the required cryptographic protection is prevented.

Fail:

- the local product side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

R.5.3.8.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.3.9 Assessment case for REQ-RDPS-L-CONF-003

R.5.3.9.1 Objective

The objective of the assessment is to verify that the local product side uses cryptographic confidentiality protection established with the intended RDPS-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

R.5.3.9.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring stronger confidentiality protection;
- the intended RDPS-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

R.5.3.9.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended RDPS-side endpoint;
- verify that protected exchange is established with the intended RDPS-side endpoint;
- verify that the local product side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended RDPS-side endpoint are rejected or do not result in disclosure of the protected data.

R.5.3.9.4 Verdict

Pass:

- confidentiality protection is established with the intended RDPS-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

Fail:

- the local product side discloses protected data without establishing confidentiality protection with the intended RDPS-side endpoint; or
- the local product side discloses the protected data to endpoints other than the intended RDPS-side endpoint.

R.5.3.9.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended RDPS-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.3.10 Assessment case for REQ-RDPS-L-AVAIL-001

R.5.3.10.1 Objective

The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay; or intolerable degradation of required RDPS-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

R.5.3.10.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed; or degraded.

R.5.3.10.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness; or equivalent detection controls;
- verify that unavailability, unacceptable delay; or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

R.5.3.10.4 Verdict

Pass:

- the local product side detects the specified failure, delay; or degradation conditions;
- timeout or equivalent timeliness controls are used; and
- a defined behaviour is applied when the identified conditions occur.

Fail:

- the local product side does not detect the relevant failure, delay; or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

R.5.3.10.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay; or degradation; and
- evidence showing application of the defined behaviour.

R.5.3.11 Assessment case for REQ-RDPS-L-AVAIL-002

R.5.3.11.1 Objective

The objective of the assessment is to verify that the local product side applies a defined degraded behaviour or secure state when required RDPS-side interactions are unavailable, delayed; or degraded, and supports recovery of the RDPS-dependent product function where needed.

R.5.3.11.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any locally maintained state, configuration; or other recovery information required to restore secure operation.

R.5.3.11.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits, the local product side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

R.5.3.11.4 Verdict

Pass:

- the local product side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

Fail:

- the local product side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

R.5.3.11.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.3.12 Assessment case for REQ-RDPS-L-AVAIL-003

R.5.3.12.1 Objective

The objective of the assessment is to verify that the local product side supports higher resilience, including continuity of operation through failover, redundancy; or equivalent resilience mechanisms where necessary.

R.5.3.12.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required RDPS-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy; or equivalent resilience mechanism, where required.

R.5.3.12.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;

- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy; or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed; or degraded.

R.5.3.12.4 Verdict

Pass:

- the local product side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

Fail:

- a required resilience mechanism is absent or ineffective; or
- the local product side fails to support continuity of operation where such support is required.

R.5.3.12.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy; or equivalent continuity support where required.

R.5.4 RDPS side requirements

R.5.4.1 Assessment case for REQ-RDPS-R-AUTH-001

R.5.4.1.1 Objective

The objective of the assessment is to verify that the RDPS side verifies, before acting upon a relevant received interaction, that the interaction originates from the intended local product-side endpoint.

R.5.4.1.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the interactions received from the local product side that can influence the behaviour, state, configuration; or security of that function;
- the intended local product-side endpoint for those interactions; and
- the mechanism used by the RDPS side to determine the origin of the received interaction.

R.5.4.1.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism used by the RDPS side to determine the origin of the relevant interaction;
- verify that the origin of the interaction is checked before the interaction is acted upon;

- verify that interactions from the intended local product-side endpoint are accepted; and
- verify that interactions not originating from the intended local product-side endpoint are rejected or not acted upon.

R.5.4.1.4 Verdict

Pass:

- the RDPS side verifies the origin of the relevant interaction before acting upon it; and
- interactions from endpoints other than the intended local product-side endpoint are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying its origin; or
- the RDPS side accepts and acts upon a relevant interaction not originating from the intended local product-side endpoint.

R.5.4.1.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence describing how origin of the interaction is determined;
- evidence showing acceptance of interactions from the intended local product-side endpoint; and
- evidence showing rejection or non-processing of interactions from other endpoints.

R.5.4.2 Assessment case for REQ-RDPS-R-AUTH-002

R.5.4.2.1 Objective

The objective of the assessment is to verify that the RDPS side verifies the data authenticity of relevant received interactions using cryptographic endpoint authentication, an authenticated communication channel; or an equivalent cryptographic mechanism providing assurance of origin.

R.5.4.2.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the cryptographic mechanism used to provide assurance of origin; and
- the conditions under which the RDPS side accepts or rejects those interactions.

R.5.4.2.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic mechanism used to provide assurance of origin;
- verify that the RDPS side checks the authenticity-protection status of the interaction before acting upon it;
- verify that a valid interaction protected by the intended mechanism is accepted; and
- verify that an interaction lacking valid cryptographic assurance of origin is rejected or not acted upon.

R.5.4.2.4 Verdict

Pass:

- the RDPS side uses a cryptographic mechanism providing assurance of origin for relevant received interactions;
- the RDPS side verifies that protection before acting upon the interaction; and
- interactions without valid assurance of origin are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying cryptographic assurance of origin; or
- the RDPS side accepts and acts upon an interaction for which the required authenticity mechanism is absent or invalid.

R.5.4.2.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic authenticity mechanism;
- traces or logs showing successful acceptance of valid protected interactions; and
- traces or logs showing rejection or non-processing of interactions without valid assurance of origin.

R.5.4.3 Assessment case for REQ-RDPS-R-AUTH-003

R.5.4.3.1 Objective

The objective of the assessment is to verify that the RDPS side verifies that the cryptographic authenticity of the received interaction is bound to the intended local product-side endpoint and that replayed or stale interactions are detected and rejected where replay or reuse could affect secure operation.

R.5.4.3.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the mechanism used to bind authenticity to the intended local product-side endpoint; and
- the replay or freshness protection mechanism, where applicable.

R.5.4.3.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds the authenticity of the interaction to the intended local product-side endpoint;
- inspect the design and configuration of the freshness, anti-replay; or equivalent mechanism used;
- verify that a valid interaction bound to the intended local product-side endpoint is accepted;
- verify that an interaction with valid-looking authenticity protection but not bound to the intended local product-side endpoint is rejected or not acted upon; and

- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.4.3.4 Verdict

Pass:

- the RDPS side verifies that authenticity is bound to the intended local product-side endpoint; and
- replayed or stale interactions are rejected where replay or reuse could affect secure operation.

Fail:

- the RDPS side accepts and acts upon an interaction whose cryptographic authenticity is not bound to the intended local product-side endpoint; or
- the RDPS side fails to detect and reject replayed or stale interactions where such protection is required.

R.5.4.3.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for source binding and anti-replay/freshness controls;
- evidence showing acceptance of valid bound interactions; and
- evidence showing rejection of misbound, replayed; or stale interactions.

R.5.4.4 Assessment case for REQ-RDPS-R-INTEG-001

R.5.4.4.1 Objective

The objective of the assessment is to verify that the RDPS side checks that a relevant received interaction has not been modified, substituted, corrupted; or injected before acting upon it.

R.5.4.4.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the mechanism used by the RDPS side to detect modification, substitution, corruption; or injection.

R.5.4.4.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the integrity-checking mechanism;
- verify that integrity is checked before the interaction is acted upon;
- verify that an unmodified valid interaction is accepted; and
- verify that modified, substituted, corrupted; or injected interactions are rejected or not acted upon.

R.5.4.4.4 Verdict

Pass:

- the RDPS side checks the integrity of relevant received interactions before acting upon them; and

- modified, substituted, corrupted; or injected interactions are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying its integrity; or
- the RDPS side accepts and acts upon an altered, substituted, corrupted; or injected interaction.

R.5.4.4.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence of the integrity-checking mechanism;
- evidence showing acceptance of valid interactions; and
- evidence showing rejection or non-processing of altered or injected interactions.

R.5.4.5 Assessment case for REQ-RDPS-R-INTEG-002

R.5.4.5.1 Objective

The objective of the assessment is to verify that the RDPS side verifies the integrity of relevant received interactions using a cryptographic integrity-protection mechanism.

R.5.4.5.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions; and
- the cryptographic integrity-protection mechanism used for those interactions.

R.5.4.5.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic integrity-protection mechanism;
- verify that integrity verification takes place before the interaction is acted upon;
- verify that a valid cryptographically protected interaction is accepted; and
- verify that an interaction with missing or invalid integrity protection is rejected or not acted upon.

R.5.4.5.4 Verdict

Pass:

- the RDPS side uses cryptographic integrity protection for relevant received interactions;
- integrity verification is performed before the interaction is acted upon; and
- interactions with invalid or missing integrity protection are rejected or not acted upon.

Fail:

- the RDPS side does not use cryptographic integrity verification where required; or
- the RDPS side accepts and acts upon an interaction whose integrity protection is missing or invalid.

R.5.4.5.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic integrity mechanism;
- evidence showing acceptance of valid protected interactions; and
- evidence showing rejection of interactions with invalid or missing integrity protection.

R.5.4.6 Assessment case for REQ-RDPS-R-INTEG-003

R.5.4.6.1 Objective

The objective of the assessment is to verify that the RDPS side verifies that the relevant received interaction is protected by a cryptographic integrity-protection mechanism bound to the authenticated source of the interaction.

R.5.4.6.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the relevant received interactions;
- the authenticated source of those interactions; and
- the mechanism used to bind integrity protection to that authenticated source.

R.5.4.6.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the mechanism that binds integrity protection to the authenticated source;
- verify that a valid interaction whose integrity protection is correctly bound to the authenticated source is accepted;
- verify that an interaction with integrity protection not bound to the authenticated source is rejected or not acted upon; and
- verify that integrity verification and source binding checks are performed before the interaction is acted upon.

R.5.4.6.4 Verdict

Pass:

- the RDPS side verifies that the interaction is protected by cryptographic integrity protection bound to the authenticated source; and
- interactions not correctly bound to that source are rejected or not acted upon.

Fail:

- the RDPS side accepts and acts upon a relevant interaction whose integrity protection is not bound to the authenticated source; or
- the RDPS side acts upon the interaction before performing the required checks.

R.5.4.6.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for integrity binding to authenticated source;
- evidence showing acceptance of correctly bound interactions; and
- evidence showing rejection of misbound interactions.

R.5.4.7 Assessment case for REQ-RDPS-R-CONF-001

R.5.4.7.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

R.5.4.7.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk; and
- the mechanism used by the RDPS side to protect confidentiality during exchange.

R.5.4.7.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the confidentiality-protection mechanism;
- verify that the identified data is protected during exchange with the local product side; and
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner.

R.5.4.7.4 Verdict

Pass:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk; and
- such data is not exchanged in an unprotected manner.

Fail:

- the RDPS side does not protect the confidentiality of exchanged data where such protection is required; or
- identified confidential data is exchanged without appropriate confidentiality protection.

R.5.4.7.5 Evidence

The following evidence may be used to support the assessment:

- design or configuration evidence identifying the protected data and the means of protection; and
- evidence showing that relevant exchanged data is protected during exchange.

R.5.4.8 Assessment case for REQ-RDPS-R-CONF-002

R.5.4.8.1 Objective

The objective of the assessment is to verify that the RDPS side protects the confidentiality of relevant exchanged data using cryptographic confidentiality protection.

R.5.4.8.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the exchanged data requiring confidentiality protection; and
- the cryptographic confidentiality-protection mechanism used during exchange.

R.5.4.8.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality-protection mechanism;
- verify that the identified exchanged data is protected by that mechanism during exchange; and
- verify that exchange of such data without the required cryptographic confidentiality protection is prevented.

R.5.4.8.4 Verdict

Pass:

- relevant exchanged data is protected using cryptographic confidentiality protection; and
- exchange without the required cryptographic protection is prevented.

Fail:

- the RDPS side exchanges relevant confidential data without cryptographic confidentiality protection; or
- the configured confidentiality mechanism is not effectively applied to the relevant data exchange.

R.5.4.8.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for the cryptographic confidentiality mechanism; and
- evidence showing protected exchange of the relevant data.

R.5.4.9 Assessment case for REQ-RDPS-R-CONF-003

R.5.4.9.1 Objective

The objective of the assessment is to verify that the RDPS side uses cryptographic confidentiality protection established with the intended local product-side endpoint and preventing disclosure of exchanged data to endpoints other than that intended endpoint.

R.5.4.9.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;

- the exchanged data requiring stronger confidentiality protection;
- the intended local product-side endpoint; and
- the cryptographic mechanism used to establish confidentiality protection with that endpoint.

R.5.4.9.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the cryptographic confidentiality mechanism and its association with the intended local product-side endpoint;
- verify that protected exchange is established with the intended local product-side endpoint;
- verify that the RDPS side does not disclose the protected data to other endpoints under the same exchange context; and
- verify that exchanges not established with the intended local product-side endpoint are rejected or do not result in disclosure of the protected data.

R.5.4.9.4 Verdict

Pass:

- confidentiality protection is established with the intended local product-side endpoint;
- protected data is disclosed only to that intended endpoint; and
- exchanges with other endpoints do not result in disclosure of the protected data.

Fail:

- the RDPS side discloses protected data without establishing confidentiality protection with the intended local product-side endpoint; or
- the RDPS side discloses the protected data to endpoints other than the intended local product-side endpoint.

R.5.4.9.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for endpoint-associated confidentiality protection;
- evidence showing protected disclosure to the intended local product-side endpoint; and
- evidence showing prevention of disclosure to other endpoints.

R.5.4.10 Assessment case for REQ-RDPS-R-AVAIL-001

R.5.4.10.1 Objective

The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay; or intolerable degradation of required local product-side interactions, uses timeout or equivalent timeliness controls, and applies a defined behaviour for the RDPS-dependent product function.

R.5.4.10.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;

- the acceptable timing or service conditions for those interactions; and
- the defined behaviour to be applied when the required interactions are unavailable, delayed; or degraded.

R.5.4.10.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the timeout, timeliness; or equivalent detection controls;
- verify that unavailability, unacceptable delay; or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur; and
- verify that, under normal conditions, expected interactions are processed without triggering the fault-handling behaviour.

R.5.4.10.4 Verdict

Pass:

- the RDPS side detects the specified failure, delay; or degradation conditions;
- timeout or equivalent timeliness controls are used; and
- a defined behaviour is applied when the identified conditions occur.

Fail:

- the RDPS side does not detect the relevant failure, delay; or degradation condition; or
- the required defined behaviour is not applied when such a condition occurs.

R.5.4.10.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for detection and timeliness controls;
- evidence showing detection of failure, delay; or degradation; and
- evidence showing application of the defined behaviour.

R.5.4.11 Assessment case for REQ-RDPS-R-AVAIL-002

R.5.4.11.1 Objective

The objective of the assessment is to verify that the RDPS side applies a defined degraded behaviour or secure state when required local product-side interactions are unavailable, delayed; or degraded, and supports recovery of the RDPS-dependent product function where needed.

R.5.4.11.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the degraded behaviour or secure state defined for failure conditions; and
- any maintained state, configuration; or other recovery information required to restore secure operation.

R.5.4.11.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the degraded behaviour or secure-state mechanism;
- inspect the design and configuration of the recovery mechanism, where applicable;
- verify that when required interactions become unavailable, delayed beyond the acceptable time; or degraded beyond acceptable limits, the RDPS side applies the defined degraded behaviour or secure state; and
- verify that recovery support is available and can be used to restore secure operation where such support is required.

R.5.4.11.4 Verdict

Pass:

- the RDPS side applies the defined degraded behaviour or secure state under the relevant failure conditions; and
- recovery support is available and usable where necessary to restore secure operation.

Fail:

- the RDPS side does not apply the defined degraded behaviour or secure state under the relevant failure conditions; or
- required recovery support is absent or ineffective.

R.5.4.11.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for degraded behaviour, secure state, and recovery support; and
- evidence showing activation of degraded behaviour / secure state and restoration of secure operation where applicable.

R.5.4.12 Assessment case for REQ-RDPS-R-AVAIL-003

R.5.4.12.1 Objective

The objective of the assessment is to verify that the RDPS side supports higher resilience, including continuity of operation through failover, redundancy; or equivalent resilience mechanisms where necessary.

R.5.4.12.2 Preparation

Before starting the assessment, the following shall be identified:

- the RDPS-dependent product function;
- the required local product-side interactions;
- the defined degraded behaviour or secure state;
- the recovery support; and
- the failover, redundancy; or equivalent resilience mechanism, where required.

R.5.4.12.3 Activities

The assessment shall include the following activities:

- inspect the design and configuration of the resilience mechanism used to support continuity of operation;
- verify that the defined degraded behaviour or secure state is applied under the relevant failure conditions;
- verify that recovery support is available where required;
- where failover, redundancy; or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed; or degraded.

R.5.4.12.4 Verdict

Pass:

- the RDPS side supports the required resilience mechanism where necessary;
- defined degraded behaviour or secure state is applied under the relevant conditions; and
- continuity of operation is supported in accordance with the design where resilience is required.

Fail:

- a required resilience mechanism is absent or ineffective; or
- the RDPS side fails to support continuity of operation where such support is required.

R.5.4.12.5 Evidence

The following evidence may be used to support the assessment:

- design and configuration evidence for resilience, degraded behaviour, and recovery support; and
- evidence showing failover, redundancy; or equivalent continuity support where required.

R.5.5 Assessment cases for mono-level alternative proposals

R.5.5.1 Assessment case for REQ-RDPS-L-AUTH-001

R.5.5.1.1 Objective

The objective of the assessment is to verify that the local product side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.5.1.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the intended RDPS-side endpoint for those interactions;
- the mechanism used by the local product side to determine or verify the origin of the received interaction;

R.5.5.1.3 Activities

- inspect the design and configuration of the mechanism used by the local product side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended RDPS-side endpoint are accepted;

- verify that interactions not originating from the intended RDPS-side endpoint; or lacking required assurance of origin, are rejected or not acted upon;
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.5.1.4 Verdict

Pass:

- the local product side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon;

Fail:

- the local product side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, misbound, replayed; or stale interactions is not enforced.

R.5.5.1.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.2 Assessment case for REQ-RDPS-L-INTEG-001

R.5.5.2.1 Objective

The objective of the assessment is to verify that the local product side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated; or replayed interactions where required.

R.5.5.2.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the mechanism used by the local product side to detect modification, substitution, corruption, injection, duplication; or replay as applicable;

R.5.5.2.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the local product side;
- verify that integrity verification is performed before the interaction is acted upon;
- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted; or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.5.2.4 Verdict

Pass:

- the local product side verifies integrity of relevant interactions before acting upon them;
- modified, substituted, corrupted, injected, duplicated; or replayed interactions are rejected or not acted upon where required;

Fail:

- the local product side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, misbound, duplicated; or replayed interactions is not enforced.

R.5.5.2.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.3 Assessment case for REQ-RDPS-L-CONF-001

R.5.5.3.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the local product side protects the confidentiality of that data during exchange with the RDPS side.

R.5.5.3.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the local product side to protect confidentiality during exchange.

R.5.5.3.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the local product side;
- verify that the identified data is protected during exchange;
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner;

R.5.5.3.4 Verdict

Pass:

- the local product side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner;

Fail:

- the local product side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.5.3.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.4 Assessment case for REQ-RDPS-L-AVAIL-001

R.5.5.4.1 Objective

The objective of the assessment is to verify that the local product side detects unavailability, unacceptable delay; or intolerable degradation of required RDPS-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.5.4.2 Preparation

- the RDPS-dependent product function;
- the relevant RDPS-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed; or degraded;
- the degraded behaviour, secure state, recovery support; or continuity mechanism required by the selected requirement.

R.5.5.4.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection; or equivalent controls used by the local product side;
- verify that unavailability, unacceptable delay; or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required.
- where failover, redundancy; or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed; or degraded.

R.5.5.4.4 Verdict

Pass:

- the local product side detects the specified failure, delay; or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the local product side does not detect the relevant failure, delay; or degradation condition; or
- the required defined behaviour, recovery support; or continuity mechanism is absent or ineffective.

R.5.5.4.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.5 Assessment case for REQ-RDPS-R-AUTH-001

R.5.5.5.1 Objective

The objective of the assessment is to verify that the RDPS side verifies origin assurance for relevant received interactions using mechanisms commensurate with the security needs of the function and rejects replayed or stale interactions where required.

R.5.5.5.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the intended local product-side endpoint for those interactions;
- the mechanism used by the RDPS side to determine or verify the origin of the received interaction.

R.5.5.5.3 Activities

- inspect the design and configuration of the mechanism used by the RDPS side to verify the origin or data authenticity of the relevant interaction;
- verify that the origin or authenticity check is performed before the interaction is acted upon;
- verify that interactions from the intended local product-side endpoint are accepted;
- verify that interactions not originating from the intended local product-side endpoint; or lacking required assurance of origin, are rejected or not acted upon;
- where replay or reuse could affect secure operation, verify that replayed or stale interactions are detected and rejected.

R.5.5.5.4 Verdict

Pass:

- the RDPS side verifies origin or data authenticity of the relevant interaction before acting upon it;
- interactions lacking the required assurance of origin are rejected or not acted upon.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required origin or authenticity; or
- the required rejection of invalid, misbound, replayed; or stale interactions is not enforced.

R.5.5.5.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.6 Assessment case for REQ-RDPS-R-INTEG-001

R.5.5.6.1 Objective

The objective of the assessment is to verify that the RDPS side verifies integrity of relevant received interactions using mechanisms commensurate with the security needs of the function and rejects modified, substituted, corrupted, injected, duplicated; or replayed interactions where required.

R.5.5.6.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the mechanism used by the RDPS side to detect modification, substitution, corruption, injection, duplication; or replay as applicable.

R.5.5.6.3 Activities

- inspect the design and configuration of the integrity-protection mechanism used by the RDPS side;
- verify that integrity verification is performed before the interaction is acted upon;
- verify that a valid interaction is accepted;
- verify that modified, substituted, corrupted; or injected interactions are rejected or not acted upon;
- verify that integrity protection is bound to the authenticated source where required, and that replayed or duplicated interactions are rejected where replay or reuse could affect secure operation.

R.5.5.6.4 Verdict

Pass:

- the RDPS side verifies integrity of relevant interactions before acting upon them;
- modified, substituted, corrupted, injected, duplicated; or replayed interactions are rejected or not acted upon where required.

Fail:

- the RDPS side acts upon a relevant interaction without verifying required integrity; or
- the required rejection of altered, invalid, misbound, duplicated; or replayed interactions is not enforced.

R.5.5.6.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;

- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.7 Assessment case for REQ-RDPS-R-CONF-001

R.5.5.7.1 Objective

The objective of the assessment is to verify that, where disclosure of exchanged data could lead to unacceptable cybersecurity risk for the RDPS-dependent product function, the RDPS side protects the confidentiality of that data during exchange with the local product side.

R.5.5.7.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the categories of exchanged data for which disclosure could lead to unacceptable cybersecurity risk;
- the mechanism used by the RDPS side to protect confidentiality during exchange.

R.5.5.7.3 Activities

- inspect the design and configuration of the confidentiality-protection mechanism used by the RDPS side;
- verify that the identified data is protected during exchange;
- verify that data designated as requiring confidentiality is not exchanged in an unprotected manner;

R.5.5.7.4 Verdict

Pass:

- the RDPS side protects the confidentiality of exchanged data where disclosure could lead to unacceptable cybersecurity risk;
- such data is not exchanged in an unprotected manner.

Fail:

- the RDPS side exchanges relevant confidential data without the required confidentiality protection; or
- protected data is disclosed to an unintended endpoint.

R.5.5.7.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.5.5.8 Assessment case for REQ-RDPS-R-AVAIL-001

R.5.5.8.1 Objective

The objective of the assessment is to verify that the RDPS side detects unavailability, unacceptable delay; or intolerable degradation of required local product-side interactions, and applies a defined behaviour, including recovery or continuity measures where necessary.

R.5.5.8.2 Preparation

- the RDPS-dependent product function;
- the relevant local product-side interactions that can influence the behaviour, state, configuration, security; or availability of that function;
- the acceptable timing or service conditions for those interactions;
- the defined behaviour to be applied when the required interactions are unavailable, delayed; or degraded;
- the degraded behaviour, secure state, recovery support; or continuity mechanism required by the selected requirement.

R.5.5.8.3 Activities

- inspect the design and configuration of the timeout, timeliness, degradation-detection; or equivalent controls used by the RDPS side;
- verify that unavailability, unacceptable delay; or intolerable degradation of required interactions is detected;
- verify that a defined behaviour is applied when such conditions occur;
- verify that a defined degraded behaviour or secure state is applied where required;
- verify that recovery support is available and can be used to restore secure operation where required.
- where failover, redundancy; or equivalent resilience is required, verify that continuity of operation is supported when the primary interaction path becomes unavailable, delayed; or degraded.

R.5.5.8.4 Verdict

Pass:

- the RDPS side detects the specified failure, delay; or degradation conditions;
- a defined behaviour is applied when the identified conditions occur;
- recovery or continuity support is available and effective where required.

Fail:

- the RDPS side does not detect the relevant failure, delay; or degradation condition; or
- the required defined behaviour, recovery support; or continuity mechanism is absent or ineffective.

R.5.5.8.5 Evidence

- design and configuration evidence for the relevant protection mechanism;
- evidence showing acceptance or normal processing of valid interactions;
- evidence showing rejection, non-processing, protected exchange, recovery; or continuity behaviour for invalid or failure conditions, as applicable.

R.6 Mapping of CRA Annex I to Annex R requirements

Table R.5 identifies the CRA [i.1], Annex I Part I requirements that are directly relevant to the RDPS boundary and maps them to the corresponding Annex R requirements. The purpose of this mapping is to support manufacturer traceability and to identify directly relevant CRA requirements that are not yet fully covered by the present Annex R. Requirements not covered by Annex R remain addressed by the core part of the present document, insofar as they apply to the product as a whole.

Table R.5: CRA Annex I Part I ↔ Annex R requirements mapping

CRA Annex	CRA text (summary)	Annex R mapping	Rationale / gap observation
Part I (1)	Products with digital elements ensure an appropriate level of cybersecurity based on the risks.	Covered by the overall Annex R threat model, assets, and requirements, in particular REQ-RDPS-L-AUTH-001 to -003, REQ-RDPS-L-INTEG-001 to -003, REQ-RDPS-L-CONF-001 to -003, REQ-RDPS-L-AVAIL-001 to -003, and the corresponding RDPS-side requirements REQ-RDPS-R-AUTH-001 to -003, REQ-RDPS-R-INTEG-001 to -003, REQ-RDPS-R-CONF-001 to -003, REQ-RDPS-R-AVAIL-001 to -003.	Annex R identifies RDPS-boundary assets, associated security properties, aligned threats, and corresponding technical requirements. It does not itself define the manufacturer's risk assessment, but provides a technical framework to address RDPS-boundary risks once identified.
Part I (2)(a)	Products with digital elements are made available on the market without known exploitable vulnerabilities.	Covered by the requirements in the core part of the standard.	This is a broader product security, lifecycle, and vulnerability management obligation, not specifically an RDPS-boundary control.
Part I (2)(b)	Products with digital elements are made available on the market with a secure by default configuration.	Covered by the requirements in the core part of the standard.	This concerns broader product configuration requirements. Annex R is focused on RDPS-boundary interactions and does not itself define general secure-by-default product configuration requirements.
Part I (2)(c)	Products with digital elements ensure that vulnerabilities can be addressed through security updates.	Covered by the requirements in the core part of the standard.	This concerns broader product lifecycle and update capabilities and is not directly addressed by the RDPS-boundary requirement set of Annex R.
Part I (2)(d)	Protection from unauthorised access by appropriate control mechanisms, including authentication, identity or access management systems, and report on possible unauthorised access.	REQ-RDPS-L-AUTH-001 to -003 and REQ-RDPS-R-AUTH-001 to -003.	The primary Annex R contribution is protection against acceptance of interactions whose source or origin is not genuine.
Part I (2)(e)-(f)	Protection of confidentiality of stored/transmitted/processed data, and protection of integrity of such data, commands, programs and configuration against unauthorised manipulation or modification, including reporting on corruptions.	Confidentiality: REQ-RDPS-L-CONF-001 to -003 and REQ-RDPS-R-CONF-001 to -003. Integrity: REQ-RDPS-L-INTEG-001 to -003 and REQ-RDPS-R-INTEG-001 to -003.	The confidentiality requirements protect exchanged RDPS interaction content where disclosure creates unacceptable risk. The integrity requirements protect against modification, substitution, corruption; or injection of interactions.
Part I (2)(g)	Products with digital elements process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimization).	Covered by the requirements in the core part of the standard.	This concerns broader product-level data processing and minimisation requirements. Annex R does not specifically address minimisation of RDPS-boundary exchanged or processed data.

CRA Annex	CRA text (summary)	Annex R mapping	Rationale / gap observation
Part I (2)(h)	Protect the availability of essential and basic functions, including through resilience and mitigation measures against denial-of-service attacks.	REQ-RDPS-L-AVAIL-001 to -003 and REQ-RDPS-R-AVAIL-001 to -003.	These requirements address detection of unavailability, delay; or intolerable degradation, use of timeout or timeliness controls, defined degraded behaviour or secure state, support for recovery, and, at the stronger level, continuity of operation through failover, redundancy; or equivalent resilience mechanisms where necessary.
Part I (2)(i)	Products with digital elements minimize the negative impact by the products themselves or connected products on the availability of services provided by other products or networks.	Covered by the requirements in the core part of the standard.	This concerns broader product or network impact beyond the RDPS boundary and is therefore addressed by the core part of the standard rather than by Annex R.
Part I (2)(j)	Limit attack surfaces, including external interfaces.	REQ-RDPS-L-AUTH-001 to -003, REQ-RDPS-R-AUTH-001 to -003	The core part of the standard is expected to address general attack-surface limitation. Annex R contributes only indirectly at the RDPS boundary by verifying source authenticity.
Part I (2)(k)	Products with digital elements are designed, developed and produced to reduce the impact of an incident using appropriate exploitation mitigation mechanisms and techniques.	REQ-RDPS-L-AVAIL-002 to -003 and REQ-RDPS-R-AVAIL-002 to -003.	This is broader than the RDPS-boundary scope of Annex R. Annex R contributes indirectly through degraded behaviour, secure state, recovery support, and resilience measures, but does not provide a standalone exploitation-mitigation requirement family.
Part I (2)(l)	Products with digital elements provide security-related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions, with an opt-out mechanism for the user.	Covered by the requirements in the core part of the standard.	This concerns broader product-level logging, recording, monitoring, and user-facing control requirements.
Part I (2)(m)	Products with digital elements provide the possibility for users to securely and easily remove on a permanent basis all data and settings and, where such data can be transferred to other products or systems, ensure that this is done in a secure manner.	Covered by the requirements in the core part of the standard.	This concerns broader product-level data and settings lifecycle management and is outside the RDPS-boundary interaction focus of Annex R.

History

Version	Date	Status
V1.0.0	August 2026	SRdAP process EV 20261102: 2026-08-10 to 2026-11-02